

Manual de Segurança da Informação

Do básico ao avançado — fundamentos, ataque, defesa e governança

Vitor Mattos

30/07/2026

Índice

Apresentação	1
Para quem é este manual	1
Como o manual está organizado	2
Seções fixas de cada capítulo	3
Política editorial	3
Licença	3
I. Volume 1 — Fundamentos da Segurança da Informação	5
1. O que é segurança da informação	7
1.1. Uma definição de trabalho	7
1.2. Dado, informação e ativo: o que exatamente se protege	8
1.3. Segurança não é um estado, é um processo	9
1.4. Pessoas, processos e tecnologia	10
1.5. O adversário não é só o hacker	10
1.6. Quem ataca, e por que o pequeno também é alvo	11
1.7. Os princípios que sustentam qualquer defesa	12
1.8. O vocabulário mínimo	13
1.9. Como se sabe se está funcionando	13
1.10. Brasil em Foco	14
1.11. No Campo	15
1.12. Resumo	16
2. Os pilares: confidencialidade, integridade e disponibilidade	17
2.1. As três propriedades, com precisão	17
2.2. Confidencialidade	17
2.3. Integridade	19
2.4. Disponibilidade	20
2.5. As três colidem	21
2.6. A ordem de prioridade muda com o contexto	22
2.7. Além da tríade	22
2.8. Brasil em Foco	23
2.9. No Campo	23
2.10. Resumo	25
3. Autenticidade, não repúdio e responsabilização	27
3.1. Quatro coisas diferentes que se confundem	27
3.2. Autenticidade	28
3.3. Não repúdio	29
3.4. Responsabilização	30
3.5. Como as seis propriedades se encaixam	31
3.6. Brasil em Foco	32
3.7. No Campo	33

3.8. Resumo	35
4. Ativos, ameaças, vulnerabilidades e risco	37
4.1. A cadeia que liga os quatro termos	37
4.2. Ativos: o inventário é o alicerce	38
4.3. Ameaças: quem ou o quê, e com que capacidade	39
4.4. Vulnerabilidades: quatro tipos, não um	39
4.5. Risco: juntando tudo	41
4.6. Brasil em Foco	43
4.7. No Campo	44
4.8. Resumo	45
5. Modelagem de ameaças: STRIDE, árvores de ataque e abuse cases	47
5.1. O que é, e quando fazer	47
5.2. Pergunta 1: desenhar o sistema	48
5.3. Pergunta 2: o que pode dar errado	49
5.4. Outras abordagens, e quando usá-las	51
5.5. Pergunta 3: o que fazer, e pergunta 4: fizemos bem?	51
5.6. Brasil em Foco	52
5.7. No Campo	53
5.8. Resumo	54
6. Gestão de risco: análise qualitativa e quantitativa	55
6.1. O processo	55
6.2. Análise qualitativa	56
6.3. Análise quantitativa	57
6.4. Lidando com a incerteza: intervalos em vez de pontos	58
6.5. Escolher entre as duas	60
6.6. Tratamento e risco residual	60
6.7. Brasil em Foco	61
6.8. No Campo	62
6.9. Resumo	63
7. Ética, legalidade e a fronteira do escopo autorizado	65
7.1. A linha é jurídica, não técnica	65
7.2. O mapa legal brasileiro	66
7.3. Autorização: como ela é feita de verdade	67
7.4. Divulgação de vulnerabilidade	68
7.5. Bug bounty e programas de recompensa	69
7.6. Ética profissional além da lei	69
7.7. Onde praticar sem risco	70
7.8. Brasil em Foco	70
7.9. No Campo	71
7.10. Resumo	72
II. Volume 2 — Redes e Sistemas: a Base Técnica	75
8. A pilha TCP/IP sob a ótica do atacante e do defensor	77
8.1. Duas pilhas, um vocabulário	77
8.2. Camada 2: onde a confiança é total	78
8.3. Camada 3: endereços que ninguém verifica	79

8.4. Camada 4: o aperto de mão e seus abusos	80
8.5. O pecado original: confiança presumida	82
8.6. Onde cada defesa mora	83
8.7. Brasil em Foco	83
8.8. No Campo	84
8.9. Resumo	85
9. Endereçamento, roteamento e NAT	87
9.1. Endereçamento IPv4 e a matemática que não dá para evitar	87
9.2. IPv6: o que muda de verdade	89
9.3. Roteamento: como o pacote encontra o caminho	89
9.4. NAT: o que ele faz e o que ele não faz	90
9.5. Brasil em Foco	92
9.6. No Campo	92
9.7. Resumo	94
10. Protocolos de aplicação e seus riscos: HTTP, DNS, SMTP e SNMP	95
10.1. O padrão comum: texto claro e confiança presumida	95
10.2. HTTP: simples por fora, complexo por dentro	96
10.3. DNS: a lista telefônica que qualquer um pode adulterar	97
10.4. SMTP: o protocolo que confia no remetente	99
10.5. SNMP: a porta dos fundos do parque de equipamentos	100
10.6. O inventário de protocolos: o exercício que ninguém faz	100
10.7. Brasil em Foco	101
10.8. No Campo	101
10.9. Resumo	103
11. Fundamentos de sistemas operacionais: processos, permissões e memória	105
11.1. O anel de proteção: a fronteira que sustenta tudo	105
11.2. Processos: identidade, herança e contexto	106
11.3. Permissões: dois modelos para o mesmo problema	107
11.4. Memória: onde a exploração acontece	107
11.5. Isolamento: quando o processo não basta	109
11.6. Lendo o que a máquina conta	110
11.7. Brasil em Foco	110
11.8. No Campo	111
11.9. Resumo	113
12. Linux essencial para segurança	115
12.1. O sistema de arquivos como mapa mental	115
12.2. Como a máquina arranca — e onde a persistência mora	116
12.3. Usuários, grupos e o que o sudo realmente permite	116
12.4. SSH: a porta principal	117
12.5. Registros: o que o sistema conta	118
12.6. Rede vista de dentro da máquina	119
12.7. Os quinze comandos da triagem	119
12.8. Endurecimento: a lista curta que vale a pena	120
12.9. Brasil em Foco	120
12.10. No Campo	121
12.11. Resumo	123

13. Windows e Active Directory essencial	125
13.1. Como o Windows pensa	125
13.2. Active Directory: o mapa da confiança	126
13.3. Autenticação: NTLM, Kerberos e a memória da estação	126
13.4. Os caminhos de escalada que existem sem falha nenhuma	128
13.5. Registros e detecção: o que ligar antes de precisar	129
13.6. Brasil em Foco	130
13.7. No Campo	130
13.8. Resumo	132
14. Virtualização e montagem do laboratório de estudos	133
14.1. Virtualização: o que a fronteira realmente vale	133
14.2. O laboratório mínimo	134
14.3. O que instalar, em que ordem	135
14.4. Plataformas de treino: o complemento	136
14.5. Um roteiro de exercícios que percorre o volume	137
14.6. Brasil em Foco	137
14.7. No Campo	138
14.8. Resumo	140
 III. Volume 3 — Criptografia Aplicada	 141
15. História e princípios da criptografia	143
16. Criptografia simétrica: AES, modos de operação e AEAD	145
17. Funções hash, HMAC e integridade	147
18. Criptografia assimétrica: RSA, Diffie-Hellman e curvas elípticas	149
19. PKI, certificados digitais e cadeias de confiança	151
20. TLS na prática: handshake, versões e configuração segura	153
21. Erros clássicos: criptografia mal empregada	155
 IV. Volume 4 — Identidade, Autenticação e Controle de Acesso	 157
22. Modelos de controle de acesso: DAC, MAC, RBAC e ABAC	159
23. Senhas: armazenamento, políticas e ataques	161
24. Autenticação multifator e fatores de autenticação	163
25. Federação de identidade: SAML, OAuth 2.0 e OpenID Connect	165
26. Gestão de identidades e de acessos privilegiados (IAM e PAM)	167
27. Arquitetura Zero Trust	169

V. Volume 5 — Segurança de Redes	171
28.Arquitetura segura e segmentação de redes	173
29.Firewalls: tipos, políticas e boas práticas	175
30.VPNs: IPsec, WireGuard e acesso remoto seguro	177
31.IDS, IPS e detecção em rede	179
32.Segurança de DNS: ataques, DNSSEC e DoH	181
33.Segurança do roteamento e BGP: sequestros, vazamentos e RPKI	183
34.Segurança em redes sem fio e enlaces de rádio	185
35.Ataques de negação de serviço e estratégias de mitigação	187
 VI. Volume 6 — Endpoints e Sistemas Operacionais	 189
36.Hardening de servidores Linux	191
37.Hardening de Windows e Active Directory	193
38.Antivírus, EDR e XDR	195
39.Gestão de vulnerabilidades e ciclo de patches	197
40.Segurança de dispositivos móveis e BYOD	199
41.Criptografia de disco e proteção de dados em repouso	201
 VII. Volume 7 — Segurança de Aplicações	 203
42.Ciclo de desenvolvimento seguro e DevSecOps	205
43.OWASP Top 10: panorama e como usar	207
44.Injeção: SQL, NoSQL e comandos de sistema	209
45.Cross-site scripting e ataques no lado do cliente	211
46.Falhas de autenticação e gestão de sessão	213
47.Falhas de controle de acesso: IDOR, SSRF e escalonamento	215
48.Segurança de APIs REST e GraphQL	217
49.SAST, DAST, SCA e automação de testes de segurança	219
 VIII. Volume 8 — Nuvem e Contêineres	 221
50.Modelo de responsabilidade compartilhada	223

51. IAM em nuvem e os erros de configuração mais caros	225
52. Segurança de contêineres e de imagens	227
53. Segurança em Kubernetes	229
54. Infraestrutura como código e segurança de pipeline	231
55. Segredos, cofres e gestão de chaves	233
IX. Volume 9 — Testes de Invasão	235
56. Metodologias e definição de escopo: PTES, OSSTMM e NIST SP 800-115	237
57. Reconhecimento passivo e OSINT	239
58. Varredura e enumeração	241
59. Análise de vulnerabilidades	243
60. Exploração: conceitos e anatomia de uma falha	245
61. Pós-exploração, persistência e movimentação lateral	247
62. Teste de invasão em aplicações web na prática	249
63. Relatório técnico e comunicação de achados	251
X. Volume 10 — Fator Humano	253
64. Engenharia social: os princípios psicológicos da persuasão	255
65. Phishing, spear phishing e fraude do e-mail corporativo	257
66. Fraudes digitais no Brasil: Pix, clonagem e golpes por mensageria	259
67. Segurança física e ataques presenciais	261
68. Cultura de segurança e programas de conscientização	263
XI. Volume 11 — Malware e Inteligência de Ameaças	265
69. Taxonomia de malware	267
70. Anatomia de um ataque de ransomware	269
71. Análise estática em laboratório	271
72. Análise dinâmica e sandboxing	273
73. MITRE ATT&CK e o mapeamento de TTPs	275
74. Inteligência de ameaças e indicadores de comprometimento	277

XII. Volume 12 — Blue Team, SOC e Detecção	279
75. Estrutura e operação de um SOC	281
76. Logging: o que registrar, por quanto tempo e por quê	283
77. SIEM: arquitetura, ingestão e correlação	285
78. Escrita de regras de detecção com Sigma e YARA	287
79. Threat hunting: caçando o que a regra não pegou	289
80. Deception: honeypots, honeytokens e canários	291
81. Métricas e maturidade da detecção	293
 XIII. Volume 13 — Resposta a Incidentes e Forense Digital	 295
82. O ciclo de resposta a incidentes	297
83. Preparação: plano, papéis e playbooks	299
84. Contenção, erradicação e recuperação	301
85. Fundamentos de forense digital e cadeia de custódia	303
86. Forense de disco e sistemas de arquivos	305
87. Forense de memória	307
88. Forense de rede e análise de tráfego	309
 XIV. Volume 14 — Continuidade e Resiliência	 311
89. Backup: estratégias e a regra 3-2-1-1-0	313
90. Recuperação de desastres e continuidade de negócio	315
91. Testes de continuidade e exercícios de mesa	317
92. Alta disponibilidade e resiliência de infraestrutura	319
93. Recuperação após um ataque de ransomware	321
 XV. Volume 15 — Governança, Risco e Conformidade	 323
94. Governança de segurança e o papel do CISO	325
95. ISO/IEC 27001 e 27002	327
96. NIST Cybersecurity Framework e CIS Controls	329
97. LGPD na prática: bases legais, incidentes e a ANPD	331

98.Marco Civil, Lei 12.737 e o direito penal digital brasileiro	333
99.Obrigações regulatórias de provedores de internet	335
100PCI-DSS e requisitos setoriais	337
101Auditoria, conformidade e gestão de riscos de terceiros	339
XVIVolume 16 — Fronteira e Carreira	341
102Segurança de sistemas de IA e modelos de linguagem	343
103Criptografia pós-quântica	345
104Segurança de OT, IoT e sistemas embarcados	347
105Segurança da cadeia de suprimentos de software	349
106Privacidade, anonimato e vigilância	351
107Carreira, certificações e aprendizado contínuo	353
Referências	355

Apresentação

Este manual cobre segurança da informação do básico ao avançado, em português, com foco em construir entendimento real em vez de decorar siglas. Ele nasce da premissa de que segurança não é uma disciplina isolada: é a consequência de entender profundamente como redes, sistemas operacionais, criptografia e pessoas realmente funcionam — e onde essas engrenagens se desencaixam.

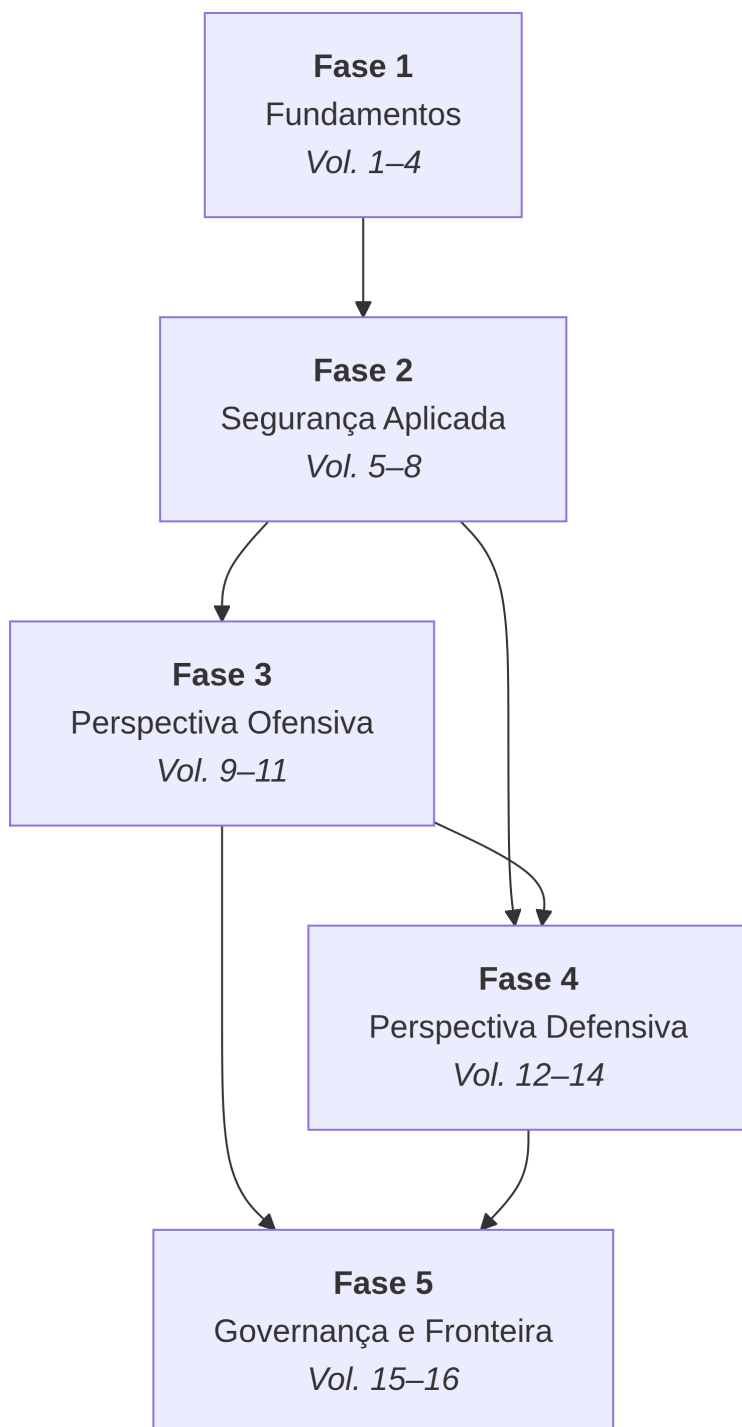
São **107 capítulos** distribuídos em **16 volumes** e **5 fases**, escritos para serem lidos em sequência por quem está começando, e consultados por assunto por quem já atua na área.

Para quem é este manual

- Quem está entrando na área e quer uma trilha ordenada em vez de tutoriais soltos
- Profissionais de infraestrutura e redes que precisam incorporar segurança ao dia a dia
- Desenvolvedores que querem entender as falhas que produzem sem perceber
- Estudantes preparando-se para certificações (Security+, CEH, CISSP, OSCP) que precisam da base conceitual antes do material de prova

Não é preciso conhecimento prévio de segurança. É preciso, sim, disposição para acompanhar os fundamentos técnicos do Volume 2 antes de correr para as partes mais chamativas.

Como o manual está organizado



Dependências entre as fases do manual

A **Fase 1** estabelece o vocabulário e a base técnica: o que é risco, como funcionam redes e sistemas, criptografia e controle de acesso. A **Fase 2** aplica isso aos domínios concretos — redes, endpoints, aplicações e nuvem. As fases **3** e **4** apresentam os dois lados da mesma moeda: como se ataca e como se detecta e responde. A **Fase 5** fecha com governança, conformidade brasileira e os temas de fronteira.

Ataque e defesa aparecem nesta ordem por um motivo pedagógico: não se detecta o que não se

compreende. Mas as duas fases são complementares, não sequenciais — quem só quer defender pode ler a Fase 4 antes da 3, aceitando algumas referências para frente.

Seções fixas de cada capítulo

Todo capítulo traz duas seções obrigatórias ao final:

i **Brasil em Foco** — como o tema se conecta à legislação e às instituições brasileiras: LGPD e ANPD, Marco Civil, Lei 12.737, Anatel, CERT.br, Gov.br, Banco Central e Pix.

💡 **No Campo** — a tradução do conceito para a operação real de infraestrutura: o que muda no dia a dia de quem administra rede, servidores e clientes.

Política editorial

! Escopo, ética e legalidade

Este manual é material educacional com orientação defensiva. Técnicas ofensivas são apresentadas para que se possa **entender, detectar e mitigar** ataques — nunca como receita operacional.

Na prática, isso significa: explicamos mecanismos, usamos ferramentas públicas e consagradas em laboratório isolado, e mostramos as contramedidas correspondentes. Não publicamos exploits armados, payloads prontos para uso, nem código de malware funcional.

Testar sistemas sem autorização formal e por escrito é crime no Brasil (Lei 12.737/2012, art. 154-A do Código Penal). O Volume 9 trata escopo e autorização como pré-requisito, não como formalidade. Monte seu laboratório (Capítulo 14) e pratique apenas nele ou em plataformas que autorizam explicitamente.

Licença

Conteúdo sob licença [CC BY-SA 4.0](#). Código e scripts sob licença MIT. Contribuições, correções e sugestões são bem-vindas via issues no repositório.

Parte I.

**Volume 1 — Fundamentos da
Segurança da Informação**

1. O que é segurança da informação

Numa terça-feira de março, às 6h40, o técnico de plantão de um provedor regional atende o primeiro chamado do dia: um assinante não consegue emitir a segunda via da fatura. Às 7h10 são doze chamados. Às 7h30 fica claro que o problema não é o portal de faturas — é o sistema de gestão inteiro, o ERP que emite boleto, controla contrato e guarda o cadastro de quatro mil assinantes. A tela de login abre. A senha do administrador não é aceita. No servidor, os arquivos do banco de dados continuam todos lá, com uma extensão nova grudada no fim. Na raiz do disco há um arquivo de texto com um endereço de carteira de criptomoeda e um prazo.

Vale olhar primeiro o que **não** falhou naquela manhã. O link de saída estava perfeito, com 6 ms de latência para o PTT. Nenhum alarme do monitoramento disparou, porque o monitoramento vigiava latência, perda de pacote, potência óptica e temperatura de rack — e os quatro estavam normais. O firewall de borda seguia bloqueando exatamente aquilo que alguém havia configurado para bloquear, sem errar um pacote. Toda a infraestrutura funcionou conforme especificada. E a empresa parou por seis dias.

O caminho, reconstruído depois, foi banal. Uma conta de VPN criada dois anos antes para um consultor, com senha reaproveitada de outro serviço que havia vazado, sem segundo fator. De dentro da VPN, uma porta de área de trabalho remota alcançável e uma conta de administrador local repetindo a mesma senha em três servidores. O backup existia — em um compartilhamento de rede montado permanentemente como unidade Z: no próprio servidor do ERP, e por isso foi cifrado junto.

No mesmo mês, essa empresa teve outros dois incidentes que ninguém chamou de incidente. Um notebook do comercial foi furtado de dentro de um carro, com uma planilha de 1.200 assinantes — nome, CPF, endereço, telefone — em disco sem cifragem. E um técnico desligado em janeiro seguiu com acesso administrativo à OLT por 40 dias, porque o desligamento passou pelo RH e pela folha, mas não por ninguém que soubesse quais credenciais aquela pessoa carregava.

Os três episódios são incidentes de segurança da informação. Nenhum dos três se resolve comprando um equipamento. É desse desconforto que a disciplina nasce.

1.1. Uma definição de trabalho

A norma ISO/IEC 27000 define segurança da informação como a **preservação da confidencialidade, da integridade e da disponibilidade da informação** (International Organization for Standardization, 2018a). É uma frase curta e bem mais densa do que parece.

Preservação implica continuidade: não é estado que se alcança e se declara, é algo que se mantém contra uma tendência natural de degradação. *Informação* — não servidor, não rede, não software. E as três propriedades, que o próximo capítulo abre em detalhe:

- **Confidencialidade** — a informação só é acessível a quem tem direito a ela.
- **Integridade** — a informação está correta e completa, e alterações não autorizadas são impedidas ou, no mínimo, detectáveis.
- **Disponibilidade** — quem tem direito à informação a alcança quando precisa.

1. O que é segurança da informação

Os três pilares são necessários, mas não bastam: uma transação bancária exige também que a origem seja comprovadamente quem afirma ser (autenticidade) e que depois não possa negar tê-la feito (não repúdio) — assunto do capítulo seguinte ao próximo.

A definição operacional que este manual carrega é esta:

Segurança da informação é o conjunto de decisões — técnicas, organizacionais e humanas — que mantém a informação disponível para quem tem direito a ela, íntegra para quem depende dela e inalcançável para quem não deveria chegar até ela, dentro de um custo que a organização consegue sustentar de forma contínua.

A última cláusula é a que separa segurança de teatro de segurança: um controle que a empresa não consegue pagar, operar e manter por três anos não é controle, é linha de relatório.

Vale notar desde já que os três pilares **entram em conflito entre si**. Cifrar o backup protege a confidencialidade e cria um risco novo de disponibilidade: chave perdida significa backup inútil. Exigir troca de senha a cada 30 dias parece reforçar o controle de acesso e, na prática, produz **Verão2026!** escrito num post-it colado no monitor da recepção. Segurança da informação é, em boa medida, escolher esses tradeoffs conscientemente em vez de tropeçar neles.

1.2. Dado, informação e ativo: o que exatamente se protege

10.20.0.42 é um dado. “Endereço de gerência da OLT do distrito de Santa Rita, acessível apenas pela VLAN 900” é informação: o dado mais o contexto que o torna útil — e, no mesmo movimento, útil para um atacante.

Ativo é qualquer coisa que tenha valor para a organização, e separá-los em dois níveis é prático:

- **Ativos primários** — a informação em si e os processos de negócio que dependem dela. O cadastro de assinantes. A base de contratos. A capacidade de faturar no dia 5.
- **Ativos de suporte** — o que sustenta os primários: hardware, software, rede, instalações, e as pessoas. O servidor do ERP, a fibra do backbone, a torre de rádio, o técnico que sabe reconfigurar a OLT.

A inversão que a disciplina propõe é esta: o objeto de proteção é o ativo primário, mas os controles quase sempre se aplicam aos de suporte. Ninguém cifra “o cadastro de assinantes” em abstrato — cifra-se o disco, restringe-se a conta, segmenta-se a VLAN.

E a informação não fica parada: percorre um ciclo, e cada etapa tem controles próprios (Figura 1.1).

O descarte é a etapa esquecida com mais frequência, e a que produz vazamentos mais silenciosos: o disco do servidor trocado por defeito que vai para o ferro-velho com o banco de dados legível; o roteador de borda vendido em marketplace com a configuração completa da rede, incluindo chaves de BGP. Nenhum desses casos tem atacante, exploração ou malware. Todos são falhas de confidencialidade.

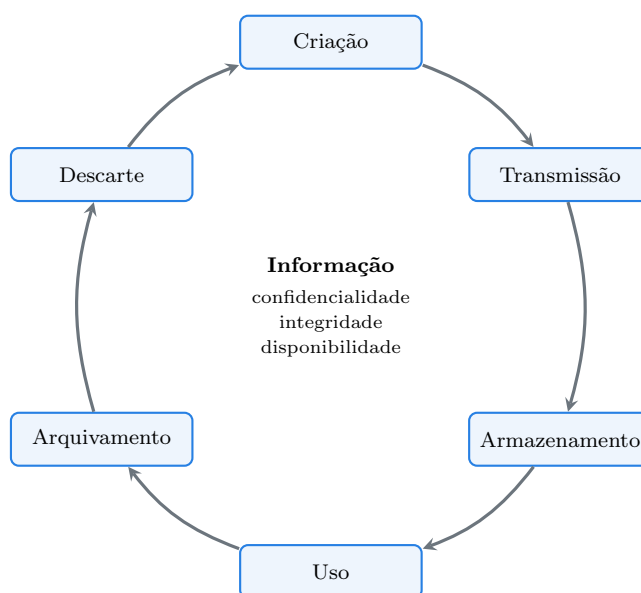


Figura 1.1.: O ciclo de vida da informação. Um controle que só cobre uma etapa deixa as outras cinco expostas.

1.3. Segurança não é um estado, é um processo

A frase é de Bruce Schneier e virou clichê justamente porque resolve uma confusão persistente (Schneier, 2000). Segurança absoluta é alcançável: desliga-se o equipamento, retira-se o disco, lacra-se num cofre. O sistema fica perfeitamente seguro e perfeitamente inútil. Todo sistema real opera num ponto intermediário, e o nome desse ponto é **risco residual**.

O que a disciplina persegue não é risco zero, é risco residual *conhecido e aceito conscientemente* — decidido por quem tem autoridade, documentado e revisitado. A diferença entre uma empresa madura e uma imprudente raramente está no número de controles: está em saber, ou não saber, o que ficou descoberto.

Existe uma razão econômica para isso, esboçada em Figura 1.2.

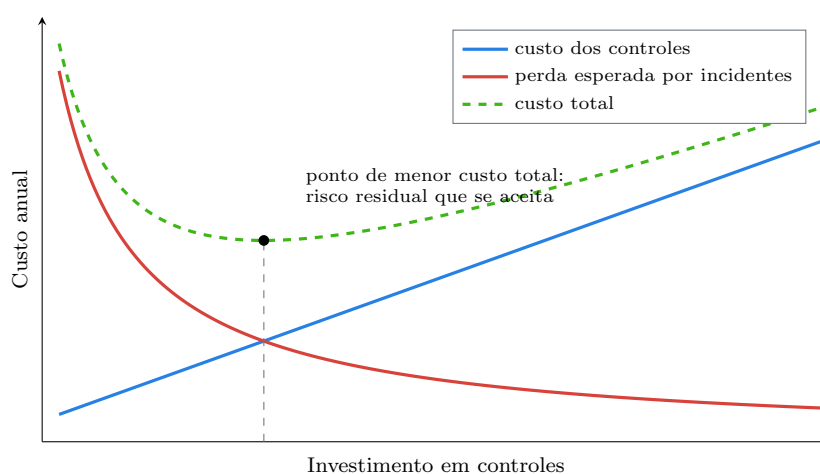


Figura 1.2.: A lógica econômica do controle. Passado certo ponto, cada real gasto em segurança compra menos redução de perda esperada do que custa.

1. O que é segurança da informação

O gráfico é uma idealização didática: na vida real não se conhecem os valores das curvas com precisão, e é por isso que existe gestão de risco como método — tema do sexto capítulo deste volume. O que importa é a *forma*: há um ponto além do qual gastar mais destrói valor, e um ponto abaixo do qual economizar destrói a empresa.

Há uma segunda razão para tratar segurança como processo: **as configurações envelhecem**. Um servidor perfeitamente endurecido em 2023 acumula, até 2026, bibliotecas com falhas conhecidas, cifras que deixaram de ser aceitáveis e regras de firewall abertas “temporariamente” para um teste que ninguém fechou. Toda base de regras com cinco anos contém alguma liberação cuja justificativa ninguém sabe mais explicar, e que ninguém remove por medo de derrubar algo.

1.4. Pessoas, processos e tecnologia

O incidente da abertura é um exemplo didático de por que a tecnologia isolada não fecha a conta. Vale reler o caso separando as camadas:

Tabela 1.1.: As três camadas do incidente de abertura.

Camada	O que falhou
Tecnologia	VPN sem segundo fator, rede interna plana, senha de administrador local repetida, backup em unidade montada
Processo	desligamento sem revogação de credencial, nenhuma revisão periódica de contas, backup nunca testado por restauração
Pessoas	senha reaproveitada de outro serviço, conta de terceiro esquecida ativa por dois anos

Nenhuma das três falhas de processo custa dinheiro para corrigir; todas custam disciplina, que é mais escassa. E o investimento típico vai no sentido inverso — 90% do orçamento em tecnologia —, o que explica por que empresas bem equipadas continuam sendo comprometidas por caminhos elementares.

1.5. O adversário não é só o hacker

A palavra “ameaça” evoca uma pessoa mal-intencionada, e essa associação estreita indevidamente o campo. Convencionalmente, separam-se três origens:

Deliberadas. Ação intencional de um agente: fraude, extorsão por ransomware, sabotagem, espionagem, furto de equipamento.

Acidentais. Erro humano sem intenção: o comando DROP no banco de produção em vez do de teste; a rota redistribuída por engano que anuncia prefixo de terceiro; o e-mail com anexo de dados pessoais enviado para a lista errada. Em volume de incidentes, esta categoria rivaliza com a primeira — e em algumas organizações a supera.

Ambientais e naturais. Descarga atmosférica na torre de rádio que leva switch, conversor e fonte no mesmo estouro. Falta de energia de nove horas num site remoto cujo banco de baterias tem autonomia de duas. Roçadeira de trator que rompe o ramal de fibra do distrito na época da

colheita. Furto de bateria de nobreak em site sem cerca — que, para quem opera rede rural, é ameaça deliberada e ambiental ao mesmo tempo.

Para quem administra infraestrutura, essa terceira categoria é com frequência a maior fonte de horas de indisponibilidade do ano — e disponibilidade é um dos três pilares. Não é curiosidade taxonômica: o mesmo arcabouço (inventariar ativos, estimar risco, implantar controle, exercitar resposta) serve para o raio e para o ransomware. Plano de resposta que só sabe lidar com atacante é metade de um plano.

1.6. Quem ataca, e por que o pequeno também é alvo

Entre os agentes deliberados, os perfis diferem tanto em capacidade quanto em motivação, e a diferença muda a defesa apropriada:

- **Oportunista automatizado.** Não escolheu você. Varre faixas inteiras de endereços procurando serviço exposto com credencial padrão ou falha conhecida. É a esmagadora maioria do que se vê nos logs.
- **Crime organizado.** Opera como negócio, com divisão de trabalho: quem obtém o acesso inicial vende para quem executa a extorsão, que aluga o programa de cifragem de um terceiro. É a economia que tornou ransomware viável contra empresas de qualquer porte.
- **Pessoa interna.** Do funcionário insatisfeito com acesso privilegiado ao terceirizado negligente que reutiliza senha. Não precisa vencer perímetro nenhum: já está dentro.
- **Ativismo.** Motivação ideológica, alvo escolhido pelo que representa e busca de visibilidade: pichação de site, vazamento seletivo, indisponibilidade em data simbólica.
- **Estado-nação.** Recursos altos, paciência longa, alvo deliberadamente escolhido. Raro como adversário direto de uma empresa média — mas provedores de telecomunicações e cadeias de suprimento são alvos de interesse justamente por serem caminho para outros.

Um servidor SSH recém-exposto coleta tentativas de acesso em minutos, sempre com esta cara:

```
Mar 12 03:11:44 borda sshd[2291]: Failed password for invalid user admin from
↪ 203.0.113.47 port 51344 ssh2
Mar 12 03:11:46 borda sshd[2293]: Failed password for invalid user ubnt from
↪ 203.0.113.47 port 51402 ssh2
Mar 12 03:11:49 borda sshd[2295]: Invalid user support from 198.51.100.12 port
↪ 44120
Mar 12 03:11:52 borda sshd[2297]: Failed password for root from 198.51.100.12
↪ port 44188 ssh2
Mar 12 03:12:03 borda sshd[2301]: Failed password for invalid user pi from
↪ 203.0.113.190 port 33012 ssh2
```

Os nomes de usuário entregam o jogo: **admin**, **ubnt**, **support** e **pi** são credenciais de fábrica de equipamentos de rede e placas embarcadas. Ninguém decidiu atacar aquele endereço — um programa varre a internet inteira, e o endereço apareceu na lista. O custo marginal de tentar em um alvo a mais é zero, e é por isso que “sou pequeno, ninguém vai me atacar” é premissa falsa por construção.

Há um segundo motivo, mais específico. Uma empresa pequena que administra rede guarda dados pessoais em volume (CPF, endereço, meio de pagamento) e opera equipamentos de cliente que, tomados em massa, valem como capacidade de ataque: milhares de roteadores domésticos com credencial padrão são ativo de mercado para quem monta rede de ataque distribuído. Nessa configuração, a infraestrutura não é apenas alvo — é vetor contra os próprios assinantes.

1.7. Os princípios que sustentam qualquer defesa

Em 1975, Saltzer e Schroeder publicaram oito princípios de projeto para proteção da informação (Saltzer; Schroeder, 1975). Cinco décadas depois, com toda a tecnologia trocada, seguem sendo o melhor filtro para avaliar uma decisão de segurança:

1. **Economia de mecanismo.** O desenho mais simples que resolve. Complexidade é onde erro se esconde.
2. **Padrões à prova de falha.** Negar por padrão; permitir por exceção explícita. Se o mecanismo falhar, deve falhar fechado.
3. **Mediação completa.** Toda requisição verificada, sempre. Atalhos de desempenho que reaproveitam decisões antigas de autorização são a origem de uma classe inteira de falhas.
4. **Desenho aberto.** A segurança não deve depender do segredo do desenho, apenas do segredo da chave. Criptografia proprietária “secreta” é sinal de alerta, não de força.
5. **Separação de privilégios.** Exigir mais de uma condição independente para a operação crítica — a lógica das duas chaves do cofre, e a razão de ser da autenticação em dois fatores.
6. **Menor privilégio.** Cada sujeito com o mínimo de permissão necessário, pelo menor tempo necessário. É o princípio mais violado da lista: quase toda rede tem contas de serviço com privilégio administrativo porque “assim funciona”.
7. **Mecanismo menos comum.** Evitar compartilhar mecanismo e estado entre usuários diferentes; o que é compartilhado se torna caminho entre eles.
8. **Aceitação psicológica.** O controle precisa ser utilizável. Controle que atrapalha o trabalho é controle burlado — e a criatividade do usuário para burlar é ilimitada.

Desses princípios decorre a estratégia que organiza tudo o que vem nos volumes seguintes: **defesa em profundidade**. Nenhuma camada é considerada confiável o suficiente para ser a única, e o comprometimento de uma não deve implicar o comprometimento das demais (Figura 1.3).

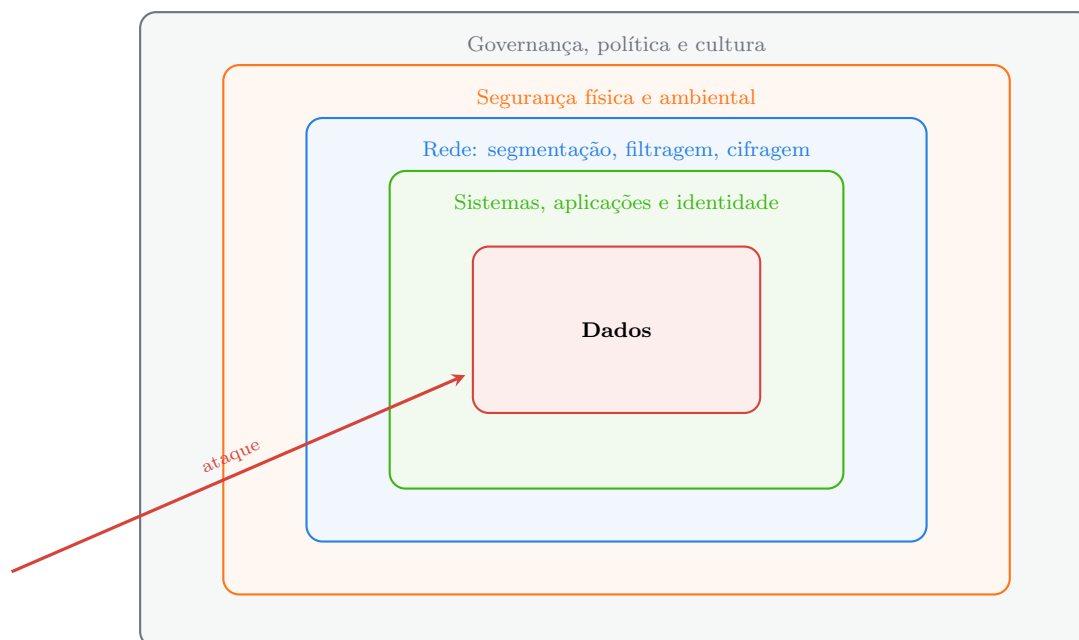


Figura 1.3.: Defesa em profundidade. Cada camada compra tempo e gera registro; nenhuma é suficiente sozinha.

Duas ressalvas importam desde já. Camadas precisam ser **independentes**: cinco que aceitam a mesma senha de administrador são, na prática, uma. E camadas servem para *detectar*, não

só para bloquear — o valor de uma camada intermediária costuma estar menos em barrar o atacante do que em produzir o registro que revela sua passagem enquanto há tempo de reagir. Assumir que o comprometimento vai acontecer e projetar para detectá-lo rápido atravessa toda a parte defensiva deste manual.

1.8. O vocabulário mínimo

Segurança da informação tem vocabulário próprio, em que palavras do uso cotidiano ganham sentido técnico estrito. Confundi-las produz conversas em que ninguém está errado e ninguém se entende. A Tabela 1.2 fixa o mínimo para seguir adiante; o quarto capítulo deste volume aprofunda cada termo.

Tabela 1.2.: Vocabulário mínimo de segurança da informação.

Termo	Sentido técnico	No caso de abertura
Ativo	Aquilo que tem valor e que se quer proteger	O cadastro dos quatro mil assinantes
Vulnerabilidade	Fraqueza que pode ser explorada	VPN sem segundo fator; senha repetida entre servidores
Ameaça	Agente ou evento com potencial de causar dano	Grupo de extorsão que compra acesso inicial
Risco	Combinação de probabilidade e impacto de a ameaça explorar a vulnerabilidade	Alta chance de parada de faturamento por vários dias
Controle	Medida que reduz risco, por prevenção, detecção ou correção	Segundo fator na VPN; backup fora do alcance do servidor
Evento	Qualquer ocorrência observável no ambiente	Uma autenticação falha às 3h11
Incidente	Evento, ou série de eventos, que compromete um dos pilares	A cifragem do banco de dados do ERP
Superfície de ataque	Conjunto de pontos alcançáveis por um adversário	VPN, área de trabalho remota, portal do assinante
Risco residual	O que permanece depois dos controles aplicados	O que se decide conviver, sabendo que existe

Duas dessas distinções têm consequência operacional direta. Uma rede grande gera milhões de *eventos* por dia, e a função de um centro de operações é separar os poucos que são *incidentes*. E como não se elimina a *ameaça* — ninguém acaba com o crime organizado a partir do datacenter —, o trabalho recai sobre reduzir vulnerabilidade e impacto.

1.9. Como se sabe se está funcionando

“Nunca fomos invadidos” não é evidência de segurança; costuma ser evidência de ausência de detecção — comprometimentos que duram meses sem serem percebidos são a regra, e a descoberta vem com frequência de fora: um cliente, um pesquisador, ou o próprio atacante ao pedir resgate.

1. O que é segurança da informação

Medir é difícil justamente porque o resultado desejado é a não ocorrência de algo, mas alguns indicadores sobrevivem ao escrutínio:

- **Tempo até detectar e tempo até conter.** Se a resposta é “não sabemos”, esse é o primeiro problema a resolver.
- **Cobertura de controle sobre inventário.** Percentual de ativos inventariados, de contas com segundo fator, de servidores corrigidos no prazo, de backups cuja restauração foi testada no trimestre. Todas dependem de existir inventário.
- **Superfície exposta.** Quantidade de serviços administrativos alcançáveis da internet. A meta é zero, e o número é fácil de medir.
- **Resultado de exercícios.** Restauração real a partir do backup, simulação controlada de phishing, exercício de mesa. Exercício produz dado; opinião produz sensação.

Métrica que só sobe e nunca gera decisão é métrica de vaidade: contar ataques bloqueados pelo firewall mede o ruído de fundo da internet, não a qualidade da defesa. O Volume 12 retoma o assunto com o rigor devido.

1.10. Brasil em Foco

No Brasil, segurança da informação deixou de ser boa prática e passou a ser obrigação jurídica com nome, prazo e sanção.

A **Lei Geral de Proteção de Dados** (Lei 13.709/2018) é o eixo (Brasil, 2018). Seu art. 46 obriga os agentes de tratamento a adotar medidas de segurança técnicas e administrativas aptas a proteger dados pessoais — redação deliberadamente aberta, que remete ao estado da técnica e à natureza da informação, e não a uma lista fechada de produtos. O art. 48 estabelece o dever de comunicar à Autoridade Nacional de Proteção de Dados e aos titulares afetados a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante. A Resolução CD/ANPD nº 15/2024 regulamentou essa comunicação, fixando prazo de três dias úteis a contar do conhecimento do incidente e definindo o conteúdo mínimo do relato (Autoridade Nacional de Proteção de Dados, 2024). Na prática, a empresa precisa ser capaz de *saber* que foi comprometida, *avaliar* o alcance e *redigir* a comunicação em três dias — impossível sem registro adequado e plano prévio. No caso da abertura, a planilha do notebook furtado é tratamento de dados pessoais, e o furto é potencialmente um incidente comunicável.

O **Marco Civil da Internet** (Lei 12.965/2014) trata da guarda de registros (Brasil, 2014). O art. 13 obriga o provedor de conexão a manter registros de conexão por um ano; o art. 15 obriga o provedor de aplicações constituído como pessoa jurídica e com fins econômicos a guardar registros de acesso por seis meses. Os arts. 10 e 11 impõem sigilo e condicionam a disponibilização a ordem judicial. A leitura é dupla: o registro é obrigação e é ativo sensível — quem guarda log de conexão de milhares de pessoas custodia um alvo de valor.

A **Lei 12.737/2012** inseriu no Código Penal o art. 154-A, que tipifica invadir dispositivo informático alheio para obter, adulterar ou destruir dados, ou instalar vulnerabilidade para obter vantagem ilícita (Brasil, 2012). As penas foram agravadas pela Lei 14.155/2021. Essa é a fronteira jurídica que sustenta a política editorial deste manual: testar sistema de terceiro sem autorização formal e por escrito é crime, ainda que a intenção seja “só verificar”. O sétimo capítulo deste volume trata exclusivamente dessa fronteira.

Para quem opera telecomunicações há camada regulatória adicional: a **Anatel** editou a Resolução nº 740/2020, com requisitos de segurança cibernética para produtos de telecomunicações, o que alcança diretamente as ONUs e roteadores entregues ao assinante (Agência Nacional

de Telecomunicações, 2020). O Volume 15 dedica um capítulo às obrigações regulatórias de provedores.

No lado institucional, o **CERT.br**, mantido pelo NIC.br, é o ponto nacional de tratamento de incidentes em redes conectadas à internet no Brasil: recebe notificações, publica estatísticas e mantém material de boas práticas usado por operadores de rede. Manter contato de abuso atualizado no WHOIS do seu bloco e responder de fato a essas notificações é um dos controles mais baratos e menos praticados do país.

Por fim, o **Banco Central** trata fraude como matéria de segurança regulada: instituições financeiras e de pagamento estão sujeitas a política obrigatória de segurança cibernética (Resolução CMN nº 4.893/2021), e o Pix conta com o Mecanismo Especial de Devolução para casos de fraude — o que faz da engenharia social contra o titular, e não do ataque à instituição, o vetor dominante no país. O Volume 10 volta ao tema.

1.11. No Campo

Traduzindo tudo para a primeira semana de quem assume a responsabilidade por uma infraestrutura, na ordem em que compensa fazer:

1. Inventário, antes de qualquer controle. Não se protege o que não se conhece, e a maior parte das surpresas está em ativo esquecido: o servidor de teste de 2019 ainda ligado com endereço público, a câmera com firmware de fábrica. Vale a varredura do próprio bloco — sua rede, sua autorização:

```
# Descoberta de hosts e serviços no PRÓPRIO bloco de endereços
nmap -sS -Pn --top-ports 200 --open -oA inventario-borda 198.51.100.0/24

# O que este servidor realmente escuta, e qual processo responde
ss -tulnp | sort -k5

# Contas locais com shell de login válido
awk -F: '$7 !~ /(nologin|false)$/ {print $1, $3, $7}' /etc/passwd
```

2. Reduzir a superfície de gerência. Painel de administração acessível da internet é o achado mais comum e mais caro. Winbox, interface web de OLT, SNMP com comunidade **public**, Telnet, área de trabalho remota — nada disso deve estar alcançável do mundo. O padrão é VLAN de gerência separada do tráfego de assinante, alcançável apenas por VPN com segundo fator, com filtro por origem no equipamento além do filtro na borda.

3. Senhas individuais e nomeadas. A senha compartilhada entre a equipe técnica destrói o menor privilégio e a responsabilização de uma vez: quando todos entram como **admin**, o log de auditoria não responde à única pergunta que importa depois de um incidente. Cofre de senhas da equipe, contas nomeadas e revogação como parte formal do desligamento — inclusive chaves SSH, VPN e acesso ao WhatsApp do suporte.

4. Backup que sobrevive ao próprio servidor. O critério é implacável: o backup precisa estar fora do alcance de quem comprometeu o servidor — compartilhamento montado permanentemente não atende, cópia que a máquina de origem pode apagar não atende. E backup nunca restaurado é hipótese, não backup; a restauração de teste trimestral é o que transforma um em outro.

1. O que é segurança da informação

5. Relógio e registro. Sem NTP consistente em todos os equipamentos, os logs não podem ser correlacionados e perdem valor tanto na investigação técnica quanto no atendimento a ordem judicial. É configuração de dez minutos com efeito permanente:

```
timedatectl set-ntp true
timedatectl status | grep -E 'synchronized|NTP service'

# Autenticações falhas por origem, últimas 24 h
journalctl -u ssh --since "24 hours ago" \
  | grep -oE 'from [0-9.]+' | sort | uniq -c | sort -rn | head
```

6. Escrever o plano antes de precisar dele. Uma folha por cenário, resposta a três perguntas: quem decide, a quem se avisa (interno, cliente, ANPD, delegacia), e qual é a primeira ação técnica. Faça para ransomware no sistema de gestão, para vazamento de base de assinantes e para rompimento de fibra do enlace principal. Às 3h da manhã, com o telefone tocando, ninguém improvisa bem.

7. Fechar o ciclo no descarte. Disco que sai da empresa é apagado de forma verificável ou destruído fisicamente. Equipamento devolvido por assinante ou retirado de operação volta a padrão de fábrica antes de ir para o estoque, para venda ou para doação.

Nenhum dos sete itens exige orçamento significativo; todos exigem que alguém seja nomeado responsável — e essa nomeação, mais do que qualquer aquisição, é o que dá início a um programa de segurança.

1.12. Resumo

- Segurança da informação é a **preservação contínua** de confidencialidade, integridade e disponibilidade: processo que se mantém, não estado que se compra. As três propriedades conflitam entre si, e escolher os tradeoffs conscientemente é parte do trabalho.
- O que se protege é a **informação**; servidores, links e equipamentos são ativos de suporte, e é neles que os controles se aplicam — em todo o ciclo de vida, inclusive no descarte, a etapa mais esquecida.
- Ameaça não é sinônimo de atacante: falhas **acidentais** e eventos **ambientais** produzem incidentes de disponibilidade em volume, e cabem no mesmo arcabouço de gestão de risco.
- A maior parte do que se vê nos logs é **varredura automatizada e indiscriminada** — o que invalida a premissa de que porte pequeno confere proteção. Além de alvo, uma infraestrutura mal protegida se torna vetor contra os próprios clientes.
- Os oito princípios de Saltzer e Schroeder, com meio século de idade, seguem sendo o melhor filtro para avaliar decisões; deles decorre a **defesa em profundidade**, com camadas independentes que bloqueiam e também produzem registro.
- No Brasil, o dever de segurança é jurídico: LGPD (arts. 46 e 48) com prazo de três dias úteis para comunicar incidente relevante, Marco Civil para guarda de registros, Lei 12.737/2012 tipificando o acesso não autorizado, mais camada setorial de Anatel e Banco Central.

2. Os pilares: confidencialidade, integridade e disponibilidade

O provedor havia feito tudo certo com o backup. Rotina diária às 2h, retenção de trinta dias, cópia replicada para um segundo site a 40 km, alerta por e-mail em caso de falha do job. Em quatro anos, nenhum alerta.

Em novembro, a equipe descobriu que a tabela de contratos estava com os campos de vencimento embaralhados: assinantes com vencimento no dia 10 apareciam com dia 25, e uma fatia menor tinha vencimento nulo. A causa foi uma migração mal-feita nove meses antes, que rodou uma atualização sem cláusula **WHERE** correta e afetou 3.100 dos 4.000 registros. O sistema não caiu. Ninguém foi invadido. Nada vazou.

E o backup não ajudou: a retenção era de trinta dias, e o dano tinha nove meses. As trinta cópias disponíveis continham, todas, os mesmos dados errados — fielmente preservados, replicados com integridade de arquivo perfeita, disponíveis a qualquer hora. Reconstruir o cadastro exigiu conferir contrato por contrato em papel, um trabalho de sete semanas.

Esse incidente ilustra o ponto central deste capítulo: as três propriedades que definem segurança da informação são **independentes**. Um sistema pode ser exemplar em duas e catastrófico na terceira, e nenhum controle protege as três de graça. Este capítulo abre confidencialidade, integridade e disponibilidade uma a uma — o que cada uma significa com precisão, como cada uma falha, o que a defende e onde as três colidem.

2.1. As três propriedades, com precisão

A tríade CID (em inglês, *CIA triad*) organiza a disciplina desde os anos 1970 e sobrevive porque é ao mesmo tempo curta e completa o bastante para servir de checklist (International Organization for Standardization, 2018a). A Figura 2.1 resume as definições e as tensões.

Vale notar que os três termos têm sentido técnico mais estreito que o do uso corrente. “Confidencial” na linguagem comum sugere sigilo absoluto; em segurança da informação, confidencialidade é um controle *relacional* — sempre em relação a um conjunto definido de sujeitos autorizados, nunca sigilo em abstrato.

2.2. Confidencialidade

Confidencialidade é a garantia de que a informação só é acessível a quem tem direito a ela. A definição embute uma pergunta prévia que costuma ficar sem resposta: *quem* tem direito? Sem classificação de informação e sem uma decisão explícita sobre quem precisa de que acesso, “proteger a confidencialidade” não tem conteúdo operacional.

2. Os pilares: confidencialidade, integridade e disponibilidade

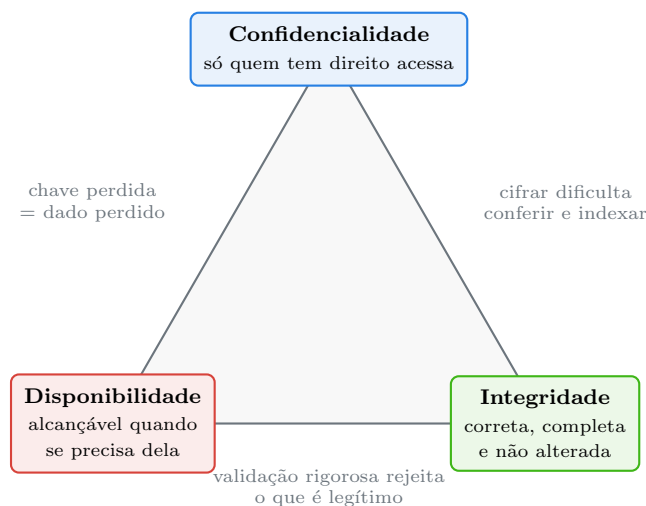


Figura 2.1.: A tríade CID e as tensões entre cada par. Reforçar um vértice quase sempre pressiona os outros dois.

2.2.1. Como a confidencialidade falha

O vazamento por invasão é o caso mais visível e o menos frequente. Os caminhos reais são mais prosaicos:

- **Excesso de permissão.** O compartilhamento de rede com acesso a “todos”, o *bucket* de armazenamento em nuvem com listagem pública, o grupo de mensagens da equipe técnica com cliente dentro. Ninguém invadiu nada: o acesso estava concedido.
- **Perda física.** Notebook furtado, pen drive esquecido, disco de servidor trocado por defeito e devolvido ao fornecedor com os dados legíveis.
- **Canal lateral e metadado.** A informação não vaza, mas se deduz. Um formulário de recuperação de senha que responde “e-mail não cadastrado” confirma quem é cliente. Tráfego cifrado revela, pelo padrão de tamanho e horário dos pacotes, qual serviço está sendo usado. Registro de conexão sem conteúdo ainda revela com quem alguém falou e quando — e é por isso que o Marco Civil trata log como dado sob sigilo.
- **Agregação e inferência.** Nome sozinho é público. Nome com CEP, data de nascimento e plano contratado identifica uma pessoa específica com precisão desconfortável. Bases anonimizadas por remoção de nome frequentemente reidentificam quando cruzadas com outra base.
- **Vazamento pelo canal legítimo.** O log de aplicação que grava o corpo da requisição, senha incluída. A mensagem de erro que devolve o rastro de execução com a *string* de conexão do banco. O relatório em PDF distribuído com texto “tarjado” por retângulo preto sobreposto — que o *pdftotext* recupera integralmente.

2.2.2. O que a defende

Quatro famílias de controle, em ordem de eficácia por real gasto:

1. **Minimização.** Dado que não se coleta não vaza; dado que se apaga no fim do prazo legal não vaza depois. É o único controle cuja eficácia é de 100% e cujo custo é negativo. A LGPD faz disso princípio jurídico (necessidade, art. 6º, III).
2. **Controle de acesso.** Autenticação, autorização e o princípio do menor privilégio. Cobre o caso do excesso de permissão, que é o mais comum. O Volume 4 é inteiro sobre isso.

3. **Cifragem.** Em repouso (disco, banco, backup) e em trânsito (TLS, VPN). Note o que a cifragem realmente faz: transfere o problema do dado para a **chave**. É uma troca excelente — proteger uma chave de 32 bytes é muito mais fácil que proteger 400 GB —, mas é uma troca, não uma solução mágica.
4. **Controles de descarte.** Sobrescrita verificável, apagamento criptográfico em disco autocifrante, destruição física. Fecha a última etapa do ciclo de vida da informação, apresentado no Capítulo 1.

2.3. Integridade

Integridade é a garantia de que a informação está correta e completa, e de que alterações não autorizadas são impedidas ou, no mínimo, detectáveis. Convém separar três níveis que costumam ser confundidos:

- **Integridade de bits.** Os bytes gravados são os bytes lidos. Ataca corrupção silenciosa de disco, erro de transmissão, falha de memória. Ferramentas: soma de verificação, memória com correção de erro, sistemas de arquivos com verificação de bloco (ZFS, Btrfs).
- **Integridade semântica.** O dado faz sentido segundo as regras do negócio. Vencimento entre 1 e 31, CPF válido, contrato ativo com endereço preenchido, saldo que nunca fica negativo sem lançamento correspondente. Ferramentas: restrições no banco, validação de entrada, transações com garantia ACID, conciliação.
- **Integridade de origem.** O dado veio de quem se afirma — que é autenticidade, tema do Capítulo 3, e se apoia em assinatura digital e código de autenticação de mensagem.

O incidente de abertura foi uma falha de integridade **semântica** com integridade de bits perfeita. É a categoria mais perigosa porque não dispara alarme: os sistemas continuam consistentes consigo mesmos, propagando o erro para relatórios, faturas e backups.

2.3.1. Por que a integridade é a mais difícil das três

Confidencialidade e disponibilidade têm sinais externos claros: o vazamento aparece, a queda aparece. A perda de integridade é silenciosa por construção. Some-se a isso o fato de que o dano se **propaga** — dado errado alimenta cálculo, que alimenta relatório, que alimenta decisão — e que a **deteção tardia inviabiliza a correção**, porque o backup íntegro já saiu da janela de retenção.

Daí três consequências práticas frequentemente ignoradas:

- Retenção de backup deve ser dimensionada pelo **tempo esperado até a deteção**, não pelo tempo de recuperação. Trinta dias cobrem exclusão acidental; não cobrem corrupção lenta.
- Vale manter, além das diárias de curto prazo, cópias **mensais e anuais de longa retenção** — o esquema avô-pai-filho existe justamente para isso.
- Conciliação periódica com uma fonte independente (contagem física, extrato bancário, base de outro sistema) é o único mecanismo que detecta erro semântico consistente.

2.3.2. O que a defende

Soma de verificação e hash criptográfico para detecção; assinatura digital para detecção e atribuição; controle de versão e registro de alterações para reconstrução; transações e restrições de integridade referencial para prevenção; armazenamento imutável (WORM, bloqueio de objeto, cópia instantânea com retenção travada) para impedir sobrescrita — que é, hoje, o controle mais eficaz contra ransomware, porque ataca a estratégia do adversário de apagar as cópias antes de cifrar o original.

2.4. Disponibilidade

Disponibilidade é a garantia de que quem tem direito à informação a alcança quando precisa. É a propriedade mais fácil de medir e a que consome mais orçamento de infraestrutura.

A métrica canônica é o percentual de tempo em operação num período. A Figura 2.2 mostra o que cada patamar significa em minutos por ano — e é o argumento mais eficiente que existe contra a promessa de “99,99%” feita sem cálculo.

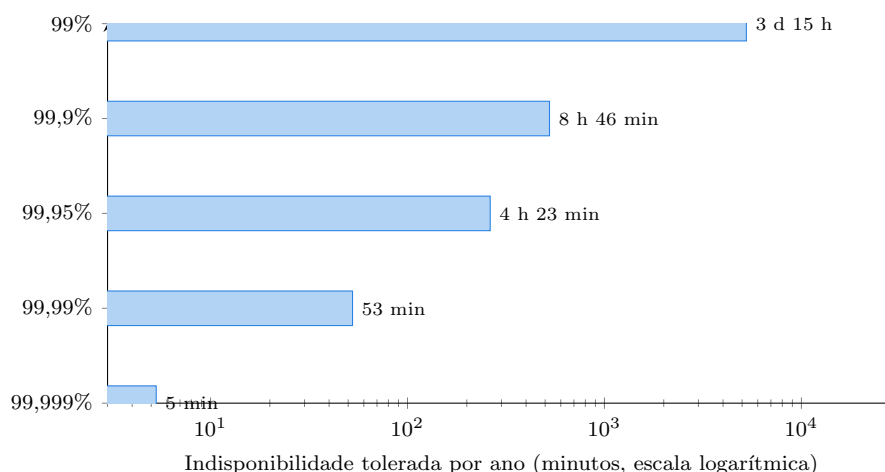


Figura 2.2.: Indisponibilidade anual tolerada por patamar de disponibilidade. Cada nove adicional custa aproximadamente uma ordem de grandeza a mais.

Dois cuidados de leitura. Primeiro, disponibilidade **composta**: se um serviço depende de quatro componentes em série, cada um com 99,9%, a disponibilidade do conjunto é $0,999^4 \approx 99,6\%$ — quatro vezes mais tempo fora do ar que o de cada peça isolada. Segundo, o número sozinho não descreve a experiência: 52 minutos fora do ar distribuídos em paradas de 30 segundos durante a madrugada e 52 minutos contínuos numa terça às 10h são o mesmo 99,99% e situações incomparáveis.

2.4.1. RTO e RPO

Disponibilidade em regime é uma coisa; recuperação depois de um desastre é outra, e tem duas métricas próprias, ilustradas na Figura 2.3.

O **RPO** (*recovery point objective*) é a quantidade máxima aceitável de dados perdidos, expressa em tempo: backup diário às 2h implica RPO de até 24 horas. O **RTO** (*recovery time objective*) é o tempo máximo aceitável até o serviço voltar. Ambos são definidos pela área de negócio e

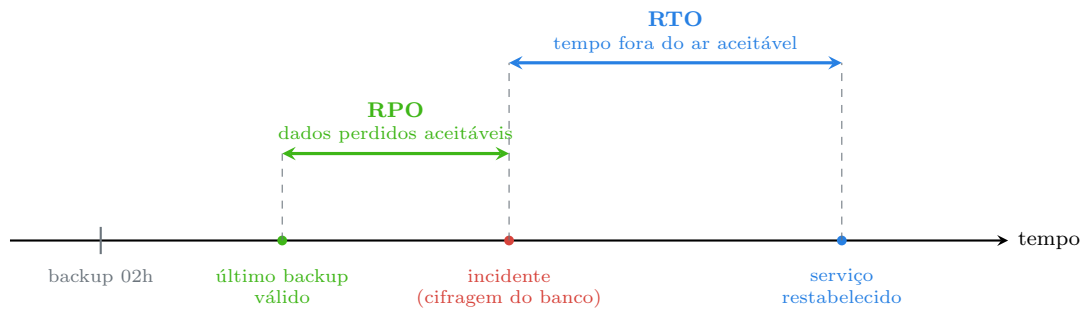


Figura 2.3.: RPO mede quanto trabalho se perde; RTO mede quanto tempo se fica parado. São decisões de negócio, não de infraestrutura.

depois traduzidos em arquitetura — a inversão comum, em que a infraestrutura existente define o RPO por acidente, é a razão de tantas surpresas no dia do incidente.

2.4.2. O que a ameaça e o que a defende

Contra disponibilidade jogam falha de hardware, erro humano, esgotamento de capacidade, dependência externa (energia, link, fornecedor de nuvem), evento ambiental e, por último na lista de frequência, ataque deliberado. Defendem-na redundância sem ponto único de falha, capacidade folgada, backup testado, monitoramento com alarme antes do limite, e — o item mais barato e mais esquecido — **procedimento escrito de recuperação que alguém já executou pelo menos uma vez**.

2.5. As três colidem

A Tabela 2.1 reúne os tradeoffs mais comuns. Reconhecê-los como escolhas, e não como falhas de projeto, é o que separa uma decisão de segurança de um reflexo.

Tabela 2.1.: Conflitos típicos entre os pilares. Nenhum tem resposta universal; todos têm resposta correta *dado o contexto*.

Decisão	Ganha	Pressiona
Cifrar backups	Confidencialidade	Disponibilidade (chave perdida = backup inútil)
Bloquear a conta após 3 erros de senha	Confidencialidade	Disponibilidade (negação de serviço trivial contra usuários)
Validação rigorosa de entrada	Integridade	Disponibilidade (rejeita o legítimo atípico)
Replicação síncrona entre sites	Disponibilidade e integridade	Custo e desempenho; propaga o erro lógico instantaneamente
Retenção longa de log	Integridade e responsabilização	Confidencialidade (mais dado sensível guardado por mais tempo)
Segundo fator em tudo	Confidencialidade	Disponibilidade (celular perdido trava o acesso) e aceitação do usuário

2. Os pilares: confidencialidade, integridade e disponibilidade

Decisão	Ganha	Pressiona
Alta disponibilidade por múltiplas cópias	Disponibilidade	Confidencialidade (mais lugares de onde vazar)

2.6. A ordem de prioridade muda com o contexto

Não existe hierarquia fixa entre os três pilares — existe a hierarquia daquele ambiente, e ela precisa ser declarada, porque é ela que resolve os conflitos da tabela anterior.

Tabela 2.2.: A ordem de prioridade é uma decisão de contexto e precisa estar escrita.

Contexto	Ordem típica	Por quê
Hospital, prontuário eletrônico	$D > I > C$	Prontuário inacessível na emergência custa vidas; o sigilo é gravíssimo, mas cede
Instituição financeira, núcleo bancário	$I > D > C$	Saldo errado destrói a instituição; a operação para até conciliar
Provedor de acesso, rede de transporte	$D > I > C$	O produto vendido é a conectividade; a métrica contratual é o tempo em operação
Provedor de acesso, base cadastral	$C > I > D$	CPF, endereço e meio de pagamento, sob a LGPD
Automação industrial e OT	$D > I > C$	Parada de linha e risco físico a pessoas
Órgão de inteligência e defesa	$C > I > D$	Vazamento é irreversível; indisponibilidade é contornável

Repare que o mesmo provedor aparece duas vezes com ordens opostas. Não é contradição: são **ativos diferentes**, e é exatamente por isso que a classificação da informação precede a escolha de controle.

2.7. Além da tríade

A tríade não é a última palavra. Duas extensões merecem registro.

Donn Parker propôs o **hexágono parkeriano**, acrescentando três propriedades que a tríade não captura bem (Parker, 1998): **posse ou controle** (perder o disco é dano ainda que ele esteja cifrado e nada tenha sido lido), **autenticidade** (a origem é quem afirma ser) e **utilidade** (o dado existe, íntegro e acessível, mas está num formato que ninguém consegue mais abrir — a fita sem leitor, o arquivo do sistema descontinuado). A distinção “posse” é a mais útil na prática: notificar um incidente à ANPD não depende de provar que alguém leu os dados.

A segunda extensão é a que este manual adota: **autenticidade, não repúdio e responsabilização** como propriedades de primeira classe, tratadas no Capítulo 3. Sem elas, não se descreve corretamente nem uma transação financeira nem uma trilha de auditoria.

2.8. Brasil em Foco

As três propriedades aparecem no direito brasileiro com nome próprio e consequência distinta para cada uma.

A **LGPD** trata a tríade explicitamente. O art. 6º lista entre os princípios do tratamento a **qualidade dos dados** (inciso V — exatidão, clareza, relevância e atualização, que é integridade em linguagem jurídica), a **segurança** (inciso VII — proteção contra acessos não autorizados e situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão, que cobre os três pilares de uma vez) e a **prevenção** (inciso VIII) (Brasil, 2018). O art. 46 impõe o dever de adotar medidas técnicas e administrativas, e o art. 18 dá ao titular o direito de exigir **correção de dados incompletos, inexatos ou desatualizados** — um direito subjetivo de integridade, exercível contra a empresa. No incidente de abertura deste capítulo, cada assinante com vencimento trocado tinha esse direito.

Vale sublinhar o alcance do art. 48: o dever de comunicar incidente à ANPD e aos titulares **não se restringe a vazamento**. A redação fala em incidente de segurança que possa acarretar risco ou dano relevante, e a Resolução CD/ANPD nº 15/2024 detalha o rito e o prazo de três dias úteis (Autoridade Nacional de Proteção de Dados, 2024). Destruição acidental de base e indisponibilidade prolongada de dados pessoais são hipóteses de comunicação — a leitura de que “só notifica quem vaza” é incorreta e comum.

Do lado da **disponibilidade**, quem presta serviço de telecomunicações tem obrigação regulatória direta: a Anatel fixa indicadores de qualidade e disponibilidade no RQUAL (Resolução nº 717/2019), com coleta, meta e possibilidade de sanção (Agência Nacional de Telecomunicações, 2019). Disponibilidade, nesse caso, não é apenas expectativa do cliente — é indicador reportado ao regulador.

Do lado da **integridade**, o Marco Civil exige a guarda de registros de conexão por um ano e de acesso a aplicações por seis meses (arts. 13 e 15), sob sigilo e com disponibilização mediante ordem judicial (Brasil, 2014). Um log só cumpre sua função probatória se for íntegro e se o horário for confiável: sem NTP sincronizado e sem proteção contra alteração, o registro perde valor exatamente quando é necessário. O art. 13, §2º prevê ainda a requisição cautelar de guarda por prazo maior — o que só se atende se o dado ainda existir quando o pedido chegar.

No setor financeiro, a Resolução CMN nº 4.893/2021 exige política de segurança cibernética com controles de confidencialidade, integridade e disponibilidade dos dados e sistemas, além de plano de continuidade e de testes periódicos (Banco Central do Brasil, 2021). Para o Pix, a disponibilidade do arranjo é acompanhada pelo Banco Central com indicadores próprios, e a instituição responde pela indisponibilidade que afete a liquidação.

2.9. No Campo

O que muda concretamente para quem administra rede e servidores, organizado por pilar.

Confidencialidade. Cifragem de disco em todo equipamento que sai do prédio, sem exceção — notebook do comercial incluído. Cifragem também no backup, com a chave guardada em local independente do servidor (cofre de senhas da equipe, com cópia impressa em envelope lacrado, é solução legítima). TLS obrigatório em tudo, inclusive na rede interna. Revisão trimestral de quem tem acesso a quê:

2. Os pilares: confidencialidade, integridade e disponibilidade

```
# Quem consegue autenticar via SSH nesta máquina
grep -E '^(AllowUsers|AllowGroups|PermitRootLogin|PasswordAuthentication)'
↪ /etc/ssh/sshd_config
getent group sudo wheel adm 2>/dev/null

# Compartilhamentos Samba abertos a convidado - achado clássico
grep -rniE 'guest ok *= *yes|public *= *yes' /etc/samba/smb.conf

# Arquivos de configuração legíveis por qualquer usuário (senhas costumam morar
↪ aqui)
find /etc /opt /srv -type f \( -name '*.conf' -o -name '*.env' -o -name '*.ini'
↪ \) \
    -perm -o=r 2>/dev/null | head -40
```

Integridade. Verificação periódica de mídia e de backup, agendada e com alerta em caso de divergência:

```
# ZFS: varredura completa de blocos com verificação de soma
zpool scrub tank && zpool status tank

# Verificação de integridade do repositório de backup (restic)
restic -r /mnt/backup check --read-data-subset=10%

# Conferência de um artefato baixado, antes de instalar
sha256sum -c imagem.iso.sha256

# Saúde do disco antes de ele falhar - atributos que antecipam corrupção
smartctl -A /dev/sda | grep -Ei 'reallocated|pending|uncorrect|crc'
```

Três hábitos valem mais que qualquer ferramenta: **restaurar de verdade** um backup por trimestre e conferir o conteúdo, não só o código de retorno do comando; manter **retenção longa** (mensal por 12 meses, anual por 5) para cobrir detecção tardia; e **conciliar** mensalmente uma amostra do cadastro contra uma fonte independente.

Disponibilidade. Redundância que resolve ponto único de falha real, e não redundância decorativa: dois links do mesmo provedor entrando pela mesma canaleta são um link. Monitorar tendência, não só limiar — disco a 78% crescendo 2% ao dia é um incidente agendado para daqui a onze dias:

```
# Uso de disco por sistema de arquivos, dos mais cheios para os mais vazios
df -h --output=pcent,size,used,target -x tmpfs -x devtmpfs | sort -rn | head

# Reinicializações e quedas registradas
last -x reboot shutdown | head

# Serviços que falharam desde o último boot
systemctl --failed --no-pager
```

E a checagem que fecha o ciclo: escrever, para os três serviços mais críticos, o RTO e o RPO **acordados com quem responde pelo negócio**, comparar com o que a infraestrutura atual

entrega de fato, e levar a diferença para a mesa como decisão consciente de risco — que é o assunto do Capítulo 6.

2.10. Resumo

- Confidencialidade, integridade e disponibilidade são propriedades **independentes**: excelência em duas não compensa falha na terceira, e cada uma falha por caminhos próprios.
- A confidencialidade quase nunca falha por invasão — falha por excesso de permissão, perda física, metadado, inferência e vazamento pelo canal legítimo. Minimizar o dado coletado é o controle mais eficaz e o de menor custo.
- A integridade é a mais difícil das três porque falha em silêncio, propaga o dano e pode ser detectada tarde demais para o backup ajudar. Retenção deve ser dimensionada pelo tempo até a detecção, e conciliação com fonte independente é o que revela erro semântico.
- Disponibilidade é composta e se degrada em série: quatro componentes de 99,9% entregam 99,6%. **RPO** mede dados perdidos, **RTO** mede tempo parado, e ambos são decisão de negócio traduzida depois em arquitetura.
- Os pilares **conflitam**, e a ordem de prioridade depende do contexto e do ativo — hospital, banco e provedor ordenam de formas diferentes, e o mesmo provedor ordena diferente para a rede de transporte e para a base cadastral.
- No Brasil, os três têm âncora normativa: LGPD (arts. 6º, 18, 46 e 48, com comunicação de incidente em três dias úteis e direito de correção), Marco Civil (guarda íntegra de registros), Anatel RQUAL (disponibilidade como indicador regulado) e Resolução CMN 4.893/2021 no setor financeiro.

3. Autenticidade, não repúdio e responsabilização

Numa quinta-feira de junho, o setor financeiro de um provedor recebeu um e-mail do fornecedor de equipamentos ópticos com quem trabalhava havia seis anos. A mensagem vinha na mesma cadeia de respostas de uma negociação real em andamento, com o histórico completo abaixo, a assinatura de sempre e o mesmo tom. Informava mudança de banco e anexava a nota reemitida com os novos dados. O pagamento de R\$ 118 mil saiu no dia seguinte.

O domínio remetente não era `fornecedor.com.br`, e sim `fornecedor-com.br`. Nada mais no e-mail era falso: o histórico era autêntico, porque a caixa de um vendedor do fornecedor havia sido comprometida semanas antes e a conversa fora copiada dali. Não houve invasão do provedor, não houve malware, não houve nenhuma falha nos três pilares do Capítulo 2. Confidencialidade, integridade e disponibilidade da mensagem estavam preservadas: ela chegou íntegra, no horário, a quem devia. O que faltou foi uma propriedade diferente — **a garantia de que a origem é quem afirma ser**.

Dentro do mesmo provedor, na mesma semana, um segundo episódio menor: alguém executou no `ip route 0.0.0.0/0` no roteador de borda às 14h20 de uma quarta e derrubou a saída por dezenove minutos. O log do equipamento registrou o comando com precisão de segundo. Registrou também o usuário: `admin`. Como as sete pessoas da equipe técnica usavam `admin`, o log respondeu o que aconteceu e quando, e não respondeu a única pergunta que faltava.

Este capítulo trata das três propriedades que os pilares clássicos não cobrem: **autenticidade** (a origem é quem afirma ser), **não repúdio** (a origem não pode negar depois) e **responsabilização** (cada ação é atribuível a um sujeito identificado).

3.1. Quatro coisas diferentes que se confundem

Antes das três propriedades, é preciso separar quatro conceitos que a linguagem cotidiana funde e cuja confusão produz erros de arquitetura recorrentes. A Figura 3.1 mostra a cadeia.

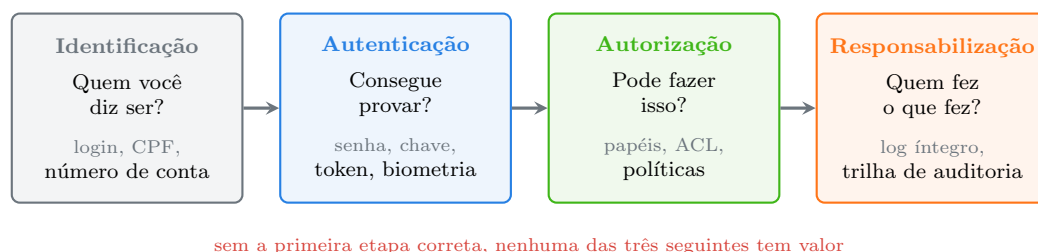


Figura 3.1.: Identificação, autenticação, autorização e responsabilização. Quatro perguntas distintas, quatro mecanismos distintos.

Identificação é a alegação: “sou o usuário `mmatos`”. É pública e não prova nada. **Autenticação** é a verificação dessa alegação contra uma evidência. **Autorização** é a decisão sobre o que aquele

3. Autenticidade, não repúdio e responsabilização

sujeito, já autenticado, pode fazer. E **responsabilização** é a capacidade, *depois*, de atribuir cada ação a um sujeito.

Duas confusões custam caro na prática. A primeira é tratar identificação como autenticação — é o que faz uma central de atendimento liberar mudança cadastral porque a pessoa “sabe o CPF”, quando o CPF é dado de identificação, presente em dezenas de bases e amplamente vazado. A segunda é presumir que autenticação forte resolve a responsabilização: se sete pessoas compartilham a credencial, o segundo fator apenas garante que *alguém do grupo* entrou.

3.2. Autenticidade

Autenticidade é a garantia de que uma entidade, mensagem ou dado é genuinamente o que ou de quem se afirma. Vem em três recortes:

- **Autenticidade de entidade.** Quem está do outro lado da conexão é mesmo aquele servidor, aquele usuário, aquele equipamento. É o que o certificado TLS resolve para o servidor e o que a autenticação resolve para o usuário.
- **Autenticidade de mensagem ou de dado.** Aquele arquivo, e-mail ou pacote realmente foi produzido pela origem alegada. É o que faltou no caso de abertura.
- **Autenticidade de origem em tempo real.** Além de vir da origem certa, a mensagem é *desta* conversa e não a repetição de uma anterior — o problema do frescor, tratado adiante.

Note que autenticidade e integridade caminham juntas mas não são a mesma coisa. Integridade responde “isto foi alterado?”; autenticidade responde “quem produziu isto?”. Um hash SHA-256 publicado ao lado de um arquivo dá integridade contra corrupção acidental, e não dá autenticidade nenhuma: quem alterou o arquivo altera o hash publicado na mesma página. A diferença é a existência de um **segredo** que só a origem legítima possui.

3.2.1. Os dois mecanismos, e por que não são intercambiáveis

Existem duas famílias criptográficas para autenticidade de mensagem, e a diferença entre elas é a diferença entre ter e não ter não repúdio (Figura 3.2).

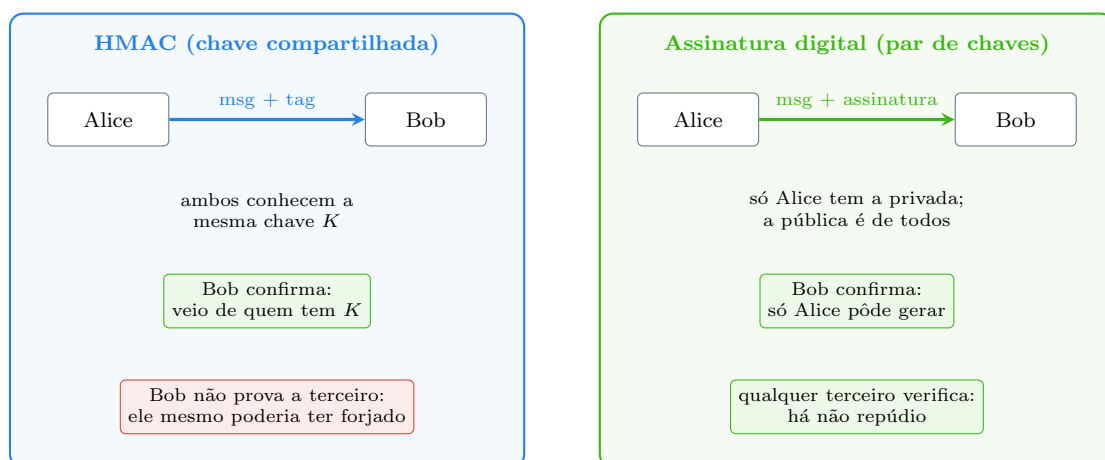


Figura 3.2.: Chave simétrica compartilhada dá autenticidade entre as partes; só o par de chaves assimétrico sustenta não repúdio perante terceiros.

Um **código de autenticação de mensagem** (MAC, tipicamente HMAC) usa uma chave secreta compartilhada entre remetente e destinatário. É rápido, simples e suficiente quando as duas partes confiam uma na outra e o objetivo é apenas detectar adulteração e impostor. Mas, como *ambos* possuem a chave, o destinatário poderia ter produzido a mesma tag — logo não consegue provar a um juiz que a mensagem veio do remetente.

Uma **assinatura digital** usa um par de chaves: a privada, que só a origem possui, gera a assinatura; a pública, que todos podem ter, a verifica. Isso permite que *qualquer terceiro* verifique, e é a base do não repúdio. A mecânica de ambas é assunto do Volume 3.

3.2.2. Autenticidade no e-mail: o caso de abertura resolvido

O correio eletrônico nasceu sem autenticidade nenhuma: o campo **From:** é preenchido livremente por quem envia, como o remetente escrito no verso de um envelope. Três mecanismos foram acrescentados depois:

- **SPF** declara, em registro DNS do domínio, quais servidores estão autorizados a enviar em seu nome. Verifica o envelope, não o **From:** que o usuário vê.
- **DKIM** assina criptograficamente cabeçalhos e corpo da mensagem com uma chave cujo par público está publicado no DNS do domínio. Dá autenticidade de origem e integridade, e sobrevive a encaminhamentos.
- **DMARC** amarra os dois ao domínio que o usuário efetivamente lê, define a política para quem falha na verificação (**none**, **quarantine**, **reject**) e produz relatórios.

E aqui está o ponto desconfortável do caso de abertura: **os três teriam passado**. O domínio **fornecedor-com.br** era real, registrado pelo atacante, com SPF e DKIM próprios corretamente configurados. A mensagem era autêntica — de um domínio que não era o esperado. Autenticidade criptográfica prova a origem; não prova que a origem é a *certa*. É por isso que o controle que resolve esse ataque não é técnico, e sim de processo: **mudança de dados bancários de fornecedor só vale com confirmação por canal independente**, telefone conhecido de cadastro anterior, nunca o número que veio no próprio e-mail.

3.2.3. Frescor: autenticidade não basta

Uma mensagem legítima, capturada e retransmitida depois, continua sendo autêntica — e é um ataque. É a **repetição** (*replay*): o comando de abertura de cancela gravado por rádio e reenviado à noite; a requisição de transferência interceptada e repetida cinco vezes.

Os antídotos são três, e quase todo protocolo sério usa alguma combinação deles: **nonce** (valor único por transação, que o destinatário recusa se repetido), **carimbo de tempo** com janela estreita de aceitação, e **contador de sequência** monotônico. É por isso que a sincronização de relógio (Capítulo 2) é requisito de segurança e não conveniência operacional: com relógios divergindo minutos, a janela de aceitação precisa ser alargada, e a janela alargada é exatamente a brecha para repetição.

3.3. Não repúdio

Não repúdio é a garantia de que quem praticou um ato não consiga negar tê-lo praticado, de forma sustentável perante um terceiro. É a propriedade mais mal-empregada do vocabulário da área, porque exige muito mais do que criptografia.

3. Autenticidade, não repúdio e responsabilização

Para que o não repúdio se sustente, cinco condições precisam valer ao mesmo tempo:

1. **Controle exclusivo da chave.** Se a chave privada estava num servidor a que cinco pessoas tinham acesso administrativo, ou numa planilha, “só o titular poderia ter assinado” é falso. Daí o uso de módulo de segurança em hardware e de cartão com chave não exportável.
2. **Vínculo confiável entre chave e pessoa.** Alguém precisa ter verificado a identidade do titular antes de emitir o certificado, e essa cadeia precisa ser auditável — é o papel de uma infraestrutura de chaves públicas, tema do Volume 3.
3. **Carimbo de tempo confiável.** Sem uma marca temporal de terceira parte, não se distingue uma assinatura feita antes da revogação da chave de outra feita depois.
4. **Integridade do que foi assinado.** A assinatura cobre um documento específico; o documento tem de ser preservado exatamente como assinado.
5. **Registro do processo.** Como a assinatura foi coletada, com que consentimento, sob que interface.

Falhando qualquer uma, o que resta é uma evidência forte — útil, muitas vezes decisiva — mas não uma impossibilidade de negar. Convém então distinguir dois níveis:

- **Não repúdio técnico:** a propriedade matemática de que só quem detém a chave privada poderia ter produzido aquela assinatura.
- **Não repúdio jurídico:** a aceitação, por um julgador, de que aquela pessoa praticou aquele ato. Admite contraprova — a alegação de chave roubada, de coação, de vício de consentimento.

Nenhum sistema entrega o segundo automaticamente. O que a engenharia entrega é a evidência que torna a negativa implausível, e o quanto de implausibilidade se consegue é proporcional ao cuidado com as cinco condições acima.

3.4. Responsabilização

Responsabilização (*accountability*) é a capacidade de atribuir cada ação relevante a um sujeito identificado, depois do fato. É a propriedade que sustenta investigação de incidente, auditoria, dissuasão interna e cumprimento de obrigação regulatória — e é a que o **admin** compartilhado do caso de abertura destrói por completo.

Seus requisitos são quatro:

Contas nomeadas e individuais. Não negociável. Toda credencial pertence a uma pessoa; contas de serviço pertencem a um sistema e têm dono humano registrado. Quando é tecnicamente necessário usar uma conta genérica — equipamento antigo que só aceita um usuário local —, o acesso deve passar por um intermediário que registre quem a usou: servidor de salto, ferramenta de acesso privilegiado, ou ao menos autenticação centralizada via RADIUS/TACACS+.

Registro suficiente. Quem, o quê, quando, de onde, com que resultado. Um log que registra “login bem-sucedido” sem o endereço de origem, ou “configuração alterada” sem dizer o quê, ocupa disco sem produzir responsabilização.

Horário confiável e uniforme. Correlacionar eventos entre firewall, servidor e aplicação exige que os três concordem sobre que horas são, e sobre qual fuso estão reportando.

Integridade do próprio registro. Este é o requisito mais negligenciado: um log que o administrador comprometido pode editar não responsabiliza ninguém. Quem invade um servidor limpa os rastros como parte da rotina. As defesas são o envio imediato para um coletor remoto

ao qual a máquina de origem não tem permissão de escrita retroativa, armazenamento imutável, e o **encadeamento por hash** ilustrado na Figura 3.3.

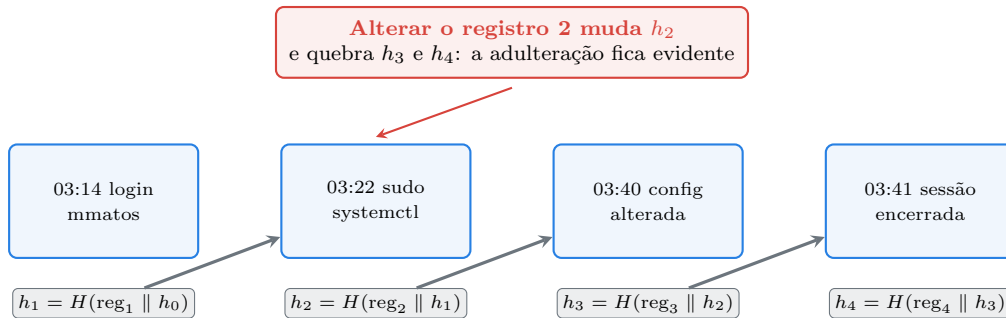


Figura 3.3.: Log encadeado por hash: cada registro incorpora o resumo do anterior, de modo que uma alteração isolada é detectável.

Vale registrar o limite dessa técnica: o encadeamento detecta alteração e remoção no meio da cadeia, mas não impede que um atacante com controle total *trunque* o log a partir de certo ponto e recomece a cadeia. Por isso o encadeamento se combina com publicação periódica da âncora — enviar o hash corrente para fora da máquina a cada intervalo — e com o envio remoto em tempo real. É a mesma lógica de defesa em profundidade do Capítulo 1: nenhuma camada isolada basta.

3.4.1. Segregação de funções

Responsabilização tem uma contraparte preventiva: **segregação de funções**. Quem executa não é quem aprova; quem administra o sistema não é quem audita os logs dele; quem cadastra o fornecedor não é quem libera o pagamento. É a aplicação direta do princípio de separação de privilégios de Saltzer e Schroeder (Saltzer; Schroeder, 1975), e é o que teria interrompido o golpe de abertura em duas frentes: alteração de dado bancário exigindo aprovação de segunda pessoa, e pagamento acima de um limite exigindo dupla assinatura.

Em equipes pequenas a segregação plena é impossível — três pessoas não se dividem em seis papéis. A alternativa aceita é **compensar por detecção**: se a mesma pessoa cadastra e paga, então um terceiro (o sócio, o contador) revisa mensalmente todos os cadastros bancários alterados. A regra sobrevive com custo diferente; o que não sobrevive é fingir que ela existe.

3.5. Como as seis propriedades se encaixam

A Tabela 3.1 reúne a tríade do Capítulo 2 e as três deste capítulo, com o mecanismo típico de cada uma.

Tabela 3.1.: As seis propriedades, a pergunta de cada uma e o mecanismo que a sustenta.

Propriedade	Pergunta que responde	Mecanismo típico
Confidencialidade	Quem consegue ler?	Controle de acesso, cifragem, minimização
Integridade	Foi alterado?	Hash, restrições, transações, armazenamento imutável

3. Autenticidade, não repúdio e responsabilização

Propriedade	Pergunta que responde	Mecanismo típico
Disponibilidade	Está acessível quando preciso?	Redundância, capacidade, backup testado
Autenticidade	Veio mesmo de quem diz?	HMAC, assinatura digital, certificados, DKIM
Não repúdio	A origem pode negar depois?	Assinatura com chave sob controle exclusivo, carimbo de tempo
Responsabilização	Quem fez o quê?	Conta nomeada, log íntegro, relógio sincronizado, segregação

A leitura mais útil dessa tabela é diagnóstica: diante de um incidente, perguntar qual das seis linhas falhou costuma apontar o controle ausente mais rápido do que qualquer outra heurística.

3.6. Brasil em Foco

O Brasil construiu, antes da maioria dos países, um arcabouço jurídico para autenticidade e não repúdio de documento eletrônico — e ele tem detalhes que mudam decisões técnicas.

A **Medida Provisória nº 2.200-2/2001** instituiu a ICP-Brasil e é a peça central (Brasil, 2001). Seu art. 10, §1º estabelece que declarações constantes de documento eletrônico assinado com certificado ICP-Brasil **presumem-se verdadeiras em relação aos signatários**. É presunção relativa — admite prova em contrário —, mas inverte o ônus: quem nega precisa provar que não assinou. O §2º do mesmo artigo é igualmente importante e menos citado: admite outros meios de comprovação de autoria e integridade, **desde que aceitos pelas partes ou pela pessoa a quem for oposto o documento**. Ou seja, assinatura fora da ICP-Brasil vale — só não carrega a presunção legal, e depende de acordo prévio ou de convencimento no caso concreto.

A **Lei nº 14.063/2020** organizou o campo em três níveis (Brasil, 2020):

Tabela 3.2.: Os três níveis de assinatura eletrônica da Lei 14.063/2020.

Nível	O que exige	Uso típico
Simple	Identifica o signatário e anexa dados em formato eletrônico	Interações de baixo risco; login em serviço público
Avançada	Controle exclusivo do signatário, detecção de alteração posterior, vínculo com a identidade — sem exigir ICP-Brasil	Atos de médio risco; assinatura gov.br
Qualificada	Certificado ICP-Brasil	Atos de maior risco, registro público, o que a lei exigir

O **Código de Processo Civil** completa o quadro: o art. 411 dispõe que se considera autêntico o documento quando assinado digitalmente na forma da lei, e o art. 441 admite documentos eletrônicos produzidos e conservados com observância da legislação específica. Na prática forense, log de servidor sem assinatura nem cadeia de custódia não é imprestável, mas seu peso probatório depende inteiramente da credibilidade do processo de coleta — assunto do Volume 13.

Para **responsabilização**, o Marco Civil impõe a guarda de registros (arts. 13 e 15) e submete sua disponibilização a ordem judicial (arts. 10 e 22), exigindo do requerente indícios do ilícito, identificação clara do usuário e período determinado (Brasil, 2014). O provedor precisa, portanto, conseguir responder *a quem pertencia aquele endereço IP naquele instante* — o que, num cenário de CGNAT, depende de registrar também a porta de origem e o horário com precisão. Registro sem porta em rede com NAT em larga escala responde por centenas de assinantes ao mesmo tempo e não individualiza ninguém.

A **LGPD** trata responsabilização como princípio expreso: o art. 6º, X exige a demonstração da adoção de medidas eficazes de cumprimento (*accountability*), e o art. 37 obriga o controlador e o operador a **manter registro das operações de tratamento** que realizarem (Brasil, 2018). Não é registro técnico apenas — é registro que precisa ser exibível à ANPD.

Do lado penal, a **Lei nº 12.737/2012** e a **Lei nº 14.155/2021** alcançam diretamente a falsidade de origem: o estelionato praticado por meio eletrônico ganhou forma qualificada no art. 171, §2º-A do Código Penal, com pena de reclusão de 4 a 8 anos, e o §2º-B agrava quando praticado contra idoso ou vulnerável (Brasil, 2021). A fraude do e-mail corporativo do caso de abertura é exatamente essa figura, e a investigação depende dos registros que o Marco Civil obriga a guardar.

Por fim, para quem opera telecomunicações: a Anatel exige identificação inequívoca do assinante no cadastro, e o **Pix** trouxe ao Banco Central um regime em que a autenticidade da ordem de pagamento é responsabilidade da instituição — com o Mecanismo Especial de Devolução para casos de fraude. É o Volume 10 que retoma o tema pelo lado da engenharia social.

3.7. No Campo

1. Acabar com a conta compartilhada. É a intervenção de maior retorno deste capítulo. Cada pessoa com sua conta em servidores, roteadores, OLTs, sistema de gestão e painel do provedor de nuvem. Em equipamento de rede, centralizar em RADIUS ou TACACS+ resolve simultaneamente a nomeação, a revogação no desligamento e o registro:

```
# Chaves SSH autorizadas - cada linha deve ter dono identificável no comentário
for u in $(awk -F: '$3>=1000 {print $1}' /etc/passwd); do
    f="/home/$u/.ssh/authorized_keys"
    [ -f "$f" ] && awk -v u="$u" '{print u, $NF}' "$f"
done

# Quem usou sudo nas últimas 24 h, e para quê
journalctl _COMM=sudo --since "24 hours ago" -o cat | grep -oP 'USER=\S+ ;
↳  COMMAND=.*'

# Contas com senha vazia ou sem expiração definida
awk -F: '($2 == "" ) {print "SEM SENHA:", $1}' /etc/shadow
```

2. Enviar o log para fora da máquina, no ato. Coletor remoto que a origem não pode reescrever. No **rsyslog**, uma linha basta; o essencial é o coletor **não** aceitar que o cliente apague o que já enviou:

3. Autenticidade, não repúdio e responsabilização

```
# /etc/rsyslog.d/90-remoto.conf - encaminha tudo, com fila em disco se o
↪ coletor cair
*. * action(type="omfwd" target="10.20.0.9" port="6514" protocol="tcp"
      StreamDriver="gtls" StreamDriverMode="1"
      queue.type="LinkedList" queue.filename="fwd"
      ↪ queue.saveOnShutdown="on")
```

3. Sincronizar o relógio em tudo. Servidor, roteador, switch, OLT, câmera, controlador de acesso. Diferença de fuso e horário de verão devem ser tratados registrando em UTC e convertendo na exibição:

```
timedatectl set-timezone America/Sao_Paulo
timedatectl set-ntp true
chronyc tracking | grep -E 'Reference ID|System time|Stratum'
```

4. Autenticar o e-mail do próprio domínio. SPF, DKIM e DMARC publicados, com política progressiva: começar em `p=none` para colher relatórios, corrigir os remetentes legítimos que falharem e só então subir para `quarantine` e `reject`:

```
dig +short TXT provedor.exemplo.br          # SPF
dig +short TXT _dmarc.provedor.exemplo.br   # DMARC
dig +short TXT seletor._domainkey.provedor.exemplo.br # DKIM
```

E o complemento defensivo contra o caso de abertura: registrar os domínios parecidos com o seu (troca de hífen, letras trocadas, `.com` por `.com.br`) e monitorar registros novos semelhantes ao seu domínio, que é o que viabiliza a fraude.

5. Um processo, não um produto, para pagamento. Alteração de dados bancários de fornecedor confirmada por telefone constante do cadastro anterior, nunca pelo contato informado na própria mensagem. Aprovação por segunda pessoa acima de um limite definido. Revisão mensal, por alguém de fora do processo, de todos os cadastros bancários alterados no período.

6. Assinar o que precisa sobreviver a uma disputa. Contrato com assinatura qualificada quando a lei exigir, avançada quando bastar. Pacote e imagem distribuídos para clientes assinados. Em repositório de código, assinar as versões publicadas:

```
# Verificar assinatura de um pacote antes de instalar
gpg --verify release-2.4.tar.gz.asc release-2.4.tar.gz

# Assinar as próprias tags de versão
git tag -s v2.4 -m "versão 2.4" && git tag -v v2.4
```

7. Testar a responsabilização com uma pergunta. Escolha uma alteração de configuração feita há três meses num equipamento de borda e tente responder, apenas com o que está registrado: quem fez, de onde, com que autorização, e quem aprovou. Se a resposta não sair em quinze minutos, o problema não é o log — é o desenho do processo.

3.8. Resumo

- **Identificação, autenticação, autorização e responsabilização** são quatro perguntas distintas. Tratar dado de identificação (CPF, número de contrato) como prova de identidade é a raiz de boa parte da fraude por atendimento.
- **Autenticidade** garante que a origem é quem afirma ser; integridade só garante que nada foi alterado. A diferença é a existência de um segredo detido pela origem — e é por isso que hash publicado ao lado do arquivo não autentica nada.
- **HMAC** dá autenticidade entre duas partes que compartilham a chave; só a **assinatura digital**, com chave privada sob controle exclusivo, sustenta **não repúdio** perante terceiros.
- SPF, DKIM e DMARC autenticam o *domínio*, não a *identidade comercial*: um domínio parecido, registrado pelo golpista e corretamente configurado, passa em todos os três. Contra isso, o controle é de processo — confirmação por canal independente.
- **Não repúdio técnico jurídico**. Exige controle exclusivo da chave, vínculo auditável com a pessoa, carimbo de tempo, preservação do documento e registro do processo; faltando um, resta evidência forte, não impossibilidade de negar.
- **Responsabilização** exige conta nomeada, registro suficiente, relógio sincronizado e log íntegro — encadeado por hash e enviado a um coletor remoto que a máquina de origem não pode reescrever. Conta **admin** compartilhada a destrói inteiramente.
- No Brasil: MP 2.200-2/2001 dá presunção de veracidade à assinatura ICP-Brasil e admite outros meios acordados entre as partes; a Lei 14.063/2020 estabelece os níveis simples, avançada e qualificada; o Marco Civil exige guarda de registros que individualizem o usuário (porta inclusa, sob CGNAT); a LGPD faz da *accountability* princípio e do registro de operações uma obrigação.

4. Ativos, ameaças, vulnerabilidades e risco

Numa sexta-feira à noite, o boletim do CERT.br e metade dos canais técnicos anunciam a mesma coisa: falha crítica de execução remota de código num servidor de aplicação amplamente usado, com exploração já observada na internet, nota máxima de severidade. O coordenador de TI do provedor lê o alerta e faz a única pergunta que importa: **nós temos isso rodando em algum lugar?**

Ninguém sabe responder. Há trinta e dois servidores em produção, três deles herdados de uma aquisição de 2021, dois em nuvem contratados diretamente pelo comercial sem passar pela TI, e um que “acho que só serve o portal antigo, mas ninguém desliga porque tem medo”. A resposta chega no domingo à tarde, depois de uma varredura improvisada: sim, dois servidores, um deles exposto à internet. O tempo entre a pergunta e a resposta — quarenta e uma horas — foi tempo de exposição pura, com exploração ativa acontecendo no mundo.

Essa é a diferença prática entre uma organização que gerencia risco e uma que reage a manchete. E ela começa não pela ferramenta de correção, mas pelo termo mais entediante do vocabulário: **inventário**.

O Capítulo 1 fixou o vocabulário mínimo numa tabela. Este capítulo abre cada um daqueles termos até o ponto em que eles viram método de trabalho: como levantar ativos, como caracterizar ameaças, como classificar vulnerabilidades com os identificadores que a indústria usa, e como combinar as três coisas em uma estimativa de risco que sustente uma decisão.

4.1. A cadeia que liga os quatro termos

Os quatro conceitos não são uma lista: são uma cadeia causal, e cada elo tem um tipo de controle que age sobre ele (Figura 4.1).

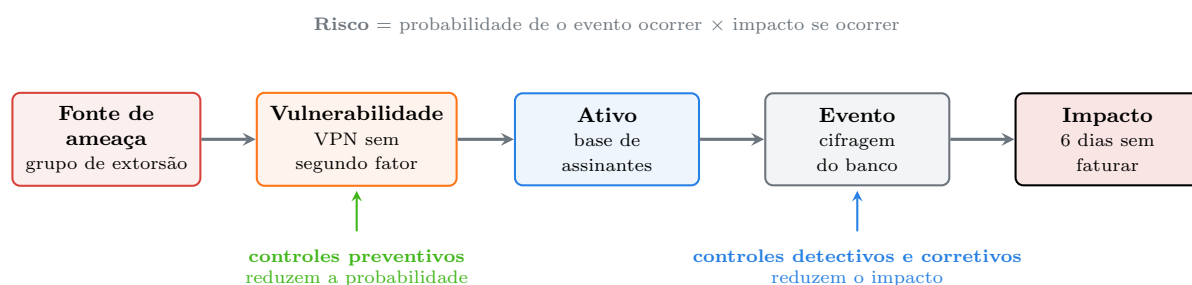


Figura 4.1.: A cadeia do risco. Não se elimina a fonte de ameaça; o trabalho recai sobre a vulnerabilidade (probabilidade) e sobre o impacto.

A leitura dessa cadeia responde a uma pergunta prática recorrente: onde investir? À esquerda, reduzindo a chance de o evento acontecer; à direita, reduzindo o estrago quando acontecer. Programas imaturos gastam quase tudo à esquerda. Programas maduros equilibram, porque a probabilidade nunca chega a zero e o custo marginal de reduzi-la cresce muito mais rápido que o de conter o impacto.

4.2. Ativos: o inventário é o alicerce

Ativo é qualquer coisa que tenha valor para a organização. O Capítulo 1 separou ativos **primários** (a informação e os processos de negócio) de ativos de **suporte** (hardware, software, rede, instalações, pessoas). Falta agora o método: como construir e manter o inventário que responde à pergunta de sexta-feira à noite.

4.2.1. O que precisa constar

Um inventário útil não é uma lista de nomes de máquina. Para cada ativo relevante, cinco campos fazem a diferença entre planilha decorativa e ferramenta de decisão:

Tabela 4.1.: Campos mínimos de um inventário de ativos que sustenta decisão.

Campo	Por que importa
Identificação e localização	Onde está fisicamente e logicamente (endereço, VLAN, provedor de nuvem, conta)
Dono	Pessoa nomeada que decide sobre ele — não “a TI”
Classificação	Qual informação trafega ou repousa ali, e sua sensibilidade
Dependências	De que depende e quem depende dele; alimenta a análise de impacto
Versões e fim de suporte	Sistema operacional, aplicação, firmware — é o campo que responde à pergunta do boletim

O campo **dono** é o que costuma faltar e o que mais paralisa a resposta a incidente: sem alguém nomeado, a decisão de desligar um servidor às 23h de domingo não tem quem a tome.

4.2.2. Como levantar, na prática

Nenhuma fonte isolada é completa; a interseção de várias é o que aproxima da realidade:

- **Varredura ativa** da própria faixa de endereços — encontra o que responde.
- **Escuta passiva** de ARP, DHCP e fluxos (NetFlow/sFlow) — encontra o que existe mas não responde a varredura, e o que aparece só de vez em quando.
- **Fontes administrativas** — faturas do provedor de nuvem, contratos de licença, notas fiscais de compra, registros de domínio. É onde aparecem os dois servidores que o comercial contratou sozinho.
- **Diretório e gerência de configuração** — objetos do Active Directory, agentes instalados, gerenciador de pacotes.
- **A conversa.** Perguntar a cada área “que sistema você usa que a TI talvez não conheça?” produz achados que nenhuma varredura produz, porque nuvem contratada por cartão de crédito não aparece na rede interna.

O que se descobre nesse cruzamento tem nome: **TI sombra** (*shadow IT*) e **ativos órfãos**. São, sistematicamente, os ativos com pior postura de segurança do ambiente, porque não estão em nenhuma rotina de correção, backup ou monitoramento.

4.2.3. Superfície de ataque

Do inventário deriva o conceito operacional mais útil deste capítulo: a **superfície de ataque** é o conjunto de pontos por onde um adversário pode interagir com o sistema. Reduzi-la é o controle de melhor retorno que existe, porque um serviço que não está exposto não precisa ser corrigido com urgência.

Ela tem três dimensões, e a terceira é a esquecida: a superfície de **rede** (portas e serviços alcançáveis), a de **software** (código, bibliotecas, dependências, funcionalidades habilitadas) e a **humana** (quem pode ser alvo de engenharia social, quantas pessoas têm privilégio administrativo, quantos terceiros têm acesso).

4.3. Ameaças: quem ou o quê, e com que capacidade

Ameaça é a causa potencial de um incidente indesejado. O Capítulo 1 apresentou as três origens (deliberada, accidental, ambiental) e os perfis de agente. O que falta é como *usar* isso: caracterizar uma ameaça com três atributos.

Fonte. Quem ou o quê. Para agentes deliberados, o perfil (oportunista automatizado, crime organizado, pessoa interna, ativismo, estado-nação); para os demais, o fenômeno (erro de operação, falha de equipamento, descarga atmosférica).

Capacidade e recursos. O oportunista automatizado usa exploração pública contra falha conhecida e desiste diante de qualquer atrito. O crime organizado compra acesso inicial, tem semanas de paciência e um orçamento. Um estado-nação desenvolve exploração própria para falha desconhecida. A capacidade determina quais controles fazem diferença: bloquear o primeiro é barato; conter o terceiro é outro orçamento.

Motivação e alvo. O oportunista não escolheu você; o crime organizado escolheu seu *setor*; a pessoa interna insatisfeita escolheu *você especificamente*. Isso muda a resposta: contra o indiscriminado, higiene básica resolve; contra o direcionado, é preciso assumir comprometimento e investir em detecção.

Catálogos ajudam a não depender de imaginação. O **MITRE ATT&CK** organiza táticas e técnicas efetivamente observadas em ataques reais, e serve tanto para modelar ameaça quanto para medir cobertura de detecção (MITRE Corporation, 2024); a ISO/IEC 27005 traz listas de fontes de ameaça e de vulnerabilidades típicas (International Organization for Standardization, 2022). O Volume 11 dedica um capítulo ao ATT&CK.

4.4. Vulnerabilidades: quatro tipos, não um

Vulnerabilidade é a fraqueza que pode ser explorada por uma ameaça. A palavra evoca falha de software, e essa associação estreita esconde três quartos do problema:

- **De software.** Erro de implementação ou de projeto no código: estouro de buffer, injeção, desserialização insegura. É a que recebe identificador CVE.
- **De configuração.** O software está correto; o modo como foi configurado, não. Credencial de fábrica, serviço administrativo exposto, permissão excessiva, cifra fraca habilitada, registro desligado. **É a categoria mais frequente em ambientes reais** e a que nenhum boletim avisa, porque não é falha do fornecedor.
- **De processo.** Não há revisão de acessos, o desligamento não revoga credenciais, o backup nunca é testado, não existe procedimento de resposta. Não aparece em varredura alguma.

4. Ativos, ameaças, vulnerabilidades e risco

- **Humana.** Suscetibilidade a engenharia social, senha reaproveitada, aprovação sem conferência. Tema do Volume 10.

Um programa de segurança que só trata a primeira categoria está tratando a minoria dos casos com a maior parte do orçamento.

4.4.1. O ciclo de vida de uma vulnerabilidade e a janela de exposição

Toda vulnerabilidade de software percorre uma linha do tempo, e o que importa nela são os intervalos, não os pontos (Figura 4.2).

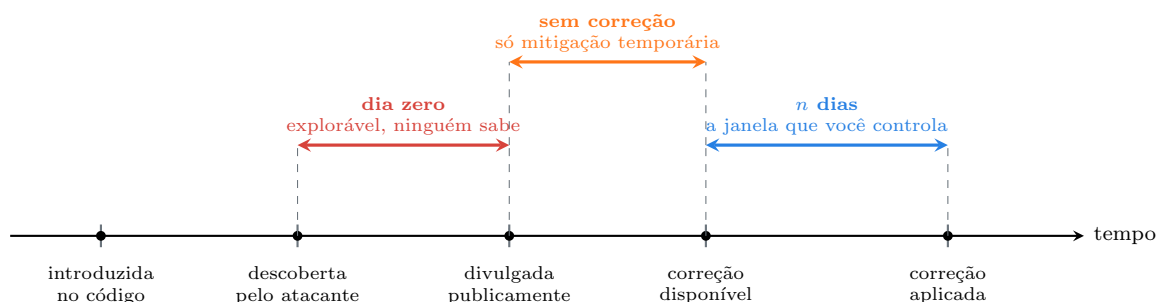


Figura 4.2.: A linha do tempo de uma vulnerabilidade. O intervalo de n dias é o único que depende inteiramente da organização.

O ponto central da figura é político, não técnico. Contra o dia zero há pouco a fazer além de defesa em profundidade e detecção. Mas a janela de n dias — entre a correção existir e a correção estar aplicada — é integralmente responsabilidade da organização, e é onde a esmagadora maioria dos comprometimentos reais acontece. Atacantes não gastam dia zero em provedor regional: usam falhas com correção publicada há meses.

Vale a distinção: **exploração** (*exploit*) é o código ou a técnica que tira proveito da falha; **prova de conceito** demonstra que é possível; **exploração armada** é a versão confiável e automatizada. O intervalo entre divulgação e exploração armada disponível encurtou de meses para dias, e às vezes horas.

4.4.2. Os identificadores que a indústria usa

Cinco siglas aparecem em todo boletim, e cada uma responde a uma pergunta diferente. Confundi-las leva a priorizar errado.

Tabela 4.2.: Os identificadores de vulnerabilidade e a pergunta de cada um.

Sigla	O que é	Pergunta que responde
CVE	Identificador único de uma vulnerabilidade concreta em um produto	<i>Qual</i> falha é essa?
CWE	Catálogo de tipos de fraqueza (ex.: CWE-89, injeção de SQL)	De que <i>classe</i> ela é?

Sigla	O que é	Pergunta que responde
CVSS	Pontuação de severidade de 0 a 10, com métricas base, de ameaça e ambientais	Quão <i>grave</i> ela é?
EPSS	Probabilidade estimada de exploração nos próximos 30 dias	Quão <i>provável</i> é ser explorada?
KEV	Catálogo de vulnerabilidades com exploração confirmada em ataques reais	Já está sendo <i>usada</i> ?

O erro mais comum e mais caro é tratar **CVSS como fila de prioridade**. O CVSS mede severidade *intrínseca*, sob a premissa do pior caso (Forum of Incident Response and Security Teams, 2023). Numa base típica, milhares de itens pontuam 7,0 ou mais — corrigir por ordem de nota significa gastar semanas em falhas que ninguém explora, enquanto uma de nota 6,5 com exploração ativa segue aberta.

A priorização que funciona combina três eixos, ilustrados na Figura 4.3: severidade (CVSS, ajustado pelas métricas ambientais que refletem *seu* contexto), probabilidade de exploração (EPSS e KEV) e **exposição real do ativo** — se o serviço vulnerável está atrás de VPN, sem alcance da internet, a urgência é outra.

4.5. Risco: juntando tudo

Risco é o efeito da incerteza sobre os objetivos (International Organization for Standardization, 2018b) — e, na formulação operacional que a segurança da informação usa, a combinação da probabilidade de um evento e do seu impacto:

$$\text{Risco} = P(\text{evento}) \times \text{Impacto}(\text{evento})$$

A fórmula é útil e é uma simplificação perigosa se levada ao pé da letra, por três motivos que valem registro desde já:

1. **Nem todo impacto é comparável.** Um evento com 1% de chance e R\$ 10 milhões de impacto e outro com 100% de chance e R\$ 100 mil de impacto têm o mesmo valor esperado e exigem decisões completamente diferentes: o segundo é custo operacional, o primeiro é ameaça à existência da empresa.
2. **As distribuições têm cauda pesada.** Perdas por incidente não se distribuem em torno de uma média bem-comportada; o valor esperado subestima sistematicamente o cenário ruim.
3. **A probabilidade raramente é conhecida.** É estimada, e a qualidade da estimativa é o que o Capítulo 6 trata em detalhe.

Duas distinções completam o quadro. **Risco inerente** é o risco antes de qualquer controle; **risco residual** é o que sobra depois deles aplicados — e é o número que a direção precisa conhecer e aceitar formalmente. E o impacto tem camadas: o **direto** (horas de indisponibilidade, custo de recuperação, dado perdido) costuma ser o menor; o **indireto** (multa da ANPD, ação de titulares, perda de assinantes, custo de aquisição para repor a base, reputação junto ao regulador) é que decide a sobrevivência da empresa.

4. Ativos, ameaças, vulnerabilidades e risco

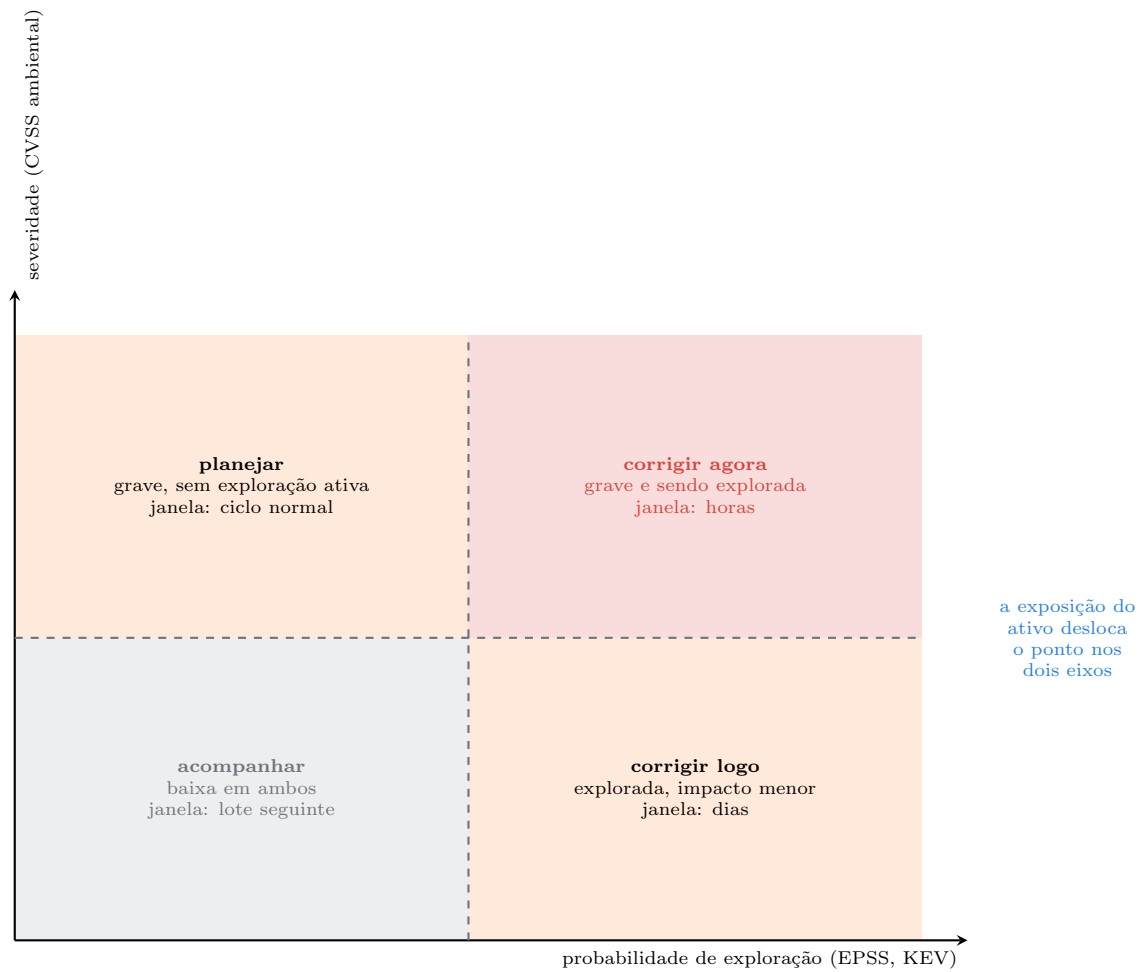


Figura 4.3.: Priorização por severidade e por probabilidade de exploração. A nota isolada do CVSS não distingue o quadrante superior esquerdo do superior direito.

4.5.1. Controles: três funções, três naturezas

Fechando a cadeia, **controle** é a medida que modifica o risco. Duas classificações que se cruzam e organizam qualquer conversa sobre o assunto:

Por **função**: **preventivo** (impede o evento — segundo fator, segmentação, menor privilégio), **detectivo** (revela que ocorreu — registro, alerta, integridade de arquivo), **corretivo** (restaura — backup, plano de resposta), e ainda **dissuasivo** (desestimula — aviso legal, câmera visível) e **compensatório** (substitui um controle inviável por outro de efeito equivalente).

Por **natureza**: **técnico** (firewall, cifragem), **administrativo** (política, procedimento, treinamento, contrato) e **físico** (fechadura, cerca, controle de acesso à sala).

A regra prática que decorre da Figura 4.1: um conjunto de controles só é defensável se cobrir as três funções. Só preventivos significa que, no dia em que um falhar, ninguém fica sabendo; só detectivos significa assistir ao incidente acontecer.

4.6. Brasil em Foco

A **LGPD** transformou inventário e análise de risco em obrigação documental. O art. 37 exige que controlador e operador **mantenham registro das operações de tratamento** de dados pessoais que realizarem — na prática, um inventário de ativos primários com finalidade, base legal, categorias de titulares, prazo de retenção e compartilhamentos (Brasil, 2018). O art. 38 faculta à ANPD determinar a elaboração de **relatório de impacto à proteção de dados pessoais**, documento que descreve os tratamentos, os riscos às liberdades civis e as medidas de mitigação — ou seja, exatamente a cadeia deste capítulo, escrita.

O art. 50 introduz as **regras de boas práticas e governança**, que a lei sugere considerando “a natureza, o escopo, a finalidade, a probabilidade e a gravidade dos riscos” — a linguagem é de gestão de risco, não de lista de controles obrigatórios. Isso tem consequência: no Brasil, não existe uma lista fechada de medidas que, cumprida, garante conformidade. O que se demonstra é o **processo**, e o processo começa por saber o que se tem.

Para agentes de tratamento de **pequeno porte**, a Resolução CD/ANPD nº 2/2022 flexibilizou obrigações, e a ANPD publicou guia orientativo de segurança da informação para esse público, com um conjunto mínimo de medidas — leitura recomendada para provedores regionais e empresas de suporte, por ser o parâmetro que a própria autoridade declara esperar (Autoridade Nacional de Proteção de Dados, 2023).

Do lado da telecomunicação, a Resolução Anatel nº 740/2020 exige que produtos de telecomunicações atendam a requisitos de segurança cibernética — sem senha padrão universal, com mecanismo de atualização de firmware e com correção de vulnerabilidades conhecidas (Agência Nacional de Telecomunicações, 2020). Para quem entrega ONU e roteador ao assinante, isso significa incluir o **parque de equipamentos de cliente no inventário**: são dezenas de milhares de ativos sob responsabilidade do provedor, e um firmware vulnerável em massa é simultaneamente risco ao assinante, risco à rede e questão regulatória.

No setor financeiro, a Resolução CMN nº 4.893/2021 exige classificação de dados e sistemas por relevância, avaliação de riscos e controles proporcionais, além de exigir a gestão de risco de **serviços de terceiros** relevantes (Banco Central do Brasil, 2021) — o que puxa fornecedores e integradores para dentro do escopo.

Institucionalmente, o **CERT.br** publica estatísticas de incidentes notificados e mantém material de boas práticas para redes; para órgãos federais, o **CTIR Gov** emite alertas de vulnerabilidade

4. Ativos, ameaças, vulnerabilidades e risco

e coordena resposta. Acompanhar essas fontes, mais o catálogo de vulnerabilidades exploradas conhecidas mantido pela CISA norte-americana, é o mínimo para não descobrir por manchete.

4.7. No Campo

1. Construir o inventário em uma semana, não em um projeto de seis meses. A versão de 20% que existe vale infinitamente mais que a versão completa que nunca fica pronta. Uma planilha com os cinco campos da Tabela 4.1, preenchida com o cruzamento de varredura, faturas e conversa, já responde à pergunta de sexta-feira à noite:

```
# Ativos que respondem na rede, com serviço e versão detectados
nmap -sS -sV -Pn --top-ports 500 --open -oA inventario 10.20.0.0/22

# Aprendizado passivo: quem já falou na rede recentemente
ip neigh show | awk '$4=="lladdr" {print $1, $5}' | sort -V

# Concessões de DHCP ativas - pega o que não estava ligado durante a varredura
grep -E 'lease|binding state active' /var/lib/dhcp/dhcpd.leases | head -40
```

2. Registrar dono e classificação, não só endereço IP. É o que transforma inventário em ferramenta de decisão. Sem dono nomeado, nenhuma decisão urgente sai do lugar.

3. Medir a superfície exposta e persegui-la até zero. Serviço administrativo alcançável da internet é o achado mais comum e mais caro. A meta não é reduzir: é zerar.

```
# O que este servidor escuta, em quais interfaces, e qual processo responde
ss -tulnp | awk 'NR==1 || $5 !~ /^(127\.|\[::1\])/ '

# Conferir de fora: o que o mundo enxerga do seu bloco
nmap -Pn -p- --open -T3 198.51.100.7

# Regras de firewall que permitem qualquer origem
iptables -S | grep -E '^-A (INPUT|FORWARD)' | grep -v ' -s '
```

4. Priorizar correção por exploração ativa, não por nota. A fila é: está no catálogo de exploração conhecida e o ativo está exposto → hoje. EPSS alto → esta semana. CVSS alto sem sinal de exploração e ativo interno → no ciclo mensal.

```
# Pacotes com atualização de segurança pendente (Debian/Ubuntu)
apt-get -s upgrade | grep -i security | awk '{print $2}' | sort -u

# Versões instaladas x fim de suporte - o campo que responde ao boletim
hostnamectl | grep -E 'Operating System|Kernel'
lsb_release -d 2>/dev/null; cat /etc/os-release | grep -E '^VERSION'
```

5. Manter um registro de risco de uma página. Dez linhas bastam: ativo, ameaça, vulnerabilidade, impacto estimado, probabilidade estimada, controle atual, controle proposto, dono, prazo, decisão. É o insumo do Capítulo 6 e o documento que a ANPD pede quando pergunta como a empresa avaliou seus riscos.

6. Incluir o parque de equipamentos de assinante. Modelo, versão de firmware, se aceita atualização remota, se tem credencial padrão. Dezenas de milhares de dispositivos com a mesma falha são o maior ativo de risco de um provedor — e o de maior potencial de dano a terceiros.

7. Assinar as fontes de alerta e definir quem lê. Boletins do CERT.br, avisos do fabricante dos equipamentos em uso, catálogo de vulnerabilidades exploradas. Um responsável nomeado, revisão semanal, e um caminho definido para escalar o que for urgente fora do horário. Alerta que chega numa caixa que ninguém abre é o mesmo que alerta que não chegou.

4.8. Resumo

- Os quatro termos formam uma **cadeia causal**: a fonte de ameaça explora uma vulnerabilidade de um ativo, produzindo um evento com impacto. Controles preventivos agem sobre a probabilidade; detectivos e corretivos, sobre o impacto — e um programa defensável cobre as duas pontas.
- **Inventário é o alicerce.** Sem dono nomeado, classificação e versões registradas, a pergunta “nós temos isso?” não tem resposta rápida, e a demora é exposição pura. TI sombra e ativos órfãos são sistematicamente os piores do ambiente.
- Vulnerabilidade não é só falha de software: as de **configuração, de processo e humanas** somam a maioria dos casos reais e não aparecem em boletim nem em varredura.
- A janela de *n dias* — entre a correção existir e estar aplicada — é a única inteiramente sob controle da organização, e é onde ocorre a maior parte dos comprometimentos. Dia zero é raro contra alvos comuns.
- **CVE, CWE, CVSS, EPSS e KEV** respondem perguntas diferentes. Priorizar pela nota do CVSS é o erro caro mais comum: a fila correta combina severidade ajustada ao contexto, probabilidade de exploração e exposição real do ativo.
- **Risco = probabilidade × impacto** é útil como organizador e enganoso como número único: impactos catastróficos e recorrentes não são intercambiáveis, as distribuições têm cauda pesada, e o impacto indireto costuma superar o direto.
- No Brasil, a LGPD converte inventário (art. 37) e avaliação de risco (arts. 38 e 50) em obrigação demonstrável; a Anatel 740/2020 traz o parque de equipamentos do assinante para dentro do escopo; e a Resolução CMN 4.893/2021 estende a gestão de risco aos fornecedores relevantes.

5. Modelagem de ameaças: STRIDE, árvores de ataque e abuse cases

O provedor lançou o portal do assinante em quatro meses de desenvolvimento. Funcionava: segunda via de fatura, alteração de plano, abertura de chamado, histórico de consumo. Autenticação por CPF e senha, sessão com expiração, tráfego em HTTPS com certificado válido, senhas armazenadas com hash forte. Os testes de aceitação passaram todos.

Três semanas depois do lançamento, um assinante mandou uma mensagem para o suporte, sem qualquer má intenção: ele havia percebido que a URL da fatura terminava em `/fatura/48213`, trocou o número por `48212` e apareceu a fatura de outra pessoa — nome, CPF, endereço, valor. Testou mais alguns. Todos abriam.

A falha é conhecida, tem nome (referência direta insegura a objeto), e leva talvez vinte minutos para corrigir. O que custou caro não foi a correção: foi que 4.000 assinantes ficaram com dados pessoais expostos por três semanas, e que o incidente virou comunicação à ANPD.

O detalhe que interessa a este capítulo é outro. Nenhum teste teria pego isso, porque todos os testes verificavam que **o sistema faz o que deve fazer**. Ninguém verificou que ele **não faz o que não deve**. A pergunta “e se o usuário trocar o número na URL?” não custa nada, não exige ferramenta e leva menos de um minuto — desde que alguém a faça. Fazer sistematicamente essa classe de pergunta, antes de construir, é o que se chama modelagem de ameaças.

5.1. O que é, e quando fazer

Modelagem de ameaças é o exercício estruturado de antecipar como um sistema pode ser atacado, antes de ele existir ou antes de ele mudar. Adam Shostack a resume em quatro perguntas (Shostack, 2014), e a virtude do método está inteiramente na disciplina de responder as quatro, na ordem:

1. **O que estamos construindo?** Um desenho do sistema que todos concordam que está correto.
2. **O que pode dar errado?** A parte criativa, guiada por um catálogo para não depender de inspiração.
3. **O que vamos fazer a respeito?** Cada ameaça vira uma decisão com dono e prazo.
4. **Fizemos um bom trabalho?** Revisão do próprio exercício.

A terceira e a quarta perguntas são as que separam modelagem de conversa. Um modelo que produz uma lista de ameaças e nenhuma decisão registrada não mudou nada.

Sobre **quando**: o retorno é máximo quando ainda é barato mudar — ao desenhar um sistema novo, ao alterar arquitetura, ao integrar um terceiro, ao expor algo que antes era interno, ao mudar quem pode acessar o quê. Não é ritual anual; é gatilho por mudança. E não precisa ser pesado: uma sessão de noventa minutos com quadro branco, a pessoa que desenvolve, a que opera a infraestrutura e alguém do negócio cobre a maior parte do valor.

5.2. Pergunta 1: desenhar o sistema

O formato que melhor sustenta o exercício é o **diagrama de fluxo de dados**, com cinco elementos e uma convenção visual estável:

- **Entidade externa** — quem interage e está fora do seu controle (assinante, integração de terceiro).
- **Processo** — código que executa e transforma dados (aplicação, API, serviço).
- **Armazenamento** — onde os dados repousam (banco, arquivo, fila, cache).
- **Fluxo de dados** — o que trafega, e por qual canal.
- **Fronteira de confiança** — a linha em que o nível de confiança muda. É o elemento mais importante do diagrama.

A regra prática que rende mais: **ameaças se concentram onde os fluxos cruzam fronteiras de confiança**. Um desenho sem fronteiras marcadas não é um modelo de ameaças, é um diagrama de arquitetura. A Figura 5.1 desenha o portal do caso de abertura.

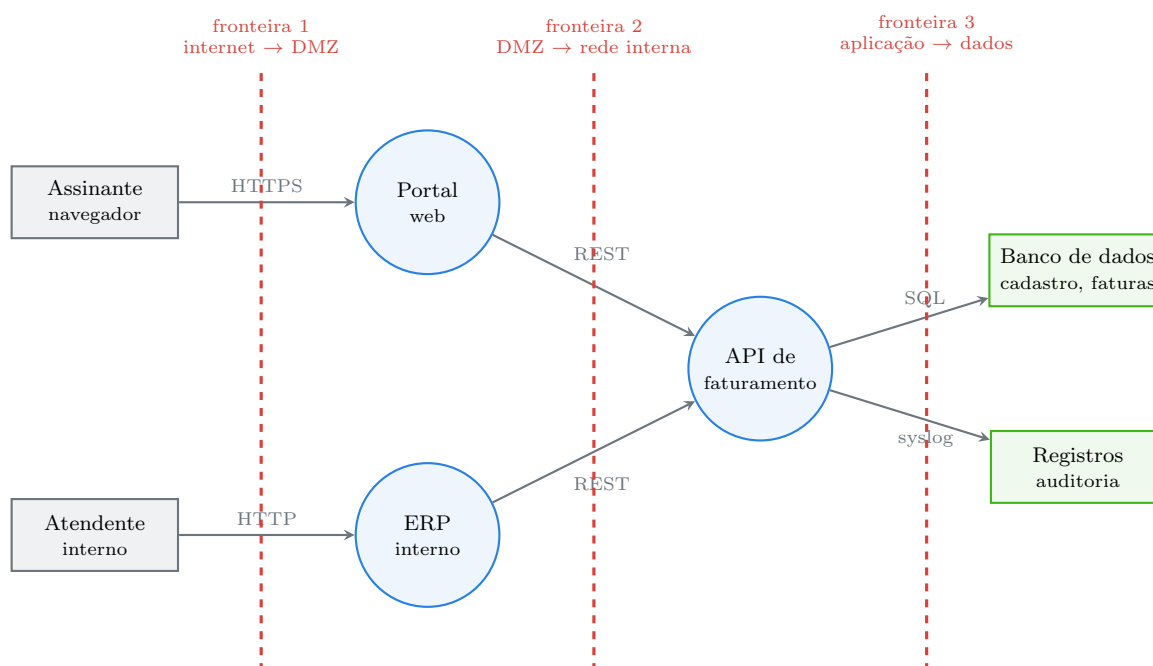


Figura 5.1.: Diagrama de fluxo de dados do portal do assinante. As três linhas vermelhas são onde o esforço de análise se concentra.

Duas dicas de execução. Primeira: desenhe no nível de detalhe em que as decisões são tomadas — um diagrama com trinta caixas não é analisado por ninguém. Segunda: valide o desenho com quem construiu o sistema. É frequente descobrir, nessa validação, um fluxo que não estava no desenho e que ninguém lembrava que existia — e esse fluxo esquecido é, com frequência desconfortável, exatamente onde está o problema.

5.3. Pergunta 2: o que pode dar errado

5.3.1. STRIDE

O **STRIDE** é o catálogo mais usado, e sua elegância está em ser o complemento exato das propriedades de segurança dos capítulos anteriores: cada letra é a violação de uma propriedade.

Tabela 5.1.: STRIDE e sua correspondência com as propriedades de segurança.

Letra	Ameaça	Propriedade violada	Exemplo no portal	Contramedida típica
S	<i>Spoofing</i> — falsificação de identidade	Autenticidade	Entrar como outro assinante com CPF vazado e senha fraca	Autenticação forte, segundo fator, TLS mútuo
T	<i>Tampering</i> — adulteração	Integridade	Alterar o valor da fatura num parâmetro da requisição	Validação no servidor, assinatura, restrições no banco
R	<i>Repudiation</i> — repúdio	Não repúdio	Negar que pediu a mudança de plano	Log íntegro, conta nomeada, carimbo de tempo
I	<i>Information disclosure</i> — vazamento	Confidencialidade	Trocar o número da URL e ver a fatura alheia	Autorização por objeto, minimização, cifragem
D	<i>Denial of service</i> — negação de serviço	Disponibilidade	Esgotar a API com requisições em massa	Limitação de taxa, cota, dimensionamento, filtragem
E	<i>Elevation of privilege</i> — elevação de privilégio	Autorização	Assinante alcançar função de atendente	Menor privilégio, verificação de papel no servidor

A falha do caso de abertura é um **I** clássico — e ela ilustra por que o catálogo funciona: bastava alguém percorrer as seis letras para o fluxo “assinante consulta fatura” e perguntar “como haveria vazamento de informação aqui?”.

A técnica que sistematiza isso chama-se **STRIDE por elemento**: em vez de olhar o sistema inteiro de uma vez, aplicar as letras relevantes a cada elemento do diagrama. Nem todas se aplicam a todos:

- **Entidade externa:** S, R
- **Processo:** todas as seis
- **Armazenamento:** T, I, D (e R, se for o armazenamento dos próprios logs)
- **Fluxo de dados:** T, I, D

Para o portal da Figura 5.1, isso significa cerca de trinta perguntas — algumas descartadas em segundos, outras rendendo achados. É trabalho de uma tarde, e é a razão pela qual a modelagem tem retorno tão desproporcional ao custo.

5.3.2. Árvores de ataque

O STRIDE responde “que categorias de coisa podem dar errado”. A **árvore de ataque**, proposta por Bruce Schneier, responde a uma pergunta diferente e complementar: *dado um objetivo do atacante, quais são todos os caminhos até ele?* (Schneier, 1999)

A raiz é o objetivo; os nós internos são submetas; as folhas são ações concretas. Os nós se combinam de duas formas: **OU** (qualquer filho basta) e **E** (todos os filhos são necessários). A Figura 5.2 monta a árvore para o objetivo mais realista no contexto de um provedor.

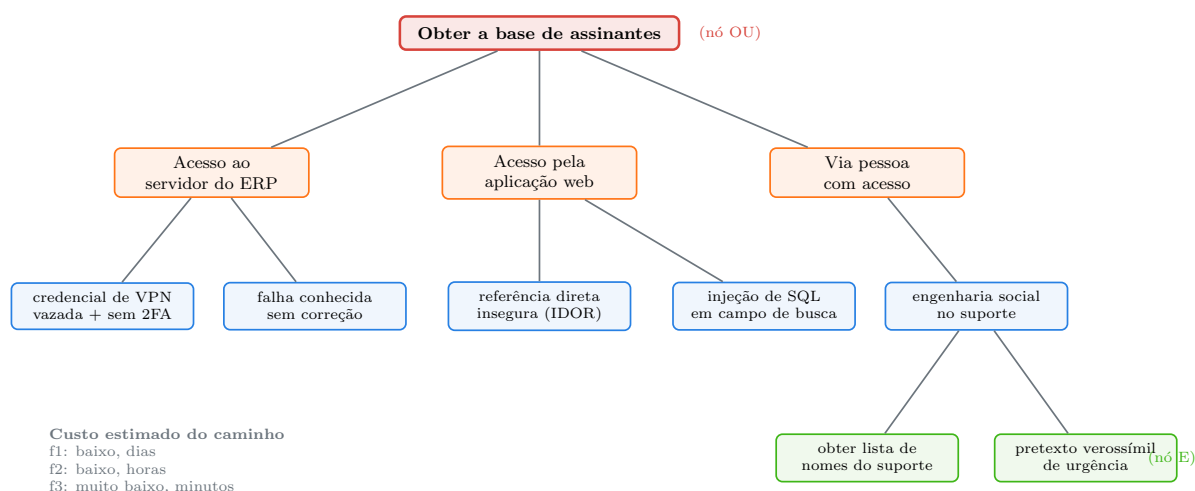


Figura 5.2.: Árvore de ataque para a base de assinantes. O caminho mais barato — não o mais sofisticado — é o que descreve o adversário real.

O valor da árvore aparece quando se anotam as folhas com **custo, tempo e habilidade requerida**. O caminho mais barato define o adversário mais provável, e é ali que o primeiro real de defesa rende mais. No exemplo, gastar em detecção sofisticada enquanto existe uma referência direta insegura explorável em minutos é investir no ramo errado da árvore.

Árvores também mostram onde um único controle corta vários caminhos ao mesmo tempo — segundo fator na VPN elimina f1 e encarece f5. Esse é o tipo de raciocínio que uma lista de vulnerabilidades ordenada por nota nunca produz.

5.3.3. Abuse cases

O terceiro instrumento parte do que a equipe já escreve. Para cada **caso de uso**, escreve-se o **caso de abuso** correspondente: o mesmo ator, com intenção hostil, ou um ator novo que ninguém previu.

Caso de uso. Como assinante autenticado, quero consultar minha fatura para pagá-la.

Caso de abuso. Como assinante autenticado, quero consultar a fatura de outro assinante alterando o identificador na URL.

Critério de aceitação derivado. A requisição de fatura cujo identificador não pertence ao assinante da sessão retorna 404, registra o evento com origem e identificador tentado, e dispara alerta após cinco tentativas.

O ganho dessa formulação é institucional: o caso de abuso vira **critério de aceitação** e depois **teste automatizado**, entrando no mesmo fluxo em que a equipe já trabalha. Segurança que vive numa planilha à parte é esquecida; segurança que vira teste que quebra o build sobrevive.

5.4. Outras abordagens, e quando usá-las

STRIDE, árvores e casos de abuso cobrem a grande maioria das necessidades. Vale conhecer quatro alternativas pelo que cada uma acrescenta:

- **PASTA** — processo de sete estágios centrado em risco de negócio, com simulação de ataque. Mais pesado; adequado quando a modelagem precisa dialogar com análise financeira de risco.
- **LINDDUN** — o análogo do STRIDE para **privacidade**: vinculabilidade, identificabilidade, não repúdio (aqui como problema, não como propriedade desejável), detectabilidade, divulgação, inconsciência e não conformidade. É o instrumento certo para o relatório de impacto exigido pela LGPD, porque olha ameaças ao titular dos dados, não à empresa.
- **OCTAVE** — orientado a organização e ativos críticos, mais que a sistemas; útil em nível de programa.
- **MITRE ATT&CK** — não é método de modelagem, e sim catálogo de táticas e técnicas reais (MITRE Corporation, 2024). Excelente como fonte de folhas para árvores de ataque e como régua de cobertura de detecção. O Volume 11 aprofunda.

Uma nota sobre a **cadeia de ataque** (*kill chain*): modelar o ataque como sequência de etapas — reconhecimento, acesso inicial, execução, persistência, movimentação lateral, exfiltração — tem valor defensivo próprio, porque cada etapa é uma oportunidade de detecção e interrupção. Um adversário precisa vencer todas; o defensor precisa pegar uma.

5.5. Pergunta 3: o que fazer, e pergunta 4: fizemos bem?

Cada ameaça identificada termina em uma de quatro decisões, e a decisão precisa estar **escrita, com dono e prazo**:

- **Mitigar** — implantar controle que reduza probabilidade ou impacto.
- **Eliminar** — remover a funcionalidade ou o dado que cria a exposição. Subestimada: a funcionalidade que ninguém usa e que só existe porque estava no escopo original é o alvo mais fácil.
- **Transferir** — passar o risco a um terceiro (seguro, contrato, fornecedor especializado). Transfere o custo financeiro, nunca a responsabilidade perante o titular dos dados.
- **Aceitar** — decidir conviver com ele, conscientemente, registrado, por quem tem autoridade para isso.

A quarta pergunta de Shostack — *fizemos um bom trabalho?* — se responde com três checagens: todos os elementos do diagrama receberam as letras aplicáveis do STRIDE; alguém que não participou revisou o modelo; e as ameaças mitigadas geraram teste que detecta regressão.

5.5.1. Erros que esvaziam o exercício

- **Modelar uma vez.** O modelo envelhece na primeira mudança de arquitetura. Revisar por gatilho, não por calendário.
- **Modelar sem quem constrói.** Modelo feito só por segurança produz achados que a equipe de desenvolvimento não reconhece como reais, e nada é implementado.
- **Buscar completude.** Não existe lista exaustiva de ameaças. Um modelo que cobre as fronteiras de confiança e os fluxos principais entrega quase todo o valor; perseguir os últimos 5% consome o tempo que faltará para corrigir os 95%.
- **Parar na lista.** Sem decisão, dono e prazo, o documento é um inventário de preocupações.
- **Confundir com teste de invasão.** A modelagem antecipa o que *pode* dar errado no desenho; o teste verifica o que *está* errado na implementação. São complementares e não se substituem — o Volume 9 trata do segundo.

5.6. Brasil em Foco

A LGPD incorporou modelagem de ameaças ao ordenamento sem usar essa expressão. O art. 46, §2º determina que as medidas de segurança deverão ser observadas **desde a fase de concepção do produto ou do serviço até a sua execução** (Brasil, 2018) — é a positivação do princípio de *security e privacy by design*, e a única forma prática de cumpri-la é analisar riscos antes de construir. Uma decisão de arquitetura tomada sem essa análise e que depois causa vazamento é, sob esse dispositivo, falha demonstrável de diligência.

O **relatório de impacto à proteção de dados pessoais** do art. 38 é o produto formal mais próximo de um modelo de ameaças no direito brasileiro. Sua estrutura pede descrição dos tratamentos, dos riscos às liberdades civis e aos direitos fundamentais, e das salvaguardas adotadas — exatamente as perguntas 1, 2 e 3 de Shostack, com o foco deslocado: o risco a analisar é o risco **ao titular dos dados**, não à empresa. É por isso que o LINDDUN é mais adequado que o STRIDE para esse documento: uma funcionalidade pode ser perfeitamente segura para a organização e ainda assim criar vinculabilidade ou identificabilidade indevida para as pessoas.

A distinção tem consequência concreta no caso de abertura. Sob a ótica da empresa, o incidente foi vazamento de dados de clientes. Sob a ótica do titular, foi a exposição de nome, CPF, endereço e valor de fatura de 4.000 pessoas a qualquer um com um navegador — situação que o art. 48 obriga a comunicar à ANPD e aos titulares afetados quando houver risco ou dano relevante, no prazo de três dias úteis fixado pela Resolução CD/ANPD nº 15/2024 (Autoridade Nacional de Proteção de Dados, 2024). Modelar antes custaria uma tarde.

No setor financeiro e de pagamentos, a Resolução CMN nº 4.893/2021 exige que a política de segurança cibernética contemple **avaliação prévia** de novas tecnologias e de mudanças relevantes, e que a instituição avalie riscos antes de contratar serviços de terceiros (Banco Central do Brasil, 2021). Para telecomunicações, a Resolução Anatel nº 740/2020 exige que produtos sejam concebidos com requisitos de segurança, o que pressupõe análise na fase de projeto (Agência Nacional de Telecomunicações, 2020).

Um ponto prático para provedores regionais: a **ANPD reconhece proporcionalidade**. Para agentes de pequeno porte, a autoridade não espera um processo formal de sete estágios — espera evidência de que os riscos foram considerados e as decisões registradas (Autoridade Nacional de Proteção de Dados, 2023). Uma ata de duas páginas por projeto, com o diagrama, as ameaças levantadas e as decisões tomadas, é documento suficiente e mais defensável que a ausência de qualquer registro.

5.7. No Campo

1. A sessão de noventa minutos. Quadro branco, três pessoas (quem desenvolve, quem opera, quem entende o negócio), um sistema por vez. Primeiros 20 minutos: desenhar o fluxo de dados e marcar as fronteiras de confiança. Próximos 45: percorrer STRIDE por elemento nos fluxos que cruzam fronteira. Últimos 25: decidir o que fazer com cada achado, com dono e prazo. Fotografar o quadro e anexar à ata é registro suficiente.

2. Modelar a rede, não só a aplicação. Para quem administra infraestrutura, o exercício mais valioso é sobre o **acesso de gerência**. Fluxo: técnico → VPN → VLAN de gerência → OLT. Aplicando STRIDE ao fluxo que cruza a fronteira internet–VPN:

Tabela 5.2.: STRIDE aplicado ao acesso de gerência de rede.

Letra	Pergunta	Achado típico
S	Alguém consegue se passar por técnico?	Conta compartilhada, sem segundo fator
T	Dá para alterar a configuração em trânsito?	Telnet ou SNMPv2 na gerência
R	Dá para negar que fez a alteração?	Login <code>admin</code> genérico no equipamento
I	Dá para ler configuração ou tráfego?	Comunidade SNMP <code>public</code> habilitada
D	Dá para derrubar a gerência?	Plano de gerência sem separação do de dados
E	Dá para sair de um acesso limitado para total?	Um único nível de privilégio no equipamento

3. Transformar cada achado em verificação executável. O caso de abuso vira teste. Para o incidente de abertura, a verificação é uma linha:

```
# Autentica como assinante A e tenta ler a fatura do assinante B.
# Esperado: 404. Qualquer 200 aqui é falha de autorização por objeto.
curl -s -o /dev/null -w '%{http_code}\n' \
  -H "Authorization: Bearer $TOKEN_ASSINANTE_A" \
  https://portal.exemplo.br/api/fatura/48212
```

4. Verificar as fronteiras que você acha que existem. Modelo desenhado é hipótese; a rede é o fato. Vale confirmar que a DMZ não alcança a rede interna e que o servidor de aplicação não alcança o que não precisa:

```
# A partir de um host da DMZ: o que da rede interna responde? (esperado: só o
↪ previsto)
nmap -Pn -n --top-ports 50 --open 10.20.0.0/24

# Rotas e regras que contradizem a fronteira desenhada
ip route show
nft list ruleset | grep -A3 -E 'chain (forward|input)'
```

5. Guardar o modelo junto do código. Um arquivo Markdown no repositório, versionado com o sistema que descreve, com o diagrama e a tabela de ameaças e decisões. Modelo em pasta compartilhada some; modelo no repositório aparece na revisão de código.

6. Reservar dez minutos da revisão de mudança para a pergunta. Antes de subir alteração relevante: *esta mudança cria fluxo novo que cruza fronteira de confiança?* Se sim, as seis letras. Se não, segue. É o formato mais barato de modelagem contínua que existe.

7. Fazer o exercício da funcionalidade removida. Percorrer o sistema perguntando o que pode ser **desligado**: relatório que ninguém abre há um ano, campo coletado e nunca usado, integração de um projeto abandonado, endereço de API sem consumidor. Eliminar é a única mitigação com eficácia de 100% e custo de manutenção zero — e conversa diretamente com o princípio da necessidade da LGPD.

5.8. Resumo

- Testes verificam que o sistema **faz o que deve**; modelagem de ameaças verifica que ele **não faz o que não deve**. Falhas como referência direta insegura passam por qualquer suíte de aceitação e são triviais de antecipar em uma sessão de quadro branco.
- O método são quatro perguntas: o que estamos construindo, o que pode dar errado, o que faremos, e fizemos bem. As duas últimas são o que separa modelagem de conversa.
- No diagrama de fluxo de dados, o elemento decisivo é a **fronteira de confiança** — é onde as ameaças se concentram e onde o esforço de análise deve se concentrar.
- **STRIDE** é o complemento exato das propriedades dos capítulos anteriores: cada letra viola uma delas. Aplicado **por elemento**, converte-se numa lista finita de perguntas concretas.
- **Árvores de ataque** partem do objetivo do adversário e revelam o caminho mais barato — que é o que descreve o atacante real — e os controles que cortam vários ramos de uma vez. **Casos de abuso** convertem achados em critério de aceitação e teste automatizado.
- Cada ameaça termina em mitigar, eliminar, transferir ou aceitar, sempre com dono e prazo. Transferir move o custo financeiro, nunca a responsabilidade perante o titular dos dados.
- No Brasil, o art. 46, §2º da LGPD exige segurança desde a concepção, e o relatório de impacto do art. 38 é o modelo de ameaças formalizado — com o foco deslocado para o risco ao **titular**, o que torna o LINDDUN mais adequado que o STRIDE nesse documento. Para agentes de pequeno porte, a ANPD espera proporcionalidade: registro das decisões, não processo formal pesado.

6. Gestão de risco: análise qualitativa e quantitativa

A reunião tem quarenta minutos e três itens na pauta. O terceiro é a proposta de contratar um segundo link de trânsito, de outra operadora, entrando por rota física distinta: R\$ 4.800 por mês, R\$ 57.600 no ano.

O coordenador de rede é a favor: já houve dois rompimentos de fibra em dezoito meses, um deles de onze horas. O diretor financeiro é contra: é o equivalente a três salários, num ano em que a meta é cortar custo. O sócio pergunta se não dá para negociar um desconto com a operadora atual. A discussão dura vinte minutos, sobe de tom duas vezes, e termina com “vamos deixar para revisar no próximo trimestre” — que é como se registra, em ata, a decisão de aceitar o risco sem nunca ter dito que se estava aceitando um risco.

O que faltou ali não foi um argumento melhor. Faltou um número. Onze horas fora do ar custam quanto? Qual a chance de acontecer de novo no ano? Quanto dessa perda o segundo link elimina de fato? Nenhuma dessas perguntas exige precisão contábil — exigem apenas uma estimativa honesta, com sua incerteza explícita. Com elas na mesa, a conversa deixa de ser sobre quem fala mais alto e passa a ser sobre se R\$ 57.600 compram ou não mais do que custam.

Gestão de risco é o método que produz esses números e as decisões que decorrem deles. Este capítulo cobre o processo, as duas famílias de análise — qualitativa e quantitativa —, suas armadilhas, e como escolher entre elas.

6.1. O processo

As normas convergem para o mesmo ciclo. A ISO 31000 dá o arcabouço geral de gestão de risco (International Organization for Standardization, 2018b), a ISO/IEC 27005 o especializa para segurança da informação (International Organization for Standardization, 2022) e o NIST SP 800-30 detalha a etapa de avaliação (National Institute of Standards and Technology, 2012). A Figura 6.1 resume.

Vale insistir em duas etapas que a prática costuma pular.

A **etapa 1** define os critérios *antes* de olhar qualquer risco específico — escala de impacto, escala de probabilidade, e o **apetite a risco**: quanto a organização está disposta a tolerar. Definir isso depois é como escolher a régua depois de ver o resultado, e o efeito é previsível: os riscos que dão trabalho corrigir acabam classificados como aceitáveis.

A **etapa 4** é distinta da 3 e frequentemente fundida com ela. Analisar é estimar probabilidade e impacto; avaliar é **comparar com o critério** e decidir se está dentro ou fora do aceitável. Sem critério declarado, não há avaliação — há opinião com aparência de método.

6. Gestão de risco: análise qualitativa e quantitativa

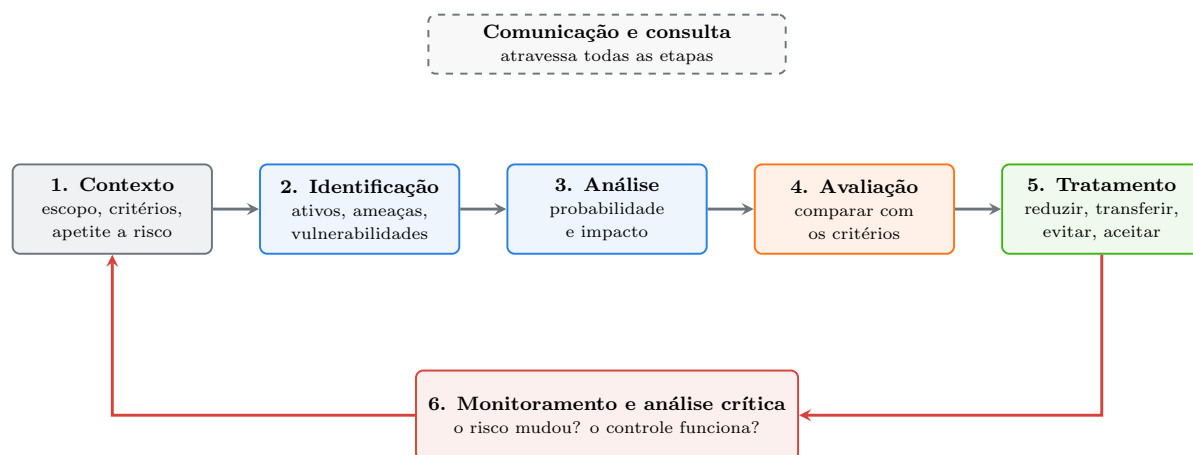


Figura 6.1.: O ciclo de gestão de risco. A sexta etapa é a que quase sempre falta: risco avaliado e nunca revisitado envelhece junto com o ambiente.

6.2. Análise qualitativa

A análise qualitativa classifica probabilidade e impacto em escalas ordinais e combina as duas numa matriz. É rápida, exige poucos dados e comunica bem — por isso domina a prática.

Também é onde mora a maior parte dos erros. E o principal deles não está na matriz: está nas escalas. Uma escala com rótulos vagos — “raro”, “possível”, “provável” — significa coisas diferentes para cada pessoa da sala. A correção é barata: **ancorar cada nível em número e em consequência concreta**.

Tabela 6.1.: Escalas ancoradas de probabilidade e impacto. Os valores são ilustrativos e devem ser calibrados ao porte de cada organização.

Nível	Probabilidade (ancorada)	Impacto (ancorado no contexto do provedor)
1 — Muito baixo	Menos de 1 vez em 10 anos	Até R\$ 5 mil; sem efeito perceptível ao assinante
2 — Baixo	Cerca de 1 vez em 5 anos	R\$ 5 mil a R\$ 30 mil; degradação localizada
3 — Médio	Cerca de 1 vez em 2 anos	R\$ 30 mil a R\$ 150 mil; parada de um serviço por horas
4 — Alto	Cerca de 1 vez por ano	R\$ 150 mil a R\$ 500 mil; parada geral por um dia, notificação à ANPD
5 — Muito alto	Mais de 1 vez por ano	Acima de R\$ 500 mil; risco de continuidade do negócio

Com as escalas ancoradas, a matriz de calor (Figura 6.2) vira instrumento de comunicação legítimo — um mapa que a direção lê em segundos.

6.2.1. As armadilhas da matriz

A matriz é útil e tem quatro problemas conhecidos que convém enfrentar de frente:

Multiplicar números ordinais. “Probabilidade 4 × impacto 3 = 12” trata rótulos de ordem como se fossem quantidades. Não são: o salto de 3 para 4 na escala de impacto da Tabela 6.1 é de R\$ 120 mil, e o de 4 para 5 é aberto e ilimitado. O produto é uma conveniência visual, não uma conta.

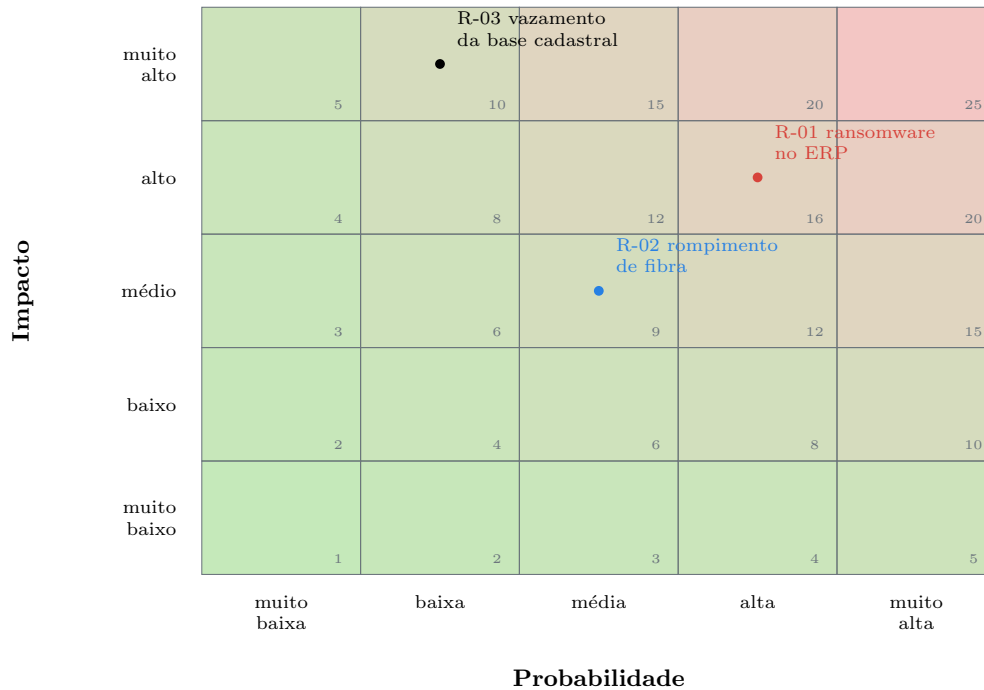


Figura 6.2.: Matriz de risco 5×5 com riscos posicionados. O número em cada célula é o produto dos índices — e é exatamente esse produto que exige cautela.

Nenhuma dessas críticas invalida a análise qualitativa. Elas definem seu uso correto: **triagem**. A matriz separa o que merece atenção do que não merece. Para o que sobe ao topo — e para toda decisão que envolve gastar dinheiro relevante — vale o esforço de quantificar.

6.3. Análise quantitativa

A análise quantitativa estima o risco em unidades monetárias. O vocabulário clássico tem quatro termos:

- **AV** (*asset value*) — valor do ativo.
- **EF** (*exposure factor*) — fração do valor perdida se o evento ocorrer.
- **SLE** (*single loss expectancy*) — perda esperada por ocorrência: $SLE = AV \times EF$.
- **ARO** (*annualized rate of occurrence*) — frequência anual esperada.
- **ALE** (*annualized loss expectancy*) — perda anual esperada: $ALE = SLE \times ARO$.

Aplicando ao caso de abertura. O provedor fatura R\$ 780 mil por mês. Um rompimento de fibra sem link redundante custa, por hora de parada, uma combinação de: crédito contratual e abatimento em fatura, chamados extras no suporte, cancelamentos atribuíveis nos trinta dias seguintes e horas extras da equipe de campo. A equipe estimou R\$ 3.900 por hora, e a duração média histórica em 6 horas.

$$SLE = 6 \text{ h} \times \text{R\$ } 3.900/\text{h} = \text{R\$ } 23.400$$

Com dois eventos em dezoito meses, $ARO \approx 1,33$ por ano:

$$ALE = \text{R\$ } 23.400 \times 1,33 \approx \text{R\$ } 31.100 \text{ por ano}$$

6. Gestão de risco: análise qualitativa e quantitativa

O segundo link não elimina a perda: rompimento continua havendo, mas a comutação leva minutos em vez de horas, e a parada residual foi estimada em 0,4 hora por evento — reduzindo a ALE para cerca de R\$ 2.100. O **retorno sobre o investimento em segurança** é então:

$$\text{ROSI} = \frac{(\text{ALE}_{\text{antes}} - \text{ALE}_{\text{depois}}) - \text{custo}}{\text{custo}} = \frac{(31.100 - 2.100) - 57.600}{57.600} \approx -0,50$$

O número é negativo. Pelo critério estrito de perda esperada, **o segundo link não se paga** — e essa conclusão, que contraria a intuição do coordenador de rede, é exatamente o tipo de resultado que justifica fazer a conta.

Mas a análise não termina aí, e é aqui que a maior parte das apresentações de gestão de risco erra. Três considerações mudam a decisão e precisam ir para a mesa junto com o número:

1. **A média esconde a cauda.** A conta usa 6 horas de duração média. Um rompimento em trecho de difícil acesso, num feriado, com equipe reduzida, é um evento de 30 horas — e a perda cresce mais que proporcionalmente, porque cancelamentos disparam a partir de certo limiar de paciência do assinante.
2. **Há benefício fora do cálculo.** Segundo link com operadora distinta protege também contra falha da operadora atual, permite manutenção programada sem janela noturna e é argumento comercial para contratos empresariais — receita nova que não entra na conta de perda evitada.
3. **O critério pode não ser o valor esperado.** Se uma parada longa ameaça contratos que representam parcela relevante da receita, a empresa pode racionalmente pagar acima do valor esperado para eliminar a cauda. É o mesmo raciocínio de comprar seguro, que tem valor esperado negativo por construção e ainda assim é decisão sensata.

A conclusão prática é que a quantificação **não substitui o julgamento** — ela o organiza. Com os números na mesa, a decisão passa a ser “estamos pagando R\$ 57,6 mil por ano para eliminar R\$ 29 mil de perda esperada e comprar proteção contra o cenário de cauda”, que é uma frase que a direção consegue aprovar ou recusar de forma consciente. Sem eles, decide-se por tom de voz.

6.4. Lidando com a incerteza: intervalos em vez de pontos

O ponto fraco de $\text{ALE} = \text{SLE} \times \text{ARO}$ é fingir precisão que não existe. “R\$ 3.900 por hora” é uma estimativa com incerteza grande, e o resultado herda essa incerteza sem mostrá-la.

A alternativa, defendida por Hubbard e Seiersen (Hubbard; Seiersen, 2016) e formalizada pelo método FAIR (Freund; Jones, 2014), é estimar **intervalos de confiança de 90%** em vez de valores únicos, e propagar a incerteza por simulação. Em vez de “custa R\$ 3.900 por hora”, a pergunta é: *qual intervalo você acredita, com 90% de confiança, que contém o custo horário real?* — digamos R\$ 1.800 a R\$ 9.000.

Sorteando milhares de cenários dentro desses intervalos, obtém-se não um número, mas uma distribuição de perda anual. Vinte linhas de Python bastam:

```
import numpy as np

rng = np.random.default_rng(42)
N = 100_000
```

```
# Intervalos de 90% de confiança, convertidos em lognormais.
# Para uma lognormal, o intervalo [lo, hi] de 90% implica:
def lognormal_90(lo, hi, n):
    mu = (np.log(lo) + np.log(hi)) / 2
    sigma = (np.log(hi) - np.log(lo)) / 3.29 # 3.29 = 2 x 1.645
    return rng.lognormal(mu, sigma, n)

custo_hora = lognormal_90(1_800, 9_000, N) # R$/hora de parada
duracao = lognormal_90(1.5, 30, N) # horas por evento
eventos = rng.poisson(1.33, N) # ocorrências no ano

perda_anual = eventos * custo_hora * duracao

for p in (50, 80, 90, 95, 99):
    print(f"P{p}: R$ {np.percentile(perda_anual, p):>12,.0f}")
print(f"média: R$ {perda_anual.mean():>10,.0f}")
print(f"P(perda > 57.600) = {(perda_anual > 57_600).mean():.1%}")
```

O resultado não é um número, é a **curva de excedência de perda** da Figura 6.3: para cada valor, a probabilidade de a perda anual superá-lo.

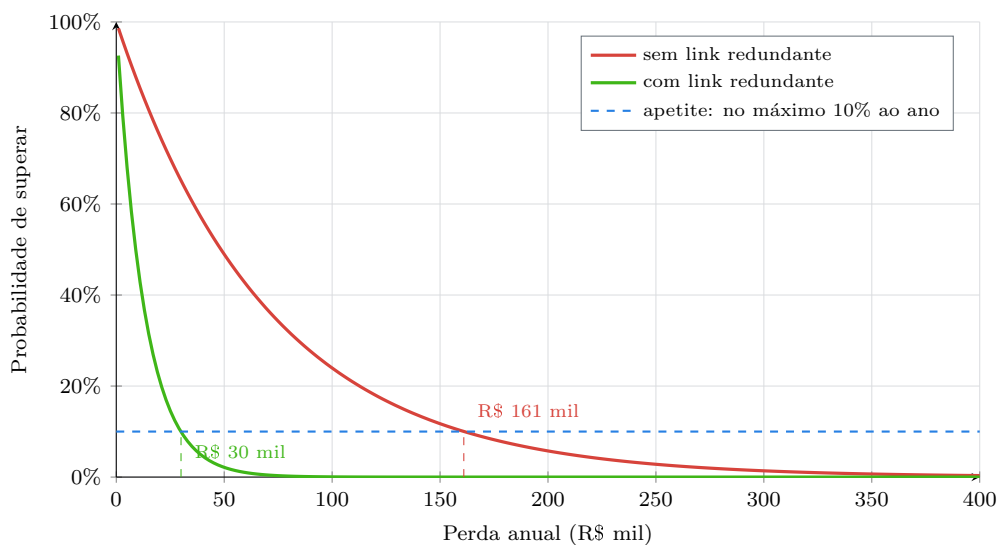


Figura 6.3.: Curva de excedência de perda. Onde a curva cruza a linha do apetite está a perda que se aceita ter 10% de chance de superar no ano.

A leitura é direta e é o que torna o método superior à matriz: com o link redundante, a perda que se tem 10% de chance de superar cai de R\$ 161 mil para R\$ 30 mil. A decisão deixa de ser sobre um valor esperado e passa a ser sobre **onde a cauda é cortada** — que é o que a diretoria de fato quer saber.

Uma objeção previsível: “não temos dados para isso”. A resposta é que o método não exige dados históricos, exige **estimativas calibradas** — e calibração é habilidade treinável. Pessoas treinadas para acertar 90% de suas faixas de 90% produzem intervalos honestos sobre grandezas que nunca mediram. E o ponto decisivo é comparativo: a alternativa não é uma estimativa melhor, é o palpite implícito de quem fala mais alto na reunião.

6.5. Escolher entre as duas

Tabela 6.2.: Quando usar cada abordagem.

Critério	Qualitativa	Quantitativa
Custo do exercício	Horas	Dias
Dado necessário	Julgamento de especialista	Julgamento calibrado, idealmente com histórico
Comparabilidade entre riscos	Frágil (escala ordinal)	Direta (mesma unidade monetária)
Suporta decisão de investimento	Mal	Bem (ROSI, curva de excedência)
Comunica à direção	Bem (mapa visual)	Muito bem (em reais)
Risco de falsa precisão	Baixo	Alto se a incerteza não for mostrada

Na prática, a combinação vence: **qualitativa para triar todo o inventário de riscos, quantitativa para os dez ou quinze do topo** e para toda decisão que envolva gasto relevante. É a proporção que respeita o custo do método.

6.6. Tratamento e risco residual

Analisado e avaliado o risco, restam quatro opções — as mesmas do Capítulo 5, agora com o número que as sustenta:

Reduzir. Implantar controle que diminua probabilidade ou impacto. É a escolha padrão. O critério de aceitação é a comparação entre custo do controle e redução de ALE, temperada pela análise da cauda.

Transferir. Seguro cibernético, cláusula contratual, terceirização para fornecedor especializado. Três ressalvas importam: apólices excluem o que a empresa deixou de fazer (ausência de segundo fator e de correção em dia são exclusões comuns); a indenização cobre prejuízo financeiro, não a obrigação perante a ANPD nem a confiança do assinante; e transferir exige demonstrar controles para conseguir preço razoável — o seguro pressupõe higiene, não a substitui.

Evitar. Não fazer, ou parar de fazer, a atividade que gera o risco. Desativar a funcionalidade pouco usada, não coletar o dado que não é necessário, encerrar a integração legada. É a opção mais subestimada e a única com eficácia integral.

Aceitar. Conviver conscientemente. Só é aceitação legítima se: estiver **registrada**, com o número que a justifica; for decidida por **quem tem autoridade** para comprometer a organização naquele valor; e tiver **data de revisão**. Aceitação sem esses três elementos é omissão com outro nome.

O que sobra depois do tratamento é o **risco residual** — e o produto final de todo o processo é uma lista curta de riscos residuais que a direção conhece e aceitou formalmente. Um programa de segurança maduro não se distingue por ter menos risco, mas por saber qual risco tem.

6.6.1. O registro de risco

O artefato que sustenta tudo isso cabe numa planilha. Dez colunas: identificador, descrição do cenário (ativo + ameaça + vulnerabilidade + consequência), impacto estimado, probabilidade estimada, risco inerente, controles existentes, risco residual, decisão de tratamento, dono, data de revisão.

Duas regras que decidem se o registro vive ou morre: descrever o **cenário completo**, não o rótulo — “ransomware” não é risco, “cifragem do banco do ERP por acesso via VPN sem segundo fator, com parada de faturamento por seis dias” é; e **cada linha tem um dono nomeado**, porque risco de todos é risco de ninguém.

6.6.2. Indicadores que antecipam

Monitoramento (etapa 6) não é reler a planilha em dezembro. São indicadores que se movem antes do incidente: percentual de servidores com correção crítica pendente há mais de 30 dias, contas privilegiadas sem segundo fator, restaurações de backup testadas no trimestre, tempo médio até detecção, serviços administrativos alcançáveis da internet. Cada um deles tem um limite que, ultrapassado, dispara reavaliação do risco correspondente — e essa é a diferença entre gestão de risco e documentação de risco.

6.7. Brasil em Foco

A gestão de risco é a espinha dorsal do modelo brasileiro de conformidade em proteção de dados, e entender isso muda a forma de investir.

A **LGPD** não traz lista fechada de controles obrigatórios. O art. 46 exige medidas “aptas a proteger” os dados, considerando o estado da técnica, a natureza da informação e os riscos; o art. 50 fala em regras de boas práticas que levem em conta “a natureza, o escopo, a finalidade, a probabilidade e a gravidade dos riscos”; o art. 38 prevê o relatório de impacto (Brasil, 2018). É um regime **baseado em risco**: a conformidade se demonstra pelo processo — inventário, avaliação, decisão registrada, revisão — e não pela posse de determinados produtos. Uma empresa com firewall de última geração e nenhum registro de avaliação de risco está em posição pior, diante da ANPD, que outra com controles modestos e um registro de risco bem mantido.

O art. 52, §1º da LGPD fixa os critérios de dosimetria das sanções, entre os quais figuram a **adoção de política de boas práticas e governança**, as **medidas adotadas para reverter ou mitigar** os efeitos do incidente e a **pronta adoção de medidas corretivas** — todos elementos que só existem se houver processo prévio. Na prática, o registro de risco é peça de defesa administrativa.

Para **agentes de pequeno porte**, a Resolução CD/ANPD nº 2/2022 e o guia orientativo da autoridade estabelecem tratamento proporcional (Autoridade Nacional de Proteção de Dados, 2023). A ANPD não espera de um provedor com quarenta funcionários o processo de uma instituição financeira — espera evidência de que os riscos foram identificados e as decisões tomadas de forma consciente. Uma planilha de dez linhas revisada semestralmente atende.

No **setor financeiro e de pagamentos**, a exigência é explícita e mais rígida: a Resolução CMN nº 4.893/2021 obriga política de segurança cibernética com avaliação de riscos, classificação de dados por relevância, controles proporcionais, plano de resposta a incidentes, testes e relatório anual submetido à alta administração — além de gestão de risco sobre serviços relevantes de terceiros (Banco Central do Brasil, 2021). Para telecomunicações, a Resolução Anatel nº 740/2020

6. Gestão de risco: análise qualitativa e quantitativa

exige tratamento de vulnerabilidades em produtos, o que pressupõe avaliação de criticidade (Agência Nacional de Telecomunicações, 2020).

Do lado das normas técnicas, as versões brasileiras estão disponíveis pela ABNT: a **NBR ISO 31000** para o arcabouço de gestão de risco e a **NBR ISO/IEC 27005** para a aplicação à segurança da informação. Adotar a terminologia dessas normas no registro de risco tem valor prático em auditoria e em processo administrativo: usa o vocabulário que o auditor e o regulador esperam.

Sobre **seguro cibernético**, o mercado brasileiro é regulado pela SUSEP e vem crescendo, com apólices que costumam cobrir custo de resposta, perícia, notificação a titulares e defesa administrativa. Duas cautelas: multa administrativa da ANPD tem cobertura limitada ou vedada em várias apólices, e o questionário de contratação funciona como auditoria — declarar controles que não existem compromete o pagamento do sinistro.

6.8. No Campo

1. Escrever os critérios antes de olhar o primeiro risco. Uma página: escala de impacto ancorada em reais e em consequência operacional, escala de probabilidade ancorada em frequência, e a linha do apetite (“não aceitamos risco com mais de 10% de chance de perda anual superior a R\$ 50 mil”). Aprovada pela direção, ela resolve antecipadamente metade das discussões.

2. Levantar dez riscos, não cem. Uma sessão de duas horas com a equipe técnica e alguém do negócio produz os dez cenários que importam. Descrever cada um como cenário completo. Os cem virão depois, se vierem.

3. Estimar o custo da hora parada — o número que falta em quase toda empresa. Ele destrava todas as demais contas:

```
# Insumos para a estimativa, a partir do que já se mede
# 1. Receita por hora
echo "scale=2; 780000 / (30*24)" | bc          # faturamento mensal / horas do mês

# 2. Histórico real de indisponibilidade dos últimos 12 meses
journalctl --list-boots | wc -l
last -x shutdown reboot | head -30

# 3. Volume de chamados por evento de parada (correlacionar com a data)
grep -c "" /var/log/suporte/chamados-2026-*.csv
```

Some receita não faturada, crédito contratual, horas extras, chamados extras e cancelamentos atribuíveis nos trinta dias seguintes. O resultado não precisa ser exato; precisa ser defensável.

4. Quantificar os três do topo, não todos. Para cada um: intervalo de 90% para o custo do evento, intervalo para a frequência, e a simulação de vinte linhas mostrada acima. O resultado em uma frase — “temos 10% de chance de perder mais de R\$ X este ano com este cenário” — é o que a direção compra ou recusa.

5. Levar decisões, não relatórios. A pauta certa tem três colunas: risco, opção recomendada com custo, e o que acontece se não fizermos nada. Uma página, três riscos. Relatório de quarenta páginas não é lido e não gera decisão.

6. Registrar a aceitação por escrito. Quando a decisão for aceitar — e será, com frequência —, uma linha na ata com o valor em risco, quem aceitou e a data de revisão. É proteção do técnico que alertou, é insumo de defesa administrativa, e é o que faz o assunto voltar à pauta antes de voltar como incidente.

7. Acompanhar cinco indicadores, e só cinco. Correções críticas pendentes há mais de 30 dias; contas privilegiadas sem segundo fator; restaurações testadas no trimestre; serviços administrativos alcançáveis da internet; tempo médio até detecção. Painel mensal, cada um com um limite que dispara reavaliação. Mais que cinco vira relatório que ninguém lê.

6.9. Resumo

- O ciclo é **contexto** → **identificação** → **análise** → **avaliação** → **tratamento** → **monitoramento**, com comunicação atravessando tudo. As etapas mais puladas são a primeira (definir critérios e apetite *antes*) e a última (revisitar).
- Na análise **qualitativa**, o erro não está na matriz e sim nas escalas: níveis com rótulos vagos significam coisas diferentes para cada pessoa. Ancorar cada nível em faixa numérica e consequência concreta é a correção mais barata que existe.
- A matriz sofre de multiplicação de ordinais, compressão da cauda, inversão de ordenação e vieses de estimativa. Isso a torna instrumento de **triagem**, não de decisão de investimento.
- A análise **quantitativa** usa $SLE = AV \times EF$ e $ALE = SLE \times ARO$, e o ROSI compara redução de perda esperada com custo do controle. O resultado pode contrariar a intuição — e é para isso que serve.
- Valor esperado esconde a cauda. Estimar **intervalos de 90%** e simular produz a **curva de excedência de perda**, que responde à pergunta que a direção realmente faz: quanto podemos perder no pior ano plausível, e quanto o controle corta disso.
- O tratamento é reduzir, transferir, evitar ou aceitar. Seguro transfere prejuízo financeiro, nunca a responsabilidade perante o titular; **evitar** é a opção mais subestimada; e aceitação só é legítima se registrada, decidida por quem tem autoridade e com data de revisão.
- No Brasil o regime é **baseado em risco**: a LGPD (arts. 38, 46, 50 e 52) demonstra conformidade pelo processo, não pela posse de produtos — e o registro de risco é peça de defesa administrativa. Setor financeiro (Res. CMN 4.893/2021) e telecomunicações (Res. Anatel 740/2020) acrescentam exigências específicas.

7. Ética, legalidade e a fronteira do escopo autorizado

Um técnico de suporte de um provedor está resolvendo um chamado de lentidão. No caminho, abre o portal de um provedor vizinho para comparar como eles apresentam o teste de velocidade. Nota que a URL da área do cliente termina em `?id=1042`. Por hábito profissional — o mesmo hábito que o Capítulo 5 elogia —, troca para 1041. Abre a página de outra pessoa: nome, CPF, plano, endereço de instalação.

O que ele faz nos próximos minutos define de que lado de uma linha ele está. Se fechar a aba e escrever um e-mail ao contato de abuso do provedor vizinho descrevendo o que viu, é um profissional agindo com responsabilidade. Se testar mais dez identificadores para “confirmar a extensão do problema”, já acessou dados de dez pessoas sem autorização. Se baixar a listagem para “provar” o achado, exfiltrou base de dados pessoais de terceiro. Se publicar no grupo de WhatsApp do setor, divulgou vulnerabilidade não corrigida de um concorrente.

A intenção é a mesma nos quatro casos. As consequências jurídicas não são.

Este é o capítulo mais importante do volume para quem pretende trabalhar com segurança, e é o que fecha a Fase 1. Os seis anteriores ensinaram a pensar como quem ataca para defender melhor. Este trata da fronteira que torna esse conhecimento legítimo: **a autorização**.

7.1. A linha é jurídica, não técnica

A confusão mais comum e mais cara na área é achar que a fronteira do lícito é definida pela dificuldade técnica ou pela intenção. Não é. É definida pela **autorização**, e a lei brasileira é explícita.

O art. 154-A do Código Penal, inserido pela Lei 12.737/2012 e agravado pela Lei 14.155/2021, tipifica:

Invadir dispositivo informático de uso alheio, conectado ou não à rede de computadores, com o fim de obter, adulterar ou destruir dados ou informações sem autorização expressa ou tácita do titular do dispositivo ou instalar vulnerabilidades para obter vantagem ilícita.

Três palavras merecem atenção. “**Invadir**” não exige violência, ferramenta sofisticada ou quebra de senha: trocar um número numa URL para acessar o que não é seu é acesso não autorizado. “**Sem autorização**” é o núcleo do tipo — a mesma ação, autorizada, é serviço profissional. E “**de uso alheio**” delimita: o dispositivo do próprio agente, ou aquele que ele foi contratado para testar, está fora.

O que a lei **não** exige também importa: não exige dano, não exige lucro, não exige que os dados sejam usados. A consumação se dá com o acesso.

Daí a regra prática deste manual, que vale para toda a carreira:

7. Ética, legalidade e a fronteira do escopo autorizado

Se você não tem autorização por escrito de quem pode dá-la, não toque. “Só olhei” é acesso. “Não usei nada” é irrelevante. “Foi para ajudar” é atenuante, não excludente.

7.2. O mapa legal brasileiro

O art. 154-A não está sozinho. A Tabela 7.1 reúne os dispositivos que alcançam atividade técnica em segurança da informação — e a coluna da direita é a que mais interessa, porque descreve o que transforma cada conduta em lícita.

Tabela 7.1.: Mapa das condutas técnicas e do que as torna lícitas no direito brasileiro.

Conduta	Enquadramento típico	O que a torna lícita
Acessar sistema de terceiro sem permissão	CP, art. 154-A (invasão de dispositivo informático)	Autorização expressa do titular, por escrito
Interromper serviço de telecomunicações ou de informação de utilidade pública	CP, art. 266, §1º	Janela de manutenção acordada; teste de carga contratado
Interceptar comunicação alheia	Lei 9.296/1996, art. 10	Ordem judicial; ou ser parte da comunicação; ou rede própria com aviso prévio (Brasil, 1996)
Fraude por meio eletrônico	CP, art. 171, §2º-A (estelionato)	Nada a torna lícita
Furto mediante dispositivo eletrônico	CP, art. 155, §4º-B	Nada a torna lícita
Inserir dados falsos em sistema da administração pública	CP, arts. 313-A e 313-B	Nada a torna lícita
Tratar dados pessoais de terceiros sem base legal	LGPD, arts. 7º e 42 (responsabilidade civil e sanção administrativa)	Base legal do art. 7º e finalidade legítima
Divulgar vulnerabilidade não corrigida de terceiro	Sem tipo penal próprio; risco civil e possível concurso com 154-A	Divulgação coordenada, com prazo e consentimento

Quatro observações completam o quadro.

As penas foram agravadas em 2021. A Lei 14.155/2021 elevou a pena do art. 154-A para reclusão de 1 a 4 anos e multa, com aumento se houver obtenção de conteúdo de comunicações privadas, segredos comerciais ou controle remoto do dispositivo — e majorantes adicionais quando praticado contra idoso ou vulnerável (Brasil, 2021). O estelionato eletrônico do art. 171, §2º-A tem reclusão de 4 a 8 anos.

A ação penal. O art. 154-B condiciona a persecução, em regra, a representação da vítima — procede-se mediante ação penal pública incondicionada apenas quando o crime é cometido contra a administração pública ou empresas concessionárias de serviços públicos. Isso significa que o provedor vizinho do caso de abertura decide se representa ou não; não significa que a conduta deixe de ser crime.

A LGPD age em paralelo. Acessar dados pessoais de terceiro sem base legal é tratamento irregular, com responsabilidade civil (art. 42) e sanção administrativa (art. 52) independentes da esfera penal. Quem “só olhou” a fatura de outro assinante tratou dado pessoal sem base legal.

A Convenção de Budapeste está em vigor no Brasil. O Decreto nº 11.491/2023 promulgou a Convenção sobre o Crime Cibernético (Brasil, 2023), que facilita a cooperação internacional e a preservação expedita de dados. O efeito prático é direto: a fronteira nacional deixou de ser obstáculo relevante à investigação, e o argumento de que “o servidor está fora do Brasil” não protege ninguém.

7.3. Autorização: como ela é feita de verdade

Autorização não é uma mensagem dizendo “pode testar”. É um documento, e faltando qualquer dos elementos abaixo, a proteção que ele oferece é parcial:

Tabela 7.2.: Elementos mínimos de uma autorização de teste.

Elemento	Por que é indispensável
Identificação das partes	Quem autoriza e quem executa, com CNPJ/CPF
Escopo positivo	Lista exata de domínios, faixas de IP, aplicações, contas de teste
Escopo negativo	O que está explicitamente fora — sistemas de terceiros, produção crítica, dados reais
Janela temporal	Data e hora de início e fim; fora dela não há autorização
Técnicas permitidas e proibidas	Negação de serviço, engenharia social contra funcionários, exploração destrutiva
Tratamento de dados encontrados	Que se faz ao encontrar dado pessoal: não copiar, registrar apenas evidência mínima, apagar ao fim
Contato de emergência	Quem atender às 3h se algo cair; e o gatilho para parar imediatamente
Sigilo e destinação do relatório	Quem recebe, por quanto tempo se guarda, como se destrói
Assinatura de quem tem poderes	Sócio, diretor ou procurador — não o gerente de TI que “aprovou por e-mail”

Dois pontos que causam problema com frequência.

Quem assina. A autorização precisa vir de quem pode comprometer a pessoa jurídica. O analista de TI que contrata o teste sem procuração não tem poder para autorizar acesso a dados de clientes da empresa. Verificar o contrato social ou a procuração é parte do trabalho, não formalidade.

Escopo com ativo de terceiro. Se o alvo está hospedado em nuvem ou em datacenter de terceiro, a autorização do cliente **não alcança** a infraestrutura do provedor. Os grandes provedores de nuvem publicam políticas de teste que permitem certas atividades sem aviso prévio e proíbem outras — notadamente teste de negação de serviço. Testar fora dessas políticas viola o contrato do cliente com o provedor e pode configurar acesso não autorizado a sistema do provedor.

7. Ética, legalidade e a fronteira do escopo autorizado

A Figura 7.1 condensa a decisão numa sequência que cabe na cabeça.

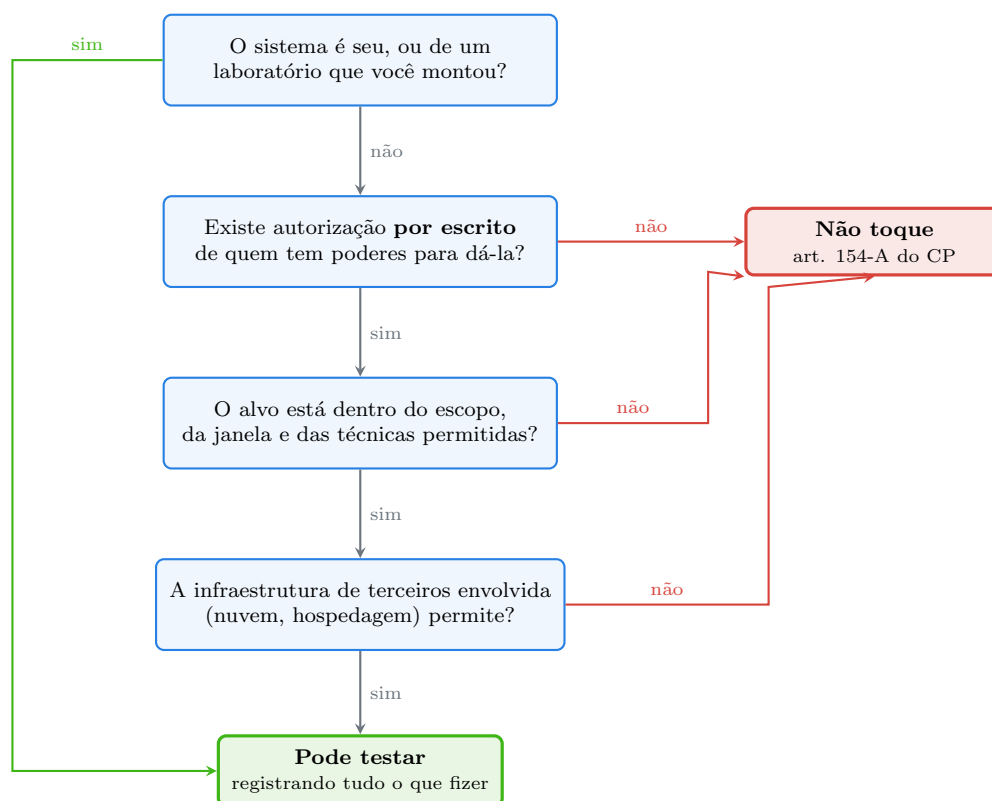


Figura 7.1.: A decisão de testar. Qualquer “não” nas três últimas perguntas leva ao mesmo lugar.

7.4. Divulgação de vulnerabilidade

Encontrada uma falha em sistema de terceiro — por acidente, como no caso de abertura, ou em pesquisa —, existe um caminho estabelecido. As normas ISO/IEC 29147 (divulgação) e 30111 (tratamento interno) descrevem o processo de ambos os lados (International Organization for Standardization, 2018c, 2019), e a Figura 7.2 mostra a linha do tempo típica.

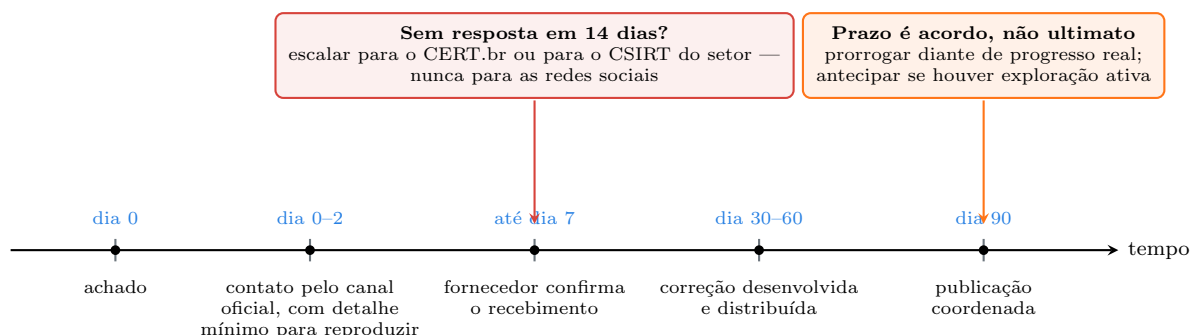


Figura 7.2.: Divulgação coordenada. O prazo de 90 dias é convenção de mercado, não regra jurídica.

Três posturas coexistem no mercado, e vale entender o argumento de cada uma. A **divulgação completa** publica tudo imediatamente, sob o argumento de que só a pressão pública faz fornecedores corrigirem e que defensores precisam da informação para se proteger. A **não divulgação**

nunca publica, e na prática protege o fornecedor às custas dos usuários. A **divulgação coordenada** — o padrão hoje — dá ao fornecedor um prazo razoável para corrigir e então publica, com ou sem correção pronta.

Cuidados que evitam transformar um ato de responsabilidade em problema:

- **Não teste além do mínimo.** Um caso comprova a falha. Dez casos “para confirmar a extensão” é acesso repetido não autorizado, e o relatório não fica melhor por isso.
- **Não copie dados.** Registre a evidência mínima — a URL, o código de resposta, uma captura com os dados tarjados. Baixar a base transforma o achado em exfiltração.
- **Documente o que fez, quando e como.** Se houver questionamento, a diferença entre pesquisador e invasor está nesse registro.
- **Use o canal oficial.** Procure `/.well-known/security.txt` no domínio, a página de contato de segurança, ou o contato de abuso no WHOIS do bloco. Não havendo canal, o CERT.br atua como intermediário.
- **Não peça pagamento.** Comunicar uma falha e sugerir que o silêncio tem preço é extorsão (CP, art. 158), independentemente de como a mensagem for redigida.

Uma nota importante sobre o Brasil: **não existe salvaguarda legal explícita para pesquisa de segurança**. Diferentemente da política do Departamento de Justiça norte-americano de 2022, que orienta não processar pesquisa de boa-fé, aqui a proteção do pesquisador depende de programas privados de recompensa com termos de porto seguro, ou da decisão da vítima de não representar. Reportar de boa-fé é o comportamento correto e ainda assim carrega risco jurídico residual. Quem pesquisa deve conhecer esse risco, minimizá-lo (não ir além do mínimo, documentar, usar canal oficial) e, em achados sensíveis, considerar orientação jurídica antes de fazer contato.

7.5. Bug bounty e programas de recompensa

Programas de recompensa resolvem juridicamente o problema: os termos publicados **são** a autorização, com escopo, técnicas permitidas e, nos bons programas, cláusula de porto seguro comprometendo a empresa a não acionar judicialmente quem cumprir as regras.

Três cuidados práticos: os termos são o limite exato — subdomínio fora da lista está fora, e “achei que estava incluído” não é defesa; testar um alvo do programa hospedado em nuvem ainda exige respeitar as políticas do provedor; e recompensa não é vínculo de trabalho, o que tem implicações fiscais para quem recebe com regularidade.

7.6. Ética profissional além da lei

A lei define o mínimo. A profissão exige mais, e três situações concentram os dilemas reais.

O poder do administrador. Quem administra sistemas pode ler o e-mail de qualquer pessoa da empresa, ver o histórico de navegação, acessar arquivos pessoais em pasta de rede. O acesso é tecnicamente possível e frequentemente autorizado *para fins específicos*. O uso além desses fins — a curiosidade sobre a conversa da colega, o interesse pelo salário do outro setor — é abuso, ainda que nenhum controle o impeça. A régua é simples: *este acesso é necessário para a tarefa que estou executando agora, e eu o registraria sem constrangimento?*

Monitoramento de funcionários. É lícito no Brasil quando há finalidade legítima, comunicação prévia e clara aos empregados, proporcionalidade e limite ao ambiente de trabalho. Não é lícito

7. Ética, legalidade e a fronteira do escopo autorizado

monitorar comunicação pessoal sem ciência, instalar captura de teclas de forma oculta ou vasculhar o dispositivo pessoal de alguém. A LGPD se aplica integralmente à relação de emprego, e a base legal costuma ser o legítimo interesse — que exige teste de proporcionalidade documentado, e não sobrevive a monitoramento excessivo.

O achado incidental. Durante um trabalho autorizado, encontra-se algo fora do escopo: indício de fraude interna, dados de outro cliente misturados, material manifestamente ilegal. A conduta correta é parar, não explorar, registrar o mínimo e comunicar imediatamente o contato definido no contrato. Diante de material de abuso infantil, a comunicação às autoridades é dever, e a preservação da evidência deve seguir orientação jurídica — não se copia, não se apaga, não se investiga por conta própria.

Os códigos de ética profissional da área — o da ISC2 é o mais citado — convergem em quatro deveres: proteger a sociedade e a infraestrutura; agir com honestidade e legalidade; prestar serviço diligente e competente; e promover a profissão (ISC2, 2024). O primeiro dever, quando conflita com os interesses de um cliente específico, prevalece: é ele que sustenta a recusa em ocultar um incidente que afeta terceiros.

7.7. Onde praticar sem risco

Aprender segurança ofensiva exige praticar. O caminho legítimo é abundante e gratuito:

- **Laboratório próprio.** Máquinas virtuais na sua máquina, rede isolada, alvos deliberadamente vulneráveis (DVWA, Metasploitable, Juice Shop, VulnHub). É o Volume 2 que monta esse ambiente.
- **Plataformas de treino.** Hack The Box, TryHackMe, PortSwigger Web Security Academy, PicoCTF. A autorização está nos termos de uso.
- **Competições CTF.** Autorização explícita, alvos preparados, comunidade ativa no Brasil.
- **Programas de recompensa,** respeitando o escopo.

E, para não errar em documentação, exemplos e testes, use os identificadores reservados: `example.com`, `example.org`, e as faixas de endereços de documentação 192.0.2.0/24, 198.51.100.0/24 e 203.0.113.0/24 (RFC 5737). Todo endereço IP que aparece neste manual vem dessas faixas, por isso mesmo.

7.8. Brasil em Foco

O capítulo inteiro é direito brasileiro; esta seção fixa o que muda no dia a dia de quem opera infraestrutura no país.

Provedor tem obrigações que se cruzam com a ética. O Marco Civil impõe guarda de registros (arts. 13 e 15) e, simultaneamente, sigilo (arts. 10 e 11): os dados só podem ser disponibilizados mediante ordem judicial, que precisa conter indícios do ilícito, identificação clara do usuário e período determinado (Brasil, 2014). Entregar registro a quem pede sem ordem — inclusive a delegado, a advogado ou ao “outro provedor que também foi atacado” — é violação de sigilo, com responsabilização civil e administrativa. A conduta correta é exigir a ordem, verificar sua abrangência e responder exatamente o que foi requisitado, nem mais.

Interceptação é linha vermelha. Capturar tráfego de assinante além do necessário para operação técnica esbarra na Lei 9.296/1996, cujo art. 10 tipifica a interceptação sem autorização

judicial (Brasil, 1996). Coleta de metadados de fluxo para engenharia de tráfego é operação legítima; inspeção de conteúdo é outra coisa, e exige base jurídica sólida.

A LGPD alcança o profissional, não só a empresa. O art. 42 estabelece a responsabilidade do controlador e do operador pelos danos causados; o art. 52 lista as sanções administrativas. Um prestador de serviço que trata dados do cliente é operador e responde nessa qualidade — o que torna o contrato de prestação, com cláusulas de finalidade, sigilo e devolução ou eliminação dos dados ao fim, instrumento de proteção do próprio prestador.

Sem porto seguro legal para o pesquisador. Vale repetir por ser a diferença mais relevante em relação a outros ordenamentos: no Brasil, quem reporta de boa-fé depende da representação da vítima e dos termos de programas privados. Não existe, hoje, dispositivo que exclua a tipicidade da conduta do pesquisador. O **CERT.br** é o intermediário estabelecido para notificar quem não tem canal — o que reduz o risco de o contato direto ser lido como ameaça.

A Convenção de Budapeste mudou a cooperação. Com o Decreto nº 11.491/2023, pedidos de preservação expedita e de cooperação internacional passaram a ter rito próprio (Brasil, 2023). Para provedores, isso significa maior volume de requisições e a necessidade de um procedimento interno definido para atendê-las corretamente — o Volume 15 detalha as obrigações regulatórias.

7.9. No Campo

1. Publicar um security.txt. Cinco minutos de trabalho que dão a quem encontrar uma falha no seu sistema um caminho responsável para avisar — e evitam que o achado vire postagem pública. Fica em `/.well-known/security.txt`:

```
Contact: mailto:seguranca@provedor.exemplo.br
Contact: https://provedor.exemplo.br/seguranca
Expires: 2027-12-31T23:59:00.000Z
Preferred-Languages: pt-BR, en
Policy: https://provedor.exemplo.br/politica-de-divulgacao
Acknowledgments: https://provedor.exemplo.br/agradecimentos
```

2. Manter o contato de abuso do bloco atualizado. É por ali que o CERT.br e outros operadores avisam sobre máquinas comprometidas na sua rede. Contato desatualizado significa não saber que seus clientes estão participando de um ataque:

```
# Contato de abuso registrado para o seu ASN e para o seu bloco
whois -h whois.registro.br AS64500 | grep -iE 'abuse|owner|responsible'
whois -h whois.registro.br 198.51.100.0/24 | grep -iE 'abuse|nserver'
```

3. Escrever a política de divulgação antes de precisar dela. Uma página: como reportar, o que a empresa se compromete a fazer (confirmar em X dias úteis, corrigir em Y), o que espera de quem reporta (não acessar dados além do mínimo, não divulgar antes do prazo), e a declaração de que não acionará judicialmente quem seguir as regras. Custa uma tarde e muda inteiramente o desfecho do dia em que alguém encontrar algo.

4. Formalizar a autorização, sempre — inclusive internamente. Vale para o teste contratado de terceiro e para a varredura da própria rede. Um documento de uma página com os elementos da Tabela 7.2, assinado por quem tem poderes, arquivado. A varredura do próprio bloco autorizada por escrito protege o técnico se o tráfego for questionado.

7. Ética, legalidade e a fronteira do escopo autorizado

5. Registrar o uso do acesso privilegiado. Quem administra pode tudo; o registro é o que separa poder de abuso. Sessão gravada ou ao menos registrada, revisão periódica por alguém que não seja o próprio administrador:

```
# Comandos executados com privilégio, por pessoa, nos últimos 7 dias
journalctl _COMM=sudo --since "7 days ago" -o cat \
  | grep -oP 'USER=\S+.*COMMAND=.*' | sort | uniq -c | sort -rn | head -20

# Acessos a arquivos sensíveis via auditd (regra prévia necessária)
auditctl -w /var/lib/erp/dados -p rwa -k dados-assinantes
ausearch -k dados-assinantes --start recent | head -40
```

6. Colocar as cláusulas certas no contrato de terceirizado. Quem presta suporte, quem administra a rede sob contrato, quem desenvolve o portal: finalidade do acesso, dever de sigilo que sobrevive ao fim do contrato, proibição de subcontratar sem anuência, obrigação de comunicar incidente em prazo curto, devolução ou eliminação dos dados ao término, e direito de auditoria. É o mesmo conjunto que a LGPD espera na relação controlador–operador.

7. Comunicar o monitoramento aos empregados. Política de uso aceitável assinada, com o que é monitorado, por quê e por quanto tempo se guarda. Monitoramento comunicado é lícito e eficaz; monitoramento oculto é risco trabalhista, risco sob a LGPD e destruição de confiança de uma vez só.

8. Treinar a resposta ao “encontrei uma falha em vocês”. Quem recebe a mensagem no suporte precisa saber que não deve responder com ameaça, não deve ignorar, e deve encaminhar imediatamente para o responsável definido. A reação hostil ao primeiro contato é o que transforma um aviso gratuito numa divulgação pública.

7.10. Resumo

- A fronteira do lícito é a **autorização**, não a dificuldade técnica nem a intenção. O art. 154-A do Código Penal não exige dano, lucro ou uso dos dados: consuma-se com o acesso não autorizado. Trocar um número numa URL é acesso.
- As penas foram **agravadas pela Lei 14.155/2021**, e o estelionato eletrônico (CP, art. 171, §2º-A) tem reclusão de 4 a 8 anos. Além da esfera penal, a LGPD gera responsabilidade civil e sanção administrativa autônomas.
- Autorização é **documento**, com escopo positivo e negativo, janela temporal, técnicas permitidas, tratamento de dados encontrados, contato de emergência e assinatura de quem tem poderes. Autorização do cliente não alcança a infraestrutura de terceiros que hospeda o alvo.
- Na **divulgação coordenada**, o essencial é não testar além do mínimo, não copiar dados, documentar tudo, usar o canal oficial e jamais condicionar o silêncio a pagamento — o que seria extorsão.
- O **Brasil não tem salvaguarda legal para pesquisa de boa-fé**. A proteção vem de programas privados com porto seguro ou da decisão da vítima de não representar. O CERT.br é o intermediário estabelecido quando não há canal de contato.
- A ética profissional vai além da lei em três frentes recorrentes: o **poder do administrador** (acesso possível não é acesso legítimo), o **monitoramento de empregados** (lícito com finalidade, comunicação prévia e proporcionalidade) e o **achado incidental** (parar, não explorar, comunicar).

- Praticar é obrigatório e há caminho legítimo abundante: laboratório próprio, plataformas de treino, competições e programas de recompensa — mais as faixas de documentação da RFC 5737 para exemplos.

Parte II.

**Volume 2 — Redes e Sistemas: a Base
Técnica**

8. A pilha TCP/IP sob a ótica do atacante e do defensor

Numa terça-feira de manhã, o setor financeiro de uma empresa cliente de um provedor regional começa a reclamar de avisos de certificado inválido ao acessar o internet banking. O navegador diz que a identidade do site não pôde ser verificada. O suporte de primeiro nível manda limpar o cache, trocar de navegador, reiniciar o computador. Nada resolve, e o problema atinge somente as máquinas daquele andar.

O técnico de rede sobe, conecta o notebook na mesma VLAN e captura trinta segundos de tráfego. O que ele vê não tem nada de sofisticado: um mesmo endereço MAC respondendo a consultas ARP para dois endereços IP diferentes — o do gateway e o do servidor de arquivos. Alguém plugou um dispositivo na rede e o colocou entre todas as máquinas do andar e o resto do mundo. O aviso de certificado não era falha do banco: era o único sinal visível de um ataque que já durava dias.

O que torna esse ataque possível não é uma vulnerabilidade de software. É uma decisão de projeto tomada nos anos 1970: o protocolo ARP acredita em qualquer resposta que receba. A pilha TCP/IP inteira foi desenhada para funcionar entre pares que confiavam uns nos outros, e a segurança foi acrescentada depois, camada por camada, remendo por remendo. Entender **onde** a confiança foi presumida é entender onde os ataques moram — e onde as defesas precisam ser instaladas.

Este é o primeiro capítulo do Volume 2, que constrói a base técnica sobre a qual o resto do manual se apoia. O Capítulo 4 e o Capítulo 5 ensinaram a enxergar ativos e ameaças de forma abstrata. Aqui a abstração encosta no fio.

8.1. Duas pilhas, um vocabulário

A literatura usa dois modelos de camadas, e a confusão entre eles atrapalha conversas técnicas todo dia. O **modelo OSI**, de sete camadas, é referência conceitual e nomenclatura: quando alguém diz “problema de camada 2” ou “firewall de camada 7”, está falando OSI. O **modelo TCP/IP**, de quatro camadas, é o que a internet realmente implementa (Kurose; Ross, 2021).

A Figura 8.1 mostra os dois lado a lado, com o que trafega em cada nível e a unidade de dados correspondente.

Vale guardar a correspondência, porque quase todo produto de segurança se descreve em termos de camada: um filtro de pacotes atua em 3 e 4, um WAF em 7, um controle de porta em 2.

8.1.1. Encapsulamento: quem envolve quem

Quando um navegador pede uma página, o dado desce a pilha e cada camada acrescenta seu próprio cabeçalho ao que veio de cima. Chegando ao destino, o processo se inverte. Esse empacotamento sucessivo é o **encapsulamento**, e tem duas consequências diretas para segurança.

8. A pilha TCP/IP sob a ótica do atacante e do defensor

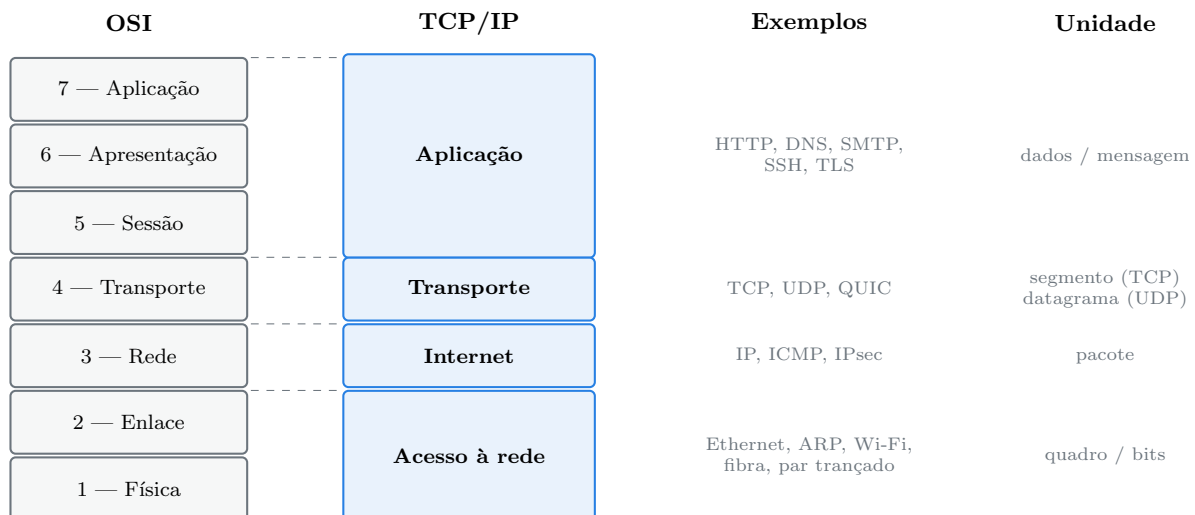


Figura 8.1.: Os dois modelos. O OSI dá o vocabulário; o TCP/IP é o que roda.

A primeira: **um cabeçalho só é lido por quem opera naquela camada**. Um switch comum olha o cabeçalho Ethernet e ignora o resto. Um roteador olha o cabeçalho IP. Um firewall de estado olha até o TCP. Cada equipamento no caminho enxerga uma fatia diferente do mesmo pacote, e a defesa precisa ser posicionada na camada onde o ataque acontece — um firewall de rede não vê injeção de SQL, e um WAF não vê ARP spoofing.

A segunda: **o que uma camada cifra, a de baixo não entende**. O TLS protege o conteúdo da camada de aplicação, mas os cabeçalhos IP e TCP continuam em claro. Quem observa o tráfego não lê a senha digitada, mas sabe com quais servidores a máquina falou, quando, por quanto tempo e com que volume. Esses **metadados** são frequentemente tão reveladores quanto o conteúdo — tema que o Volume 16 retoma ao tratar de privacidade e vigilância.

8.2. Camada 2: onde a confiança é total

A camada de enlace entrega quadros dentro de um mesmo segmento de rede. É a camada com menos verificação de todas e, por isso, a mais explorada por quem já conseguiu um ponto de presença interno.

8.2.1. ARP: o protocolo que acredita em tudo

Para enviar um quadro a um endereço IP na mesma rede, a máquina precisa descobrir o endereço MAC correspondente. O ARP resolve isso com uma pergunta em difusão — “quem tem 192.0.2.1?” — e aceita a primeira resposta que chegar. Não há autenticação, não há verificação, e respostas não solicitadas (*gratuitous ARP*) são aceitas e usadas para atualizar a tabela.

O ataque decorre diretamente disso. O invasor responde às consultas da vítima afirmando ser o gateway, e às do gateway afirmando ser a vítima. As duas tabelas ARP passam a apontar para o MAC dele, e todo o tráfego entre a vítima e o mundo atravessa sua máquina — o cenário de abertura deste capítulo. É o **ataque de intermediário** (*man in the middle*) em sua forma mais barata: não requer exploração de falha nenhuma, apenas acesso à rede local.

O que o invasor consegue depois disso depende do que trafega. Protocolos em claro entregam credenciais direto. Com HTTPS, ele pode tentar *downgrade* — interceptar a primeira requisição

HTTP e impedir o redirecionamento para HTTPS — ou apresentar um certificado próprio, gerando exatamente o aviso que o setor financeiro do caso de abertura via na tela. **O aviso de certificado é o controle funcionando**; o problema é que anos de avisos espúrios ensinaram os usuários a clicar em “prosseguir”.

As defesas moram no switch, não no computador:

- **Dynamic ARP Inspection (DAI)**, que valida respostas ARP contra a tabela de DHCP snooping e descarta as inconsistentes;
- **DHCP snooping**, que constrói essa tabela e bloqueia servidores DHCP não autorizados;
- **Port security**, limitando quantos MACs podem aparecer em cada porta de acesso;
- **HSTS** no lado do servidor, que elimina a janela de *downgrade* ao instruir o navegador a nunca usar HTTP naquele domínio.

8.2.2. Os outros ataques de camada 2

MAC flooding. A tabela CAM do switch — que associa MAC a porta — tem tamanho finito. Inundá-la com milhares de endereços forjados faz o switch, em muitos modelos, passar a inundar quadros por todas as portas, degradando-o ao comportamento de um hub e permitindo captura passiva. *Port security* limita o número de MACs por porta e resolve.

VLAN hopping. Duas variantes. Na primeira, o atacante negocia entroncamento com um switch que tem DTP habilitado e passa a receber o tráfego de todas as VLANs. Na segunda, marcação dupla (*double tagging*), ele insere duas etiquetas 802.1Q; a primeira é removida pelo switch de entrada e o quadro é entregue numa VLAN à qual ele não deveria ter acesso. As defesas são configuração explícita: desabilitar DTP nas portas de acesso, não usar a VLAN 1 para nada e definir uma VLAN nativa sem uso em todos os entroncamentos.

STP e o root bridge forjado. Anunciando-se como raiz da árvore de spanning tree, o atacante reposiciona o fluxo lógico da rede para passar por ele. As proteções chamam-se BPDU Guard e Root Guard, e devem estar ligadas em toda porta de acesso.

DHCP rogue. Um servidor DHCP falso entrega às vítimas o gateway e o DNS do atacante — resultado equivalente ao ARP spoofing, com menos esforço. DHCP snooping bloqueia respostas vindas de portas não confiáveis.

Um padrão emerge: **todas as defesas de camada 2 são configurações do switch que vêm desligadas de fábrica.** Rede montada com o padrão do equipamento é rede sem nenhuma dessas proteções.

8.3. Camada 3: endereços que ninguém verifica

A camada de rede leva pacotes de uma rede a outra. Seu cabeçalho carrega origem, destino, TTL, protocolo encapsulado e informações de fragmentação — e o campo de origem **não é verificado por ninguém no caminho.**

8.3.1. Falsificação de endereço de origem

Escrever um endereço de origem falso num pacote IP é trivial. As consequências dependem do protocolo acima.

Com **UDP**, que não exige resposta, a falsificação funciona plenamente. É a base dos ataques de **amplificação e reflexão**: o atacante envia consultas pequenas a servidores mal configurados — DNS recursivos abertos, NTP com `monlist`, memcached exposto — usando como origem o endereço da vítima. Os servidores respondem à vítima com pacotes dezenas ou centenas de vezes maiores. Um atacante com 1 Gbps de banda gera dezenas de Gbps contra o alvo, e o tráfego chega de milhares de servidores legítimos, o que dificulta o bloqueio por origem.

Com **TCP**, a falsificação é bem mais difícil, porque o atacante não recebe a resposta e precisaria adivinhar o número de sequência inicial escolhido pelo servidor. Pilhas modernas geram esse número de forma imprevisível — o que nem sempre foi verdade, e a história do TCP está cheia de ataques de predição de sequência.

A defesa contra falsificação de origem não é do lado da vítima: é de quem opera a rede de origem. A **BCP 38** (RFC 2827) recomenda que todo operador filtre, na borda, pacotes cuja origem não pertença ao bloco do cliente (Ferguson; Senie, 2000). Um provedor que aplica filtragem de entrada impede que sua rede seja usada como plataforma de reflexão. Um provedor que não aplica é parte do problema — e no Brasil essa é orientação de longa data do CERT.br e do NIC.br.

8.3.2. Fragmentação, ICMP e TTL

Fragmentação. Pacotes maiores que a MTU do enlace são divididos e remontados no destino. Historicamente isso foi usado para evadir inspeção: fragmentos sobrepostos, remontados de formas diferentes pelo IDS e pelo sistema-alvo, permitiam esconder o conteúdo real. Ataques clássicos como o *ping of death* e o *teardrop* exploravam falhas na remontagem. Firewalls e IDS modernos remontam antes de inspecionar, e a orientação prática é descartar fragmentos sobrepostos.

ICMP. Muito além do ping. `Echo` mapeia hosts vivos; `Time exceeded` alimenta o `traceroute` e revela a topologia; `Destination unreachable` com “fragmentation needed” é essencial à descoberta de MTU de caminho; `Redirect` pode alterar a rota de um host. Bloquear ICMP inteiramente é erro comum: quebra a descoberta de MTU e produz conexões que abrem e travam sem explicação. A postura correta é seletiva — permitir os tipos 3 e 11 e o `echo reply`, filtrar `redirect` e limitar a taxa do resto.

TTL. Decrementado a cada salto, existe para matar pacotes em laço. Como efeito colateral, seu valor inicial denuncia o sistema operacional de origem (64 em Linux, 128 em Windows, 255 em muitos equipamentos de rede) e a diferença entre o valor inicial esperado e o observado dá a distância em saltos. É um dos sinais que ferramentas de identificação passiva de sistema operacional usam — e um dos que denunciam um dispositivo intruso se apresentando como outra coisa.

8.4. Camada 4: o aperto de mão e seus abusos

O TCP oferece entrega confiável e ordenada sobre uma camada de rede que não garante nada. Faz isso mantendo **estado** — e estado é recurso finito, o que é exatamente a superfície de ataque.

8.4.1. O handshake de três vias

A Figura 8.2 mostra a abertura normal de conexão e, ao lado, o que o SYN flood faz com ela.

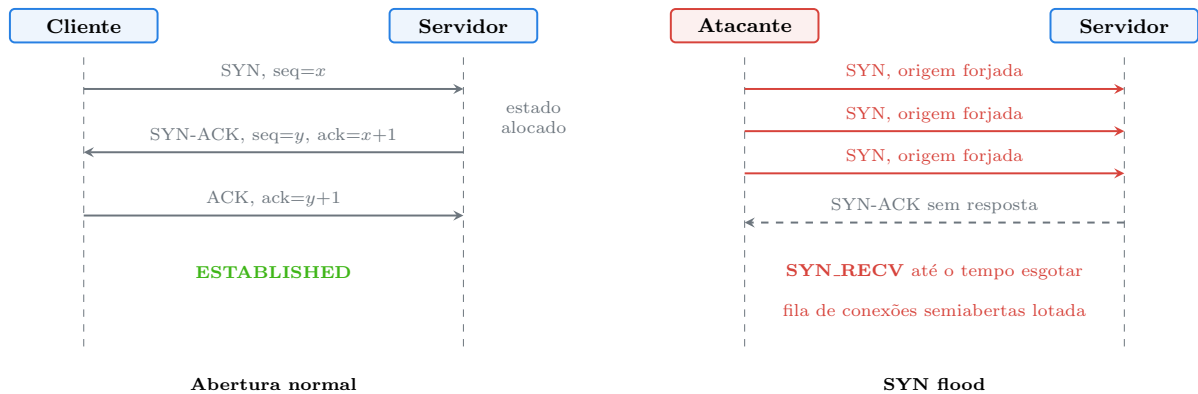


Figura 8.2.: O handshake de três vias e o abuso do estado que ele obriga o servidor a manter.

O ataque é elegante na sua economia: cada SYN custa ao atacante um pacote de algumas dezenas de bytes e custa ao servidor uma entrada de estado mantida por dezenas de segundos. A defesa clássica são os **SYN cookies**, que codificam o estado dentro do próprio número de sequência do SYN-ACK, permitindo ao servidor não alocar nada até que o ACK final chegue. No Linux é `net.ipv4.tcp_syncookies=1`, ligado por padrão nas distribuições atuais.

8.4.2. Flags, RST e a varredura

As bandeiras do cabeçalho TCP são a linguagem que as ferramentas de varredura falam, e as diferentes técnicas de escaneamento — que o Capítulo 14 vai colocar em laboratório e o Volume 9 vai detalhar — são combinações delas.

Tabela 8.1.: Técnicas de varredura e o que cada uma revela.

Técnica	O que envia	Interpretação	Rastro deixado
SYN scan	SYN, e RST antes de completar	SYN-ACK = aberta; RST = fechada	Conexão não completa; pouco log de aplicação
Connect scan	Handshake completo	Conexão bem-sucedida = aberta	Registro em todo log de aplicação
FIN, NULL, Xmas	Flags anômalas sem conexão	Silêncio = aberta ou filtrada; RST = fechada	Falha contra Windows, que sempre responde RST
ACK scan	Apenas ACK	Mapeia regra de firewall, não porta aberta	Discreto, mas informativo
UDP scan	Datagrama vazio ou específico	ICMP porta inalcançável = fechada	Lento; limitação de taxa distorce o resultado

O **RST** merece atenção separada. Um pacote RST forjado, com os números de sequência corretos, derruba uma conexão TCP estabelecida. Quem está no caminho — um provedor,

8. A pilha TCP/IP sob a ótica do atacante e do defensor

um equipamento de inspeção, um atacante em posição de intermediário — consegue injetá-lo. Historicamente foi usado tanto para censura quanto para gestão abusiva de tráfego. A proteção real é criptográfica: o TLS não impede o RST, mas impede que o conteúdo seja lido ou alterado, e protocolos sobre QUIC — que roda em UDP com autenticação de cabeçalho — resistem bem melhor a essa injeção.

8.4.3. UDP e QUIC

O UDP não tem handshake, não tem estado, não tem entrega garantida. Isso o torna adequado para DNS, VoIP, jogos e streaming — e conveniente para amplificação, como já visto. Do ponto de vista defensivo, a ausência de estado significa que o firewall também não tem estado real para acompanhar: o que ele faz é manter uma pseudo-sessão por tempo limitado após ver o primeiro datagrama.

O **QUIC**, padronizado na RFC 9000 e base do HTTP/3, muda o quadro. Roda sobre UDP na porta 443, integra o handshake TLS 1.3 ao estabelecimento da conexão e cifra a maior parte dos próprios metadados de transporte (Iyengar; Thomson, 2021). Para o operador de rede isso significa **menos visibilidade**: números de sequência, confirmações e controle de congestionamento — tudo o que um analisador de tráfego usava para diagnosticar desempenho — deixam de ser legíveis. É a tensão recorrente entre privacidade do usuário e observabilidade da rede, e ela reaparece no Volume 5.

8.5. O pecado original: confiança presumida

Recuando um passo, o padrão fica visível. A Tabela 8.2 lista, camada por camada, o que a pilha original simplesmente presumiu — e o que foi criado depois para consertar.

Tabela 8.2.: A confiança presumida em cada camada e o que veio depois para compensar.

Camada	O que o projeto original presumiu	Ataque decorrente	Remendo posterior
Enlace	Quem está na rede é legítimo	ARP spoofing, DHCP rogue, VLAN hopping	802.1X, DAI, DHCP snooping, port security
Rede	O endereço de origem é verdadeiro	Falsificação, amplificação, reflexão	BCP 38, uRPF, IPsec
Transporte	Os pares seguem o protocolo	SYN flood, injeção de RST	SYN cookies, TLS, QUIC
Aplicação	O nome resolvido é o servidor certo	Envenenamento de DNS, phishing	DNSSEC, TLS com validação de certificado, HSTS

Duas leituras importam. A primeira é histórica e generosa: a ARPANET ligava algumas dezenas de instituições que se conheciam, e autenticar cada quadro seria custo sem benefício. A segunda é operacional e menos generosa: **todos os remendos da coluna da direita são opcionais e a maioria vem desligada**. A internet insegura não é acidente inevitável — é o valor padrão que ninguém mudou.

Essa é também a razão pela qual a arquitetura Zero Trust, tema do Volume 4, ganhou tração: ela parte de negar a premissa de que estar dentro da rede significa alguma coisa.

8.6. Onde cada defesa mora

Encerrando com o mapa que a operação usa. Cada tecnologia de segurança atua numa camada específica e é cega para as demais:

- **Camada 2** — 802.1X (autenticação de porta), MACsec, port security, DAI, DHCP snooping, segmentação por VLAN.
- **Camada 3** — filtragem de pacotes, listas de acesso, IPsec, uRPF, roteamento com RPKI, anti-spoofing na borda.
- **Camada 4** — firewall de estado, SYN cookies, limitação de taxa por fluxo, balanceamento com verificação de saúde.
- **Camada 7** — TLS, WAF, filtro de DNS, gateway de e-mail, proxy com inspeção, autenticação de aplicação.

A pergunta que essa lista responde é a mais comum na resposta a incidentes: *o controle que eu tenho conseguiria enxergar esse ataque?* Um WAF caríssimo não vê um dispositivo intruso fazendo ARP spoofing no andar do financeiro. Um switch com DAI ligado vê — e teria evitado o caso de abertura antes que qualquer aviso de certificado aparecesse.

8.7. Brasil em Foco

Captura de tráfego é atividade regulada, não neutra. O diagnóstico do caso de abertura envolveu capturar pacotes de uma rede corporativa. Isso é lícito quando há autorização de quem opera a rede e finalidade técnica definida, mas o Capítulo 7 já fixou a régua: a Lei 9.296/1996 tipifica a interceptação de comunicação sem autorização judicial (Brasil, 1996), e capturar conteúdo alheio “para diagnosticar” sem autorização escrita é risco real. A prática correta é capturar o mínimo necessário, preferir cabeçalhos a conteúdo e ter autorização documentada antes de conectar o analisador.

A LGPD alcança o arquivo de captura. Um .pcap de rede corporativa contém endereços IP, nomes de máquina, credenciais em protocolos legados e frequentemente conteúdo de e-mail e navegação — dados pessoais no sentido do art. 5º, I da LGPD (Brasil, 2018). Capturas precisam de prazo de retenção, armazenamento restrito e descarte definido. Aquele **captura-financeiro.pcap** guardado por dois anos na pasta compartilhada do suporte é um incidente esperando por um momento oportuno.

BCP 38 é a contribuição mais concreta que um provedor brasileiro pode dar. O NIC.br e o CERT.br mantêm há anos o programa de boas práticas para operadores, e a filtragem anti-spoofing na borda é o item de maior impacto coletivo. Um provedor que não filtra permite que seus clientes participem de ataques de reflexão contra terceiros — inclusive contra outros provedores brasileiros. Há testes públicos que permitem verificar externamente se a própria rede está filtrando.

Anatel e a resiliência da rede. A Resolução 740/2020 estabelece requisitos de segurança cibernética aplicáveis a produtos de telecomunicações e às redes das prestadoras (Agência Nacional de Telecomunicações, 2020). Na prática, configurações básicas de camada 2 e 3 — controle de acesso à administração dos equipamentos, filtragem de borda, registro de eventos — deixaram de ser boa vontade e passaram a compor obrigação regulatória, com fiscalização possível.

Marco Civil e a inspeção de tráfego. O art. 9º do Marco Civil consagra a neutralidade de rede e restringe a discriminação de tráfego a requisitos técnicos indispensáveis e à priorização de serviços de emergência (Brasil, 2014). Bloquear ou degradar tráfego de uma aplicação específica

8. A pilha TCP/IP sob a ótica do atacante e do defensor

por decisão comercial é vedado; aplicar mitigação de ataque volumétrico é requisito técnico legítimo. A diferença entre as duas coisas precisa estar documentada na política de gestão de tráfego do provedor.

8.8. No Campo

1. Ligar as proteções de camada 2 que vieram desligadas. É o item de melhor relação entre esforço e resultado em toda a rede de acesso. Em equipamento com sintaxe Cisco-like:

```
! Em todas as portas de acesso
interface range GigabitEthernet0/1-46
  switchport mode access
  switchport nonegotiate           ! desliga DTP, mata VLAN hopping
  switchport port-security
  switchport port-security maximum 2
  switchport port-security violation restrict
  spanning-tree portfast
  spanning-tree bpduguard enable   ! ninguém vira root bridge

! Globais
ip dhcp snooping
ip dhcp snooping vlan 10,20,30
ip arp inspection vlan 10,20,30    ! depende do snooping acima
```

2. Verificar a tabela ARP quando o sintoma for “certificado inválido em vários micros”. Dois IPs com o mesmo MAC é o padrão que denuncia o intermediário:

```
# Linux: agrupa vizinhos por MAC e mostra os repetidos
ip neigh show | awk '$5 != "" {print $5}' | sort | uniq -c | sort -rn | head
```

```
# Windows: MACs que respondem por mais de um IP
Get-NetNeighbor -AddressFamily IPv4 |
  Where-Object State -ne 'Unreachable' |
  Group-Object LinkLayerAddress |
  Where-Object Count -gt 1
```

3. Aplicar filtragem anti-spoofing na borda. Em roteador com sintaxe Cisco-like, o caminho curto é o uRPF; em Linux, uma regra de saída equivalente:

```
interface GigabitEthernet0/0
  description Cliente - bloco 198.51.100.0/24
  ip verify unicast source reachable-via rx
```

```
# Linux: só deixa sair o que tem origem no bloco do cliente
nft add rule inet filter forward iifname "eth1" \
  ip saddr != 198.51.100.0/24 counter drop
```

4. Confirmar que os SYN cookies estão ativos e a fila é adequada. Custa dois comandos e evita indisponibilidade por um ataque de baixo volume:

```
sysctl net.ipv4.tcp_syncookies net.ipv4.tcp_max_syn_backlog net.core.somaxconn
# Conexões semiabertas agora - número alto e crescente é sintoma
ss -tan state syn-recv | wc -l
```

5. Filtrar ICMP com bisturi, não com machado. Bloqueio total quebra a descoberta de MTU e gera chamados insolúveis de “o site abre e trava”:

```
nft add rule inet filter input icmp type { echo-reply, destination-unreachable,
↪ time-exceeded } accept
nft add rule inet filter input icmp type echo-request limit rate 10/second
↪ accept
nft add rule inet filter input icmp type redirect drop
```

6. Fechar os amplificadores da própria rede. Antes de se preocupar em ser vítima, garantir que não se é plataforma. Recursão de DNS aberta ao mundo, NTP com `monlist`, memcached e SNMP expostos:

```
# O que responde recursão vindo de fora? (executar de fora da rede)
dig @198.51.100.53 example.com A +short
# NTP: a consulta de modo 7 deve falhar
ntpq -c rv 198.51.100.10
```

7. Padronizar a captura de tráfego. Um procedimento de uma página: quem autoriza, o que se captura (preferir `-s 96` para limitar a carga útil), onde se guarda, por quanto tempo e como se apaga:

```
# Cabeçalhos apenas, rotação a cada 5 minutos, 10 arquivos no máximo
tcpdump -i eth0 -s 96 -w /var/captura/rede-%Y%m%d-%H%M.pcap -G 300 -W 10 \
'not port 22'
```

8. Documentar a política de gestão de tráfego. Uma página que separa, para o Marco Civil e para a Anatel, o que é requisito técnico (mitigação de ataque, controle de congestionamento) do que seria discriminação comercial. Escrita antes do incidente, é defesa; escrita depois, é justificativa.

8.9. Resumo

- Os dois modelos convivem: **OSI dá o vocabulário** (camada 2, camada 7) e **TCP/IP é o que roda**. Cada equipamento no caminho lê apenas os cabeçalhos da sua camada, e por isso a defesa precisa estar na camada onde o ataque ocorre.
- A **camada 2 não verifica nada**. ARP spoofing, DHCP rogue, MAC flooding, VLAN hopping e root bridge forjado exploram a mesma premissa de que quem está na rede é legítimo. Todas as defesas — DAI, DHCP snooping, port security, BPDU Guard, 802.1X — são configurações de switch **desligadas de fábrica**.

8. A pilha TCP/IP sob a ótica do atacante e do defensor

- O **endereço de origem IP não é verificado por ninguém**. Com UDP isso viabiliza amplificação e reflexão; com TCP é limitado pela imprevisibilidade dos números de sequência. A defesa é a filtragem na borda de quem origina o tráfego (**BCP 38**), não do lado da vítima.
- O TCP mantém **estado**, e estado finito é superfície de ataque: o SYN flood custa dezenas de bytes ao atacante e uma entrada de tabela ao servidor. **SYN cookies** resolvem. Injeção de RST derruba conexões estabelecidas e só é neutralizada por criptografia.
- **QUIC muda o equilíbrio**: cifra os metadados de transporte, ganhando privacidade e reduzindo a visibilidade que operadores usavam para diagnóstico.
- O padrão que atravessa a pilha é a **confiança presumida** por um projeto feito para uma rede entre pares conhecidos. Todos os remendos posteriores são opcionais — a insegurança padrão é escolha de configuração, não fatalidade.
- No Brasil, capturar tráfego exige autorização e cuidado com a Lei 9.296/1996; o **.pcap** resultante é dado pessoal sob a LGPD; e a filtragem anti-spoofing na borda é a contribuição coletiva mais concreta de um provedor.

9. Endereçamento, roteamento e NAT

Um provedor de médio porte cresceu por aquisição. Herdou três redes que usavam 192.168.1.0/24 para a gerência dos equipamentos — a sua, a da empresa comprada em 2021 e a da comprada em 2023. Ninguém reenumerou. A solução foi ir empilhando NAT: cada rede herdada fica atrás de um roteador que traduz seus endereços para um bloco distinto antes de entrar na rede principal.

Funcionou por dois anos. Até a noite em que um servidor de monitoramento passou a registrar tentativas de acesso SSH vindas de 10.20.0.7, um endereço que, dependendo de qual tabela de tradução se consulte, corresponde a três equipamentos diferentes em três cidades diferentes. A equipe levou seis horas para descobrir de qual deles vinha o tráfego, porque o registro do firewall guardava o endereço traduzido e não o original.

O invasor teve seis horas de vantagem. Não por causa de uma falha de software: por causa de um plano de endereçamento que nunca existiu.

Este capítulo trata da camada 3 do Capítulo 8 do ponto de vista de quem projeta e opera: como os endereços são atribuídos, como os pacotes encontram o caminho, e o que o NAT realmente faz — incluindo o que ele não faz, apesar de todo mundo acreditar que faz.

9.1. Endereçamento IPv4 e a matemática que não dá para evitar

Um endereço IPv4 tem 32 bits, escritos em quatro octetos decimais. A **máscara de rede** separa esses 32 bits em duas partes: um prefixo que identifica a rede e um sufixo que identifica o host dentro dela. A notação CIDR escreve o tamanho do prefixo depois da barra — 198.51.100.0/24 significa 24 bits de rede e 8 de host (Fuller; Li, 2006).

A conta que todo profissional precisa fazer de cabeça:

Tabela 9.1.: Prefixos CIDR de uso corrente.

Prefixo	Máscara	Endereços	Hosts utilizáveis	Uso típico
/30	255.255.255.252	4	2	Enlace ponto a ponto
/29	255.255.255.248	8	6	Pequeno bloco de servidores
/28	255.255.255.240	16	14	Sub-rede de DMZ
/24	255.255.255.0	256	254	VLAN padrão de escritório
/22	255.255.252.0	1.024	1.022	Rede de acesso de provedor
/16	255.255.0.0	65.536	65.534	Espaço de agregação

Os dois endereços subtraídos em cada linha são o de **rede** (todos os bits de host em zero) e o de **broadcast** (todos em um). A exceção é o /31, previsto na RFC 3021 para enlaces ponto a ponto, onde os dois endereços são utilizáveis — economia que importa quando um provedor tem centenas de enlaces.

Há três faixas **privadas**, definidas pela RFC 1918, que não são roteáveis na internet pública (Rekhter et al., 1996):

- 10.0.0.0/8 — 16,7 milhões de endereços;
- 172.16.0.0/12 — de 172.16.0.0 a 172.31.255.255;
- 192.168.0.0/16 — 65.536 endereços.

E vale conhecer duas faixas que causam confusão em diagnóstico. 127.0.0.0/8 é *loopback*: nunca sai da máquina. 169.254.0.0/16 é auto-configuração de enlace local — quando uma máquina aparece com um endereço dessa faixa, significa que **o DHCP não respondeu**. É o sintoma, não a causa, e a causa costuma ser cabo, VLAN errada ou servidor DHCP fora do ar.

9.1.1. O plano de endereçamento como controle de segurança

O caso de abertura mostra por que endereçamento é assunto de segurança, e não apenas de conectividade. Um plano de endereçamento bem feito produz três benefícios diretos:

Legibilidade. Ao ver 10.30.20.15 num alerta, quem está de plantão deve conseguir dizer, sem consultar planilha, que se trata da filial 30, VLAN de servidores, host 15. Isso se obtém reservando significado posicional aos octetos: por exemplo, o segundo octeto para o site, o terceiro para a função (10 = gerência, 20 = servidores, 30 = usuários, 40 = visitantes, 50 = câmeras).

Filtragem simples. Se todas as VLANs de gerência de todos os sites estiverem em 10.x.10.0/24, uma única regra 10.0.10.0/16 com máscara não contígua — ou, mais limpo, um bloco agregado dedicado — cobre a regra “gerência não fala com usuário”. Endereçamento aleatório exige uma regra por sub-rede, e listas longas de regras são listas com erro.

Ausência de sobreposição. Redes que se sobrepõem impedem VPN entre sites, impedem fusão de empresas e obrigam ao empilhamento de NAT do caso de abertura. Reservar de saída um bloco /8 privado inteiro e distribuir /16 por site custa nada e evita o problema para sempre.

A Figura 9.1 mostra a estrutura de um plano assim.

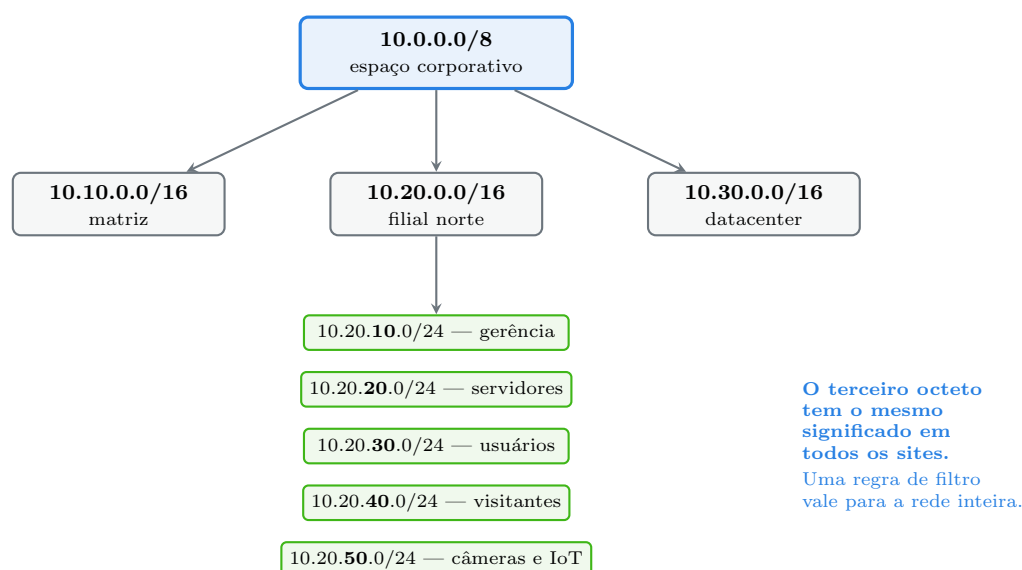


Figura 9.1.: Plano de endereçamento hierárquico. Posição com significado transforma um endereço em informação de diagnóstico.

9.2. IPv6: o que muda de verdade

O IPv6 usa 128 bits, escritos em oito grupos hexadecimais de quatro dígitos, com regras de abreviação: zeros à esquerda de cada grupo podem ser omitidos e uma única sequência de grupos nulos vira `::`. Assim, `2001:0db8:0000:0000:0000:0000:0000:0001` escreve-se `2001:db8::1`. A faixa `2001:db8::/32` é reservada para documentação, e é dela que vêm todos os exemplos deste manual.

Cinco pontos concentram o que importa para segurança:

Não existe NAT, e isso é bom e ruim. Cada dispositivo pode ter endereço global roteável. Bom porque restaura a conectividade fim a fim e simplifica diagnóstico e registro; ruim porque desaparece o efeito colateral de ocultação que muita gente confundia com segurança. Com IPv6, **o firewall precisa ser explícito** — não há mais um NAT bloqueando por acidente o que ninguém liberou.

A varredura muda de natureza. Uma sub-rede IPv6 padrão é /64: 18 quintilhões de endereços. Varrer sequencialmente é inviável. Isso não protege tanto quanto parece, porque atacantes usam DNS, certificados públicos, registros em serviços e padrões previsíveis de atribuição para descobrir hosts ativos. Endereçamento sequencial manual (`::1`, `::2`, `::3`) devolve a varredura à mesa.

Autoconfiguração e o vizinho malicioso. O SLAAC permite que um host se configure a partir de anúncios de roteador (RA). Um RA forjado redireciona todo o tráfego da rede — o equivalente IPv6 do DHCP rogue. A defesa chama-se **RA Guard** e é configuração de switch, tal como as do Capítulo 8. O protocolo NDP substitui o ARP e herda os mesmos problemas de confiança, mitigados por **ND Inspection** e, em ambientes exigentes, por SEND.

Extensões de privacidade. Endereços derivados do MAC identificavam a máquina em qualquer rede. As extensões da RFC 4941 geram endereços temporários rotativos, hoje o padrão nos sistemas operacionais. Para o operador, isso significa que um endereço IPv6 de cliente **muda com frequência**, com impacto direto em registro, correlação e resposta a incidentes.

Pilha dupla é dobro de superfície. O erro mais comum na transição: a organização configura firewall rigoroso em IPv4, habilita IPv6 sem perceber (ele vem ligado por padrão em praticamente tudo) e deixa a política v6 permissiva ou inexistente. **Todo controle precisa existir nas duas pilhas** — regra de firewall, registro, monitoramento, lista de bloqueio. Um caminho v6 aberto anula meses de trabalho no v4.

9.3. Roteamento: como o pacote encontra o caminho

Um roteador recebe um pacote, consulta sua tabela e decide por onde encaminhá-lo. A regra de decisão é o **prefixo mais longo**: entre `0.0.0.0/0`, `198.51.0.0/16` e `198.51.100.0/24`, o pacote para `198.51.100.7` sai pela rota /24, a mais específica.

Rotas entram na tabela por três origens. As **conectadas** aparecem sozinhas quando uma interface recebe endereço. As **estáticas** são escritas à mão — previsíveis, sem tráfego de controle, mas sem reação a falha. As **dinâmicas** vêm de protocolos que trocam informação entre roteadores: OSPF e IS-IS dentro de um domínio administrativo, BGP entre domínios.

9.3.1. O interior: OSPF e amigos

Protocolos de gateway interior propagam mudanças de topologia em segundos e recalculam caminhos automaticamente. Do ponto de vista de segurança, dois riscos:

Vizinhança não autenticada. Um roteador não autorizado que estabeleça adjacência OSPF pode injetar rotas e atrair tráfego. A mitigação tem duas partes: **autenticação de área** com chave compartilhada ou HMAC-SHA, e marcação de todas as interfaces de usuário como **passive-interface**, para que não formem adjacência com nada.

Vazamento de topologia. Um protocolo de estado de enlace distribui o mapa completo da rede a todos os participantes. Quem consegue escutar aprende a topologia inteira de graça — reconhecimento sem enviar um único pacote.

9.3.2. O exterior: BGP e a confiança global

O BGP mantém a internet de pé anunciando quais blocos cada sistema autônomo (AS) alcança. E funciona, essencialmente, na base da palavra: por padrão, um AS que anuncia um prefixo é acreditado pelos vizinhos.

Daí decorrem duas famílias de incidente. O **sequestro de prefixo** (*hijack*) ocorre quando um AS anuncia bloco que não é seu e atrai o tráfego destinado a ele — por erro de digitação ou por intenção, com casos documentados de desvio de tráfego para interceptação e de roubo de criptoativos por sequestro de rotas de DNS. O **vazamento de rota** (*route leak*) ocorre quando um AS repassa a um provedor rotas aprendidas de outro provedor, transformando-se involuntariamente em trânsito para tráfego que não deveria passar por ele — com congestionamento imediato.

As defesas atuais são três, e todas dependem de adoção coletiva: **filtros de prefixo** entre vizinhos, construídos a partir de objetos de roteamento registrados; **RPKI com validação de origem** (ROV), que assina criptograficamente a autorização de um AS para anunciar um prefixo; e **limites de prefixos recebidos**, que derrubam a sessão quando um vizinho anuncia muito além do esperado, contendo vazamentos. O Volume 5 dedica um capítulo ao tema; aqui basta fixar que a autorização de anúncio é um problema de confiança global e ainda parcialmente resolvido.

9.4. NAT: o que ele faz e o que ele não faz

A tradução de endereços de rede reescreve endereços — e frequentemente portas — nos cabeçalhos dos pacotes que atravessam um roteador. Nasceu como paliativo para a escassez de IPv4 e acabou virando peça estrutural de quase toda rede corporativa.

O tipo dominante é o **NAT de sobrecarga** (PAT, ou *masquerade*), em que muitos hosts internos compartilham um endereço público, distinguidos pela porta de origem. A Figura 9.2 mostra a mecânica e a tabela de estado que a sustenta.

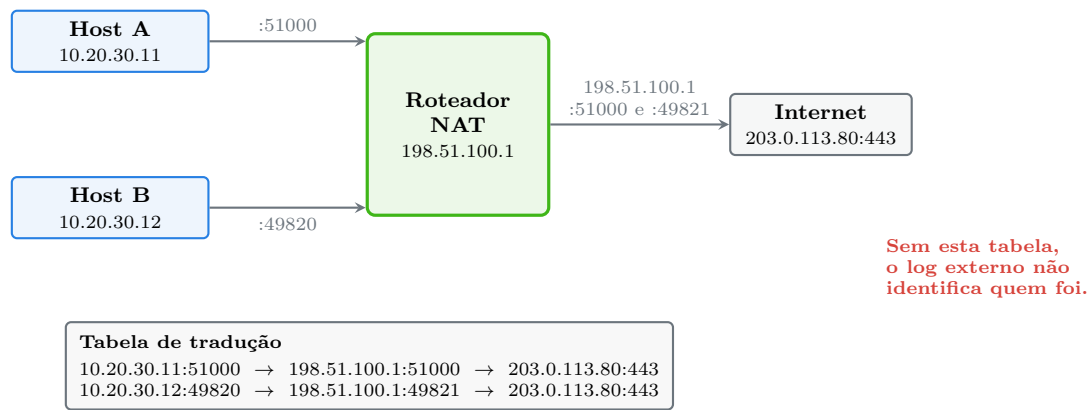


Figura 9.2.: NAT de sobrecarga. A tabela de tradução é o único elo entre o endereço público registrado e o host que originou a sessão.

9.4.1. O mito da segurança por NAT

A crença de que “estar atrás de NAT é estar protegido” é uma das mais persistentes e mais caras da área. O que o NAT realmente oferece é um efeito colateral: como não há tradução prévia para conexões entrantes não solicitadas, elas não têm para onde ser encaminhadas e são descartadas. Isso se parece com um firewall — mas não é um.

O que o NAT **não** faz:

- **Não protege contra nada iniciado de dentro.** Um usuário que abre um anexo malicioso estabelece a conexão de dentro para fora, e o NAT cria a tradução com prazer. Praticamente todo malware moderno funciona assim, exatamente por isso.
- **Não inspeciona conteúdo.** Não vê exploração, não vê exfiltração, não vê comando e controle.
- **Não resiste a técnicas de travessia.** UPnP e NAT-PMP permitem que qualquer aplicação na rede interna abra portas no roteador sem autorização humana. STUN e *hole punching* estabelecem sessões diretas entre dois hosts atrás de NAT. Essas técnicas existem porque aplicações legítimas precisam delas — e servem igualmente ao que não é legítimo.
- **Não impede movimentação lateral.** Dentro da rede traduzida, tudo se comunica livremente, a menos que haja segmentação de verdade.

E o que o NAT **quebra**, em compensação: rastreabilidade (o caso de abertura), geolocalização e reputação por endereço, IPsec fim a fim em modo transporte, protocolos que carregam endereços na carga útil (SIP, FTP ativo) e, no caso do CGNAT, a própria capacidade de responder a um ofício judicial. A postura correta é: **NAT é solução de endereçamento; firewall é solução de segurança.** Quem precisa de proteção configura política explícita de filtragem, com ou sem NAT no caminho.

9.4.2. CGNAT e a obrigação de registrar

Provedores que esgotaram seu espaço IPv4 usam CGNAT: centenas ou milhares de assinantes compartilham um mesmo endereço público, com o espaço 100.64.0.0/10 (RFC 6598) entre o cliente e a borda. É uma segunda camada de tradução, sobre a que o roteador do cliente já faz.

O problema operacional é imediato e recorrente. Chega um ofício informando que, em determinada data e hora, o endereço 198.51.100.42 praticou um ilícito. Esse endereço foi compartilhado por

512 assinantes naquele instante. **Sem o registro de tradução — endereço interno, porta externa, destino, marca temporal com fuso — não há como identificar o assinante**, e a resposta ao ofício é a admissão de que a informação não existe.

A prática consolidada, e que reduz o volume de registro em ordens de magnitude, é a **alocação determinística de blocos de portas**: cada assinante recebe uma faixa fixa de portas no endereço público, e basta registrar essa atribuição em vez de cada sessão. Um registro por assinante por dia substitui milhões de linhas de fluxo.

9.5. Brasil em Foco

O Marco Civil exige o registro que o CGNAT dificulta. Os arts. 13 e 15 da Lei 12.965/2014 obrigam à guarda de registros de conexão por um ano e de registros de acesso a aplicações por seis meses (Brasil, 2014). Com CGNAT, “registro de conexão” só é útil se incluir a **porta de origem** e a **marca temporal precisa** — sem isso, o endereço público sozinho aponta para centenas de assinantes e o provedor fica sem condições de responder. Guardar apenas o endereço é cumprir a obrigação de forma que não serve a ninguém.

Marca temporal e fuso horário derrubam investigações. Registro sem fuso explícito, ou com relógio dessincronizado, produz identificação errada de assinante — com potencial de apontar pessoa inocente. Sincronização NTP obrigatória em todo equipamento que registra, e registro em UTC com fuso declarado, são requisitos práticos, não preciosismo. É o tipo de detalhe que só aparece quando já é tarde.

Sigilo dos registros. Os arts. 10 e 11 do Marco Civil impõem que esses dados só sejam disponibilizados mediante ordem judicial, com indicação do período e do fato apurado. Entregar identificação de assinante a quem pede sem ordem — inclusive a autoridade policial fora do rito — é violação de sigilo, com responsabilização civil e administrativa. O Capítulo 7 tratou da postura correta: exigir a ordem, verificar sua abrangência e responder exatamente o requisitado.

A LGPD sobre a tabela de tradução. Endereço IP associável a pessoa é dado pessoal. Os registros de CGNAT são, portanto, base de dados pessoais sob a LGPD (Brasil, 2018), com necessidade de controle de acesso, registro de quem consulta, prazo de retenção definido (os prazos legais são mínimos, não permissão para guardar indefinidamente) e eliminação ao fim. Um provedor que retém cinco anos de tabela NAT “por precaução” está criando risco, não reduzindo.

Blocos e ASN vêm do registro.br. No Brasil, prefixos IPv4/IPv6 e números de AS são atribuídos pelo NIC.br via registro.br, e o contato de abuso registrado é o canal por onde o CERT.br notifica máquinas comprometidas. Manter esse contato atualizado e monitorado é obrigação prática. **Adotar IPv6 nativo** é, além disso, a única saída estrutural para o problema de rastreabilidade do CGNAT — e o Brasil está entre os países com maior adoção, o que remove a desculpa de que o mercado não está pronto.

9.6. No Campo

1. Escrever o plano de endereçamento antes de precisar dele. Uma planilha com bloco por site, significado fixo do terceiro octeto e faixas reservadas para crescimento. Depois de renumerar uma rede em produção, ninguém precisa ser convencido do valor disso.

```
10.<site>.<função>.<host>/24
```

```
site:      10=matriz  20=filial norte  30=DC  40..=novos
função:    10=gerência 20=servidores 30=usuários 40=visitantes 50=IoT/CFTV
reserva:   60..99 livres para crescimento por site
```

2. Guardar registro de tradução que serve para responder ofício. Com CGNAT, blocos determinísticos de porta reduzem o volume a uma linha por assinante:

```
# Exemplo com nftables: bloco determinístico de portas por assinante
nft add rule ip nat postrouting ip saddr 100.64.0.10 \
  snat to 198.51.100.42:2048-3071

# Verificar sincronização de relógio em quem registra - sem isso, o log mente
timedatectl show -p NTPSynchronized -p Timezone
chronyc tracking | grep -E 'Stratum|System time'
```

3. Auditar a sobreposição de endereços antes de cada aquisição ou VPN nova. Cinco minutos que evitam meses de NAT empilhado:

```
# Lista as redes conectadas e as rotas aprendidas, para conferir contra o plano
ip -4 route show | sort
ip -6 route show | sort
```

4. Fechar a pilha IPv6 com a mesma política do IPv4. O erro mais comum da transição:

```
# As duas tabelas precisam ter política equivalente
nft list ruleset | grep -A5 'table ip filter'
nft list ruleset | grep -A5 'table ip6 filter'

# Se IPv6 não for usado nem gerenciado, desabilitar é melhor que ignorar
sysctl net.ipv6.conf.all.disable_ipv6
```

5. Proteger o protocolo de roteamento interno. Autenticação nas adjacências e interface passiva em tudo que dá para usuário:

```
router ospf 1
  area 0 authentication message-digest
  passive-interface default
  no passive-interface GigabitEthernet0/1    ! só o enlace de trânsito
interface GigabitEthernet0/1
  ip ospf message-digest-key 1 md5 <chave>
```

6. Ligar RA Guard e DHCPv6 Guard nas portas de acesso. O equivalente IPv6 do DHCP snooping, e igualmente desligado de fábrica:


```
ipv6 nd raguard policy ACESSO
device-role host
interface range GigabitEthernet0/1-46
ipv6 nd raguard attach-policy ACESSO
```

7. Verificar o que está anunciado com o seu ASN. Sequestro de prefixo é detectado por monitoramento externo, não pelo roteador de borda. Ferramentas públicas de olhar-de-vidro (*looking glass*) e serviços de monitoramento de BGP alertam quando um prefixo seu aparece anunciado por outro AS — configurar esse alerta leva minutos e é a única forma prática de descobrir o problema em tempo hábil.

8. Desligar UPnP na borda. Permitir que qualquer aplicação da rede interna abra portas no roteador sem aprovação anula a política de firewall. Onde houver necessidade legítima, encaminhamento explícito e documentado, com revisão periódica da lista.

9.7. Resumo

- Endereçamento é **controle de segurança**, não só conectividade: um plano hierárquico com significado posicional dá legibilidade ao alerta, permite regras de filtro curtas e evita a sobreposição que leva ao NAT empilhado e à perda de rastreabilidade.
- As faixas privadas da RFC 1918 e as de documentação (192.0.2.0/24, 2001:db8::/32) são o vocabulário obrigatório. Um 169.254.x.x na máquina significa **DHCP sem resposta**, não configuração válida.
- No **IPv6**, o que muda para segurança é a ausência de NAT (o firewall precisa ser explícito), a inviabilidade da varredura sequencial, os ataques de RA e NDP equivalentes aos de camada 2, os endereços temporários que dificultam correlação, e o risco de **pilha dupla com política só em v4**.
- O roteamento decide por **prefixo mais longo**. Internamente, autenticar adjacências e marcar interfaces de usuário como passivas. Externamente, o BGP funciona na base da confiança, e as defesas contra sequestro e vazamento — filtros de prefixo, RPKI com validação de origem, limite de prefixos — dependem de adoção coletiva.
- **NAT não é firewall**. Não protege contra o que é iniciado de dentro, não inspeciona conteúdo, é atravessado por UPnP e *hole punching* e não impede movimentação lateral. Em compensação, quebra rastreabilidade, geolocalização, IPsec fim a fim e protocolos que carregam endereços na carga útil.
- Com **CGNAT**, o registro só é útil se incluir porta de origem e marca temporal sincronizada e com fuso declarado — sem isso, o Marco Civil não é atendido de forma útil e um ofício aponta para centenas de assinantes. Blocos determinísticos de portas reduzem o volume de registro em ordens de magnitude.
- Registros de tradução são **dados pessoais sob a LGPD**: acesso controlado, retenção definida e eliminação ao fim do prazo. Adotar IPv6 nativo é a única solução estrutural para o problema de rastreabilidade.

10. Protocolos de aplicação e seus riscos: HTTP, DNS, SMTP e SNMP

O departamento financeiro de uma distribuidora recebe um e-mail do fornecedor habitual informando mudança de conta bancária. O remetente aparece corretamente como `financeiro@fornecedor.exemplo.br`. O texto cita o número do pedido em aberto, o valor exato e o nome da pessoa que costuma assinar. O pagamento de R\$ 180 mil sai naquela tarde.

Duas semanas depois, o fornecedor cobra a fatura. A investigação mostra que o e-mail nunca passou pelo servidor do fornecedor: o campo **From:** foi simplesmente escrito pelo atacante, porque o SMTP permite escrever o que se quiser ali. O domínio do fornecedor não tinha registro SPF, não assinava com DKIM e não publicava política DMARC. A informação sobre o pedido veio de uma caixa postal comprometida meses antes, lida em silêncio.

Nenhum software foi explorado. O ataque consistiu em usar quatro protocolos exatamente como eles foram especificados.

Os dois capítulos anteriores trataram da infraestrutura que move pacotes. Este sobe à camada 7 — onde estão os dados que interessam a quem ataca, e onde a maior parte dos incidentes efetivamente acontece.

10.1. O padrão comum: texto claro e confiança presumida

Os protocolos de aplicação fundamentais da internet foram especificados entre 1971 e 1990, e compartilham três traços que explicam quase todos os seus problemas de segurança.

São textuais e legíveis. Comandos em ASCII, respostas em ASCII. Isso foi decisão deliberada — facilita depuração, permite falar o protocolo à mão com um `telnet` — e significa que qualquer um no caminho lê tudo.

Não autenticam a origem. O SMTP aceita qualquer remetente. O DNS aceita qualquer resposta que case com a pergunta. O HTTP não tem noção de identidade.

Não verificam integridade. Nada impede que um intermediário altere o conteúdo em trânsito.

A resposta histórica foi a mesma em todos os casos: envolver o protocolo original em TLS e acrescentar mecanismos de autenticação por cima. A Tabela 10.1 resume o quadro atual.

Tabela 10.1.: Protocolos de aplicação, portas e o que cada um expõe sem proteção.

Protocolo	Porta em claro	Porta protegida	O que vaza sem proteção	Camada de autenticação
HTTP	80	443 (TLS)	Conteúdo, cookies, credenciais	TLS + HSTS

Protocolo	Porta em claro	Porta protegida	O que vaza sem proteção	Camada de autenticação
DNS	53	853 (DoT), 443 (DoH)	Todo o histórico de navegação	DNSSEC (integridade)
SMTP	25	587/465 (STARTTLS, TLS)	Mensagens, credenciais	SPF, DKIM, DMARC, MTA-STS
IMAP / POP3	143 / 110	993 / 995	Caixa postal inteira	TLS + autenticação forte
FTP	21	990 (FTPS), 22 (SFTP)	Credenciais e arquivos	Substituir por SFTP
Telnet	23	—	Sessão administrativa completa	Substituir por SSH
SNMP v1/v2c	161	161 (SNMPv3)	Inventário e configuração	SNMPv3 com authPriv
LDAP	389	636 (LDAPS)	Diretório e credenciais	LDAPS ou StartTLS

Duas leituras práticas dessa tabela. A primeira: **a coluna do meio ainda está em uso** em quase toda rede corporativa, tipicamente em equipamentos antigos, sistemas legados e impressoras. A segunda: para os quatro protocolos que este capítulo detalha, a defesa não é apenas ligar TLS — cada um tem um problema estrutural próprio que o TLS não resolve.

10.2. HTTP: simples por fora, complexo por dentro

O HTTP é um protocolo de requisição e resposta sem estado (Fielding; Nottingham; Reschke, 2022). O cliente envia um método, um caminho e cabeçalhos; o servidor responde com um código e um corpo. Toda a complexidade — e a superfície de ataque — vem do que foi acrescentado por cima dessa simplicidade.

10.2.1. Os cabeçalhos que importam para segurança

Os cabeçalhos de resposta são o principal controle de segurança que uma aplicação web configura sem tocar no código:

Tabela 10.2.: Cabeçalhos de resposta HTTP com função de segurança.

Cabeçalho	O que faz	Sem ele
Strict-Transport-Security	Obriga HTTPS naquele domínio	Janela de <i>downgrade</i> na primeira visita
Content-Security-Policy	Restringe origens de script, estilo e mídia	XSS explora sem restrição
X-Content-Type-Options: nosniff	Impede adivinhação de tipo	Upload vira script executável
X-Frame-Options / frame-ancestors	Impede enquadramento em outro site	<i>Clickjacking</i>

Cabeçalho	O que faz	Sem ele
Referrer-Policy	Limita o que vaza na navegação	URLs internas com token vazam a terceiros
Set-Cookie: Secure; HttpOnly; SameSite	Protege o cookie de sessão	Roubo por script ou por HTTP; CSRF

O Capítulo 5 chamaria isso de controles que atuam sobre a exploração, não sobre a falha. São baratos, testáveis por ferramenta automática e mesmo assim ausentes na maioria dos sistemas internos — precisamente porque “é só a intranet”.

10.2.2. O estado que o protocolo não tem

Como o HTTP não guarda estado, a sessão é reconstruída a cada requisição por um **cookie**, um cabeçalho **Authorization** ou um token. Isso desloca o problema: quem obtiver esse identificador é o usuário, sem precisar da senha. Daí a importância dos atributos do cookie e da rotação do identificador de sessão após a autenticação — assunto que o Volume 7 aprofunda.

Três abusos merecem menção desde já, porque aparecem em qualquer análise de tráfego:

Métodos indevidamente habilitados. TRACE viabiliza roubo de cabeçalhos por *cross-site tracing*; PUT e DELETE abertos em servidor mal configurado permitem escrita direta. A regra é permitir apenas o que a aplicação usa.

Redirecionamento aberto. Um parâmetro que recebe URL de destino sem validação transforma o domínio confiável em trampolim de phishing: o usuário vê o domínio do banco no link e termina no site do atacante.

Vazamento por resposta. Cabeçalhos Server e X-Powered-By com versão exata, páginas de erro com pilha de execução, comentários em HTML com caminho interno. Nada disso é vulnerabilidade por si; tudo isso encurta o trabalho de reconhecimento.

10.2.3. HTTPS não é opcional, e “só interno” não é argumento

O Capítulo 8 mostrou como um intermediário na rede local intercepta tráfego. Toda aplicação HTTP interna — o painel do switch, o sistema de chamados, a impressora — entrega credenciais a quem esteja nessa posição. Certificados internos assinados por uma CA própria, ou ACME interno automatizado, resolvem o problema sem custo de certificado público. O Volume 3 trata do TLS em detalhe; a decisão de política, porém, é deste nível: **não existe rede confiável o bastante para justificar HTTP em claro.**

10.3. DNS: a lista telefônica que qualquer um pode adulterar

Toda conexão começa por uma consulta DNS. Isso faz do DNS, simultaneamente, o alvo mais estratégico e o sensor mais rico de uma rede.

A Figura 10.1 mostra o caminho de uma consulta e os quatro pontos onde ele pode ser subvertido.

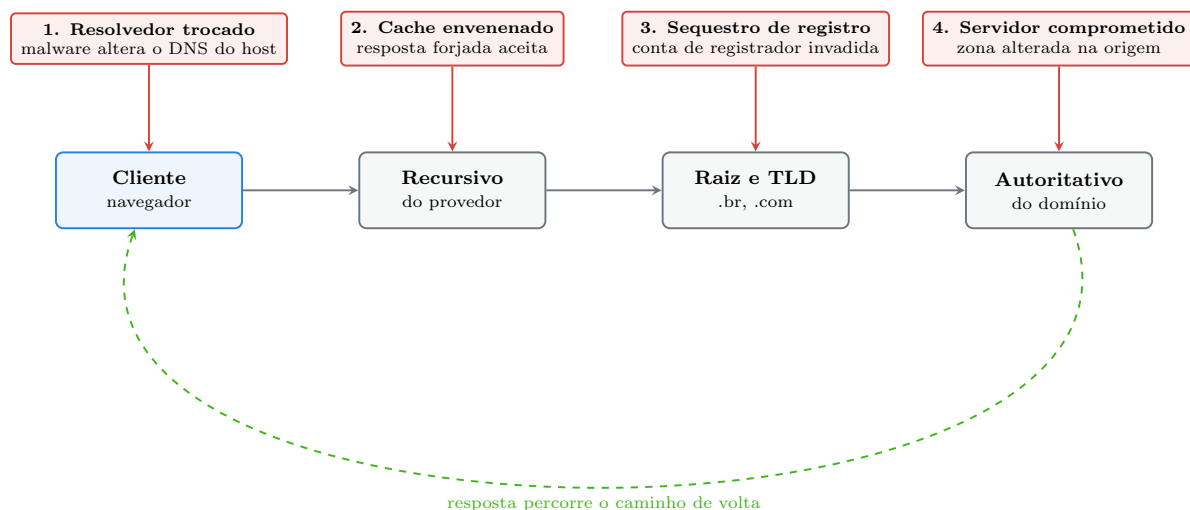


Figura 10.1.: Os quatro pontos de subversão de uma resolução DNS. Só o segundo é mitigado por DNSSEC.

10.3.1. Envenenamento de cache e o que o DNSSEC resolve

O DNS usa UDP por padrão e casa perguntas com respostas por um identificador de 16 bits mais a porta de origem. Um atacante que consiga entregar uma resposta forjada com esses valores corretos antes da resposta legítima insere no cache do recursivo um registro falso — que será servido a todos os clientes daquele recursivo até expirar o TTL. A técnica descrita por Dan Kaminsky em 2008 tornou isso viável a ponto de forçar a adoção emergencial de aleatorização de porta de origem em toda a internet.

O **DNSSEC** resolve o problema na raiz: assina criptograficamente os registros, encadeando a confiança da raiz até o domínio. O que ele **não** faz merece ênfase igual — DNSSEC garante integridade e autenticidade, **não** **confidencialidade**. A consulta continua visível. Quem observa o tráfego sabe exatamente que sites foram acessados, mesmo com todo o conteúdo em HTTPS.

Confidencialidade veio depois, com **DoT** (DNS sobre TLS, porta 853) e **DoH** (DNS sobre HTTPS, porta 443) (Hoffman; McManus, 2018). E aqui há uma tensão real para quem opera rede: DoH esconde as consultas do próprio operador, quebrando filtros de conteúdo corporativos, bloqueio de domínios maliciosos e visibilidade para resposta a incidentes. Navegadores que habilitam DoH por padrão para um resolver externo tiram do administrador um dos seus melhores sensores. A resposta madura não é bloquear DoH e sim **oferecer DoH interno**: o mesmo benefício de privacidade contra terceiros, com o controle e a visibilidade permanecendo na organização.

10.3.2. O DNS como sensor e como canal de fuga

Do lado defensivo, o registro de consultas DNS é o dado mais custo-eficiente de uma rede: uma única fonte revela acesso a domínios de comando e controle, a sites de phishing recém-registrados, a serviços não autorizados, e denuncia máquinas infectadas antes de qualquer outro sinal.

Do lado ofensivo, o mesmo protocolo é o canal de exfiltração mais confiável que existe. Como quase toda rede permite DNS de saída, dados podem ser codificados em nomes de subdomínio — `ZGFkb3NleGZpbHRyYWRvcw.atacante.exemplo` — e recuperados no servidor autoritativo do

atacante. **Tunelamento DNS** carrega sessões interativas inteiras assim, lentamente e sem chamar atenção. Os indicadores são reconhecíveis: volume anormal de consultas a um único domínio, nomes muito longos, alta proporção de respostas NXDOMAIN, uso intenso de tipos TXT e NULL, entropia elevada nos rótulos.

10.4. SMTP: o protocolo que confia no remetente

O SMTP entrega mensagens numa sequência de comandos textuais. O ponto que explica o caso de abertura deste capítulo é a existência de **dois remetentes** numa mesma mensagem, e o fato de que só o segundo aparece na tela.

O **envelope** (MAIL FROM) é usado no transporte e é o que o SPF verifica. O **cabeçalho** (From:) é o que o cliente de e-mail exibe. São campos independentes, e nada no protocolo obriga que coincidam. Escrever qualquer coisa no **From:** é comportamento previsto — é assim que listas de discussão e sistemas de notificação funcionam.

Sobre essa base foram construídos três mecanismos que, **juntos**, fecham a falsificação:

SPF publica em DNS quais servidores podem enviar em nome do domínio (Kitterman, 2014). Verifica o envelope, não o **From:** exibido, e quebra ao encaminhar mensagens — daí não bastar sozinho.

DKIM assina criptograficamente cabeçalhos e corpo com uma chave cujo público está no DNS (Crocker; Hansen; Kucherawy, 2011). Sobrevive ao encaminhamento e prova integridade, mas não diz o que fazer quando falha.

DMARC amarra os dois ao **From:** exibido, exigindo **alinhamento**, e publica a política a aplicar em caso de falha — **none** (só relatar), **quarantine** ou **reject** — além de habilitar relatórios agregados (Kucherawy; Zwicky, 2015).

A Figura 10.2 mostra a sequência de verificação no servidor receptor.

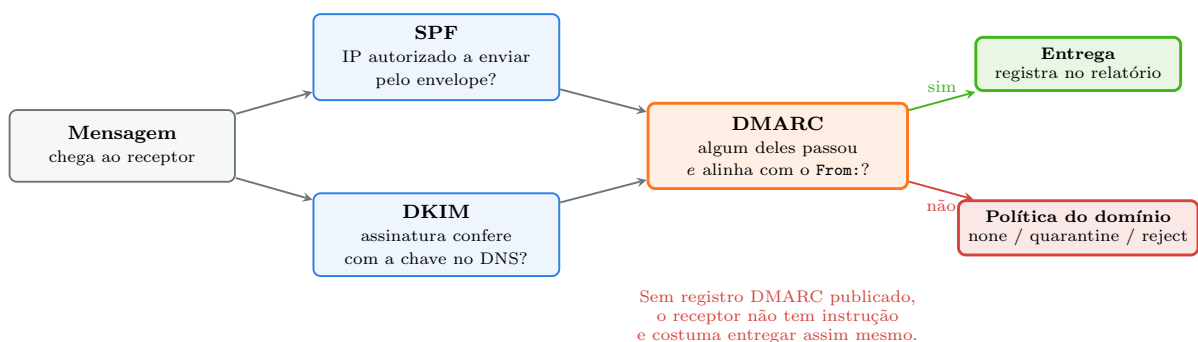


Figura 10.2.: Verificação de autenticidade de e-mail. O alinhamento com o **From:** exibido é a peça que só o DMARC fornece.

A publicação em p=none é o erro mais comum. É o ponto de partida correto — permite observar os relatórios sem quebrar fluxos legítimos —, mas muitas organizações param ali e acreditam estar protegidas. Enquanto a política não avançar para **quarantine** e depois **reject**, o receptor não recebe instrução para rejeitar nada. A publicação de **p=none** protege exatamente zero mensagens.

Vale ainda distinguir dois ataques que a defesa trata de forma diferente. A **falsificação direta do domínio** é o que SPF, DKIM e DMARC bloqueiam. O **domínio parecido** — `fornecedor-exemplo.com.br` no lugar de `fornecedor.exemplo.br`, ou caracteres visualmente similares — passa por todas as verificações, porque é um domínio legítimo do atacante, devidamente autenticado. Contra esse, os controles são outros: monitoramento de registros semelhantes, marcação visual de remetente externo no cliente de e-mail, e processo de negócio que exija confirmação por canal independente para mudança de dados bancários. O caso de abertura teria sido evitado por qualquer um dos três — e o Volume 10 trata do assunto em profundidade.

10.5. SNMP: a porta dos fundos do parque de equipamentos

O SNMP monitora e configura equipamentos de rede. É a fonte dos gráficos de banda e, quando mal configurado, o mapa completo da infraestrutura entregue a quem perguntar.

O problema está nas versões. **SNMPv1 e v2c autenticam por uma *community string*, que trafega em claro** e funciona como senha compartilhada. Duas delas vêm de fábrica em praticamente todo equipamento: `public` para leitura e `private` para escrita. Com leitura, o atacante obtém inventário de interfaces, tabela ARP, tabela de roteamento, versão de firmware, nomes de host, tempo de atividade — reconhecimento interno completo sem tocar em nenhum sistema. Com escrita, reconfigura o equipamento.

O SNMP é ainda um dos vetores clássicos de **amplificação** descritos no Capítulo 8: uma consulta `GetBulk` de poucos bytes gera resposta muitas vezes maior, e o serviço roda sobre UDP.

As três medidas, em ordem de prioridade: **migrar para SNMPv3** com `authPriv` (autenticação SHA e cifragem AES); onde o equipamento legado não suportar v3, **restringir por lista de acesso** ao endereço do coletor e usar apenas leitura, com *community* longa e única por equipamento; e **nunca expor o 161/UDP à internet**, o que ainda ocorre com frequência em roteadores de borda de provedores pequenos.

10.6. O inventário de protocolos: o exercício que ninguém faz

Fecha o capítulo o exercício mais revelador e menos praticado: listar o que efetivamente escuta na rede. Ele produz invariavelmente três descobertas — um serviço que ninguém sabia que estava ligado, um protocolo em claro que deveria ter sido desativado anos atrás, e um sistema exposto à internet por engano.

A ordem de tratamento que funciona é por consequência:

1. **Administração em claro exposta** — Telnet, HTTP de painel, SNMP v2c com escrita. Sessão administrativa capturada é comprometimento imediato.
2. **Autenticação em claro** — FTP, POP3, IMAP, LDAP sem TLS. Credenciais capturadas costumam ser reutilizadas em outros sistemas.
3. **Serviços amplificadores abertos** — DNS recursivo, NTP, SNMP, memcached. Aqui a vítima é um terceiro, mas a responsabilidade e a reputação do bloco são da organização.
4. **Serviços legítimos sem TLS** — o resto.

10.7. Brasil em Foco

A fraude do caso de abertura tem nome e tipo penal. O golpe do boleto e a fraude do e-mail corporativo (*BEC*) configuram estelionato, e desde a Lei 14.155/2021 o art. 171, §2º-A do Código Penal prevê pena de reclusão de 4 a 8 anos quando praticado por meio eletrônico (Brasil, 2021). A pena aumenta quando a vítima é idosa. Para a empresa que pagou, resta a via civil — e a discussão sobre quem tinha o dever de cuidado costuma envolver justamente a ausência de SPF, DKIM e DMARC no domínio do fornecedor.

Domínio .br e o registro.br. Registro de domínio e publicação de SPF, DKIM e DMARC são feitos no painel do registro.br, e a proteção da conta de registrador é crítica: é o ponto 3 da Figura 10.1, e o comprometimento dessa conta permite redirecionar e-mail e site do domínio inteiro. Segundo fator obrigatório nessa conta e nas contas de DNS não é recomendação, é requisito básico.

Registro de consultas DNS é dado pessoal. O histórico de resolução de um assinante revela hábitos, saúde, orientação política e religiosa — dado potencialmente sensível no sentido do art. 5º, II da LGPD (Brasil, 2018). Um provedor que registra consultas precisa de base legal, finalidade declarada, prazo de retenção e controle de acesso. Usar esse registro para fins comerciais, como perfilamento publicitário, exige base legal própria e esbarra também na neutralidade de rede do art. 9º do Marco Civil (Brasil, 2014).

Bloqueio de porta 25 e o combate ao spam. A gestão da porta 25, coordenada no Brasil pelo CGI.br e pelo CERT.br desde 2012, é caso de política pública técnica bem-sucedida: o encaminhamento de mensagens passou a usar a porta 587 com autenticação, e a saída direta pela 25 a partir de redes de acesso residencial foi bloqueada. Provedores que não aplicam a medida veem seus blocos entrarem em listas de bloqueio internacionais, com prejuízo para todos os assinantes — inclusive os que não têm relação alguma com o problema.

Anatel e a segurança do equipamento do assinante. A Resolução 740/2020 alcança os produtos de telecomunicações fornecidos ao cliente (Agência Nacional de Telecomunicações, 2020). Roteadores entregues com senha padrão, painel de administração acessível pela WAN ou SNMP aberto são, além de risco técnico, exposição regulatória do provedor — e foram vetor de campanhas em larga escala de alteração de DNS de assinantes no Brasil, exatamente o ponto 1 da Figura 10.1.

10.8. No Campo

1. Publicar SPF, DKIM e DMARC — e avançar a política. Vinte minutos que fecham a falsificação direta do domínio:

```
; SPF - encerrar com -all, nunca com ?all
exemplo.com.br.      IN TXT "v=spf1 include:_spf.provedor.exemplo.br -all"

; DMARC - começar em none para observar, avançar em semanas
_dmarc.exemplo.com.br. IN TXT "v=DMARC1; p=none;
↪  rua=mailto:dmARC@exemplo.com.br; pct=100"
; depois: p=quarantine; pct=25 → pct=100 → p=reject
```

```
# Conferir o que está publicado hoje
dig +short TXT exemplo.com.br | grep spf1
dig +short TXT _dmarc.exemplo.com.br
dig +short TXT selecao._domainkey.exemplo.com.br
```

2. Levantar o inventário de portas abertas na borda. O exercício que sempre encontra surpresa. Executado a partir de fora, contra o próprio bloco e **com autorização escrita**, conforme o Capítulo 7:

```
# Serviços administrativos e amplificadores expostos no bloco
nmap -sS -Pn -p 21,22,23,25,53,80,110,143,161,389,443,445,3389,8080
↪ 198.51.100.0/24 -oA borda
nmap -sU -Pn -p 53,123,161,1900,11211 198.51.100.0/24 -oA borda-udp
```

3. Checar os cabeçalhos de segurança das aplicações web internas. Vale para o painel do switch tanto quanto para o sistema de chamados:

```
curl -sI https://app.exemplo.com.br | \
  grep -iE
↪ 'strict-transport|content-security|x-content-type|x-frame|referrer-policy|set-cookie'
```

4. Migrar SNMP para v3 e fechar o que sobrar. Prioridade máxima onde houver escrita habilitada:

```
! Substitui community por usuário com autenticação e cifragem
snmp-server group MONITORA v3 priv
snmp-server user coletor MONITORA v3 auth sha <senha-auth> priv aes 128
↪ <senha-priv>
no snmp-server community public
no snmp-server community private
snmp-server host 10.30.20.9 version 3 priv coletor
```

5. Registrar as consultas DNS e vigiar os indicadores de tunelamento. É a fonte de detecção mais barata que existe:

```
# No resolvidor: domínios com muitas consultas e rótulos longos
awk '{print $NF}' /var/log/dns/queries.log \
  | awk -F. '{print $(NF-1)}' "$NF, length($1)}' \
  | sort | uniq -c | sort -rn | head -20

# Proporção de NXDOMAIN por cliente - pico indica DGA ou túnel
grep NXDOMAIN /var/log/dns/queries.log | awk '{print $3}' | sort | uniq -c |
↪ sort -rn | head
```

6. Oferecer DoH e DoT internos em vez de bloquear. Preserva a privacidade do usuário contra terceiros e mantém a visibilidade e o filtro na organização. Na prática: publicar o resolvidor interno como DoH, distribuí-lo por política nos navegadores e bloquear na borda os resolvidores externos conhecidos.

7. Desativar os protocolos em claro com prazo, não com boa intenção. Um inventário com data de desligamento por sistema, comunicado aos donos, e a porta efetivamente fechada no dia marcado. Sem prazo, Telnet sobrevive a três trocas de gerência.

8. Exigir confirmação por canal independente para mudança de dados bancários. É o controle de processo que teria evitado os R\$ 180 mil do caso de abertura, e não custa nada: qualquer alteração de conta de fornecedor é confirmada por telefone, num número já cadastrado — nunca no número que veio no e-mail.

10.9. Resumo

- Os protocolos fundamentais da internet são **textuais, não autenticam origem e não verificam integridade**. TLS resolve confidencialidade e integridade em trânsito, mas cada protocolo tem um problema estrutural próprio que o TLS não alcança.
- No **HTTP**, os cabeçalhos de resposta (HSTS, CSP, **nosniff**, **X-Frame-Options**, atributos de cookie) são controles baratos e sistematicamente ausentes em sistemas internos. Como o protocolo não tem estado, quem obtém o identificador de sessão é o usuário.
- No **DNS**, há quatro pontos de subversão — resolvente do host, cache do recursivo, conta no registrador e servidor autoritativo — e o DNSSEC só cobre o segundo. **DNSSEC dá integridade, não confidencialidade**; DoT e DoH dão confidencialidade e, se forem externos, custam ao operador o seu melhor sensor.
- O DNS é ao mesmo tempo a **fonte de detecção mais custo-eficiente** e o canal de **exfiltração** mais confiável. Os indicadores de tunelamento são reconhecíveis: rótulos longos, alta entropia, excesso de **NXDOMAIN**, uso intenso de **TXT**.
- No **SMTP** existem dois remetentes, e só o exibido chega ao usuário. SPF verifica o envelope, DKIM assina o conteúdo, e apenas o **DMARC** amarra os dois ao **From**: exibido e publica a política. **p=none não protege nenhuma mensagem** — é ponto de partida, não de chegada. Contra domínio parecido, a defesa é processo, não protocolo.
- **SNMP v1 e v2c entregam o mapa da infraestrutura** a quem souber a *community* — que é **public** na fábrica, trafega em claro e ainda serve de amplificador. SNMPv3 com **authPriv**, lista de acesso e nunca exposto à internet.
- O **inventário de protocolos** é o exercício mais revelador e menos praticado. Trata-se por consequência: administração em claro, autenticação em claro, amplificadores abertos, e só então o resto.

11. Fundamentos de sistemas operacionais: processos, permissões e memória

Um analista abre um chamado de rotina: o servidor de arquivos está com uso de CPU acima do normal desde a madrugada. O `top` mostra um processo chamado `httpd-worker` consumindo 90% de um núcleo. Parece o servidor web. Não é: o servidor web da casa é o `nginx`, e ninguém instalou Apache naquela máquina.

O processo roda como o usuário `www-data`, o mesmo do `nginx`. Foi iniciado às 3h14, tem como pai um processo que já morreu, e seu executável foi apagado do disco — o arquivo continua acessível apenas através de `/proc/<pid>/exe`, marcado como `(deleted)`. O diretório de trabalho é `/tmp`. Ele mantém uma conexão TCP estabelecida com um endereço na Holanda, na porta 443.

Cada um desses detalhes é uma propriedade do sistema operacional: identidade de processo, herança de pai, descritor de arquivo que sobrevive ao arquivo, contexto de usuário, espaço de memória. Quem não conhece esses conceitos vê um processo estranho. Quem conhece lê, em dois minutos, a história inteira de um comprometimento — inclusive como ele começou e o que ele consegue alcançar a seguir.

Os três capítulos anteriores trataram da rede. Os quatro seguintes tratam da máquina. Este é o alicerce conceitual comum a Linux e Windows; o Capítulo 12 e o Capítulo 13 descem ao específico de cada um.

11.1. O anel de proteção: a fronteira que sustenta tudo

Processadores modernos executam código em pelo menos dois níveis de privilégio. Em **modo núcleo** (anel 0), o código acessa qualquer endereço de memória, fala diretamente com o hardware e altera as tabelas que controlam tudo. Em **modo usuário** (anel 3), cada programa vê apenas a memória que o núcleo lhe concedeu e não toca em hardware.

Essa separação é a fundação de toda a segurança de um sistema operacional. Dela decorrem três consequências:

A única passagem entre os modos é a chamada de sistema. Para ler um arquivo, abrir um socket ou criar um processo, o programa precisa pedir ao núcleo. Esse pedido é o ponto onde toda decisão de autorização é tomada — e, não por acaso, é onde antivírus, EDR e ferramentas de auditoria se instalam para observar. O Volume 6 trata de como isso é feito na prática.

Um defeito no núcleo derruba toda a proteção. Uma falha em código de anel 0 — driver, módulo, subsistema de arquivos — dá controle total. É por isso que uma vulnerabilidade de escalonamento local no núcleo é tratada com a mesma gravidade de uma remota: ela transforma qualquer acesso mínimo em domínio da máquina.

O núcleo é a superfície de ataque menos visível. Um *rootkit* que consiga executar em anel 0 mente para todas as ferramentas que rodam em anel 3, inclusive para o antivírus. Daí a importância de mecanismos que verificam a integridade do próprio núcleo — inicialização verificada, assinatura obrigatória de módulos, integridade protegida por virtualização.

11.2. Processos: identidade, herança e contexto

Um **processo** é um programa em execução com seu próprio espaço de endereçamento. Do ponto de vista de segurança, o que importa não é o código que ele executa, e sim o **contexto** em que executa: quem ele é, o que herdou e o que pode alcançar.

11.2.1. A árvore genealógica

Todo processo (exceto o primeiro) é criado por outro, e a relação pai-filho é a estrutura mais reveladora numa investigação. A pergunta que resolve a maioria dos casos é sempre a mesma: *quem chamou isso?*

Um interpretador de comandos cujo pai é um editor de planilhas é anomalia grave — significa que uma macro executou. Um processo de rede cujo pai é um serviço de impressão idem. Regras de detecção comerciais e abertas são, em boa medida, catálogos de pares pai-filho que não deveriam existir; o Volume 12 trata de escrevê-las.

Quando o pai termina antes do filho, o filho é adotado pelo processo inicial do sistema. Isso apaga o rastro da origem — exatamente o que aconteceu no caso de abertura — e é técnica comum tanto de daemons legítimos quanto de código malicioso.

11.2.2. Identidade e o bit que muda tudo

Cada processo carrega identificadores de usuário e de grupo que determinam o que ele pode acessar. O modelo Unix distingue o identificador **real** (quem iniciou) do **efetivo** (o usado nas verificações de permissão). A diferença entre os dois é a base do mecanismo de elevação — e da sua exploração.

O bit **SUID** faz um executável rodar com a identidade do seu dono, não de quem o executou. Existe por necessidade legítima: `passwd` precisa escrever em `/etc/shadow`, que só o root pode alterar. E é, simultaneamente, uma das superfícies de escalonamento local mais exploradas que existem. Um binário SUID de root com qualquer falha — estouro de buffer, injeção de argumento, confiança numa variável de ambiente, chamada a um programa externo por caminho relativo — entrega o sistema.

A regra operacional é direta: **o inventário de binários SUID de uma máquina deve ser conhecido, pequeno e estável**. Um SUID novo que aparece sem explicação é indicador de comprometimento de alta confiança, e é o primeiro lugar onde se olha depois de um acesso suspeito.

O Windows resolve o mesmo problema de forma diferente, com *tokens* de acesso que carregam a identidade, os grupos e uma lista de **privilégios** nomeados. Alguns desses privilégios equivalem, na prática, a ser administrador: `SeDebugPrivilege` permite abrir qualquer processo e ler sua memória; `SeImpersonatePrivilege` permite assumir a identidade de outro usuário; `SeBackupPrivilege` permite ler qualquer arquivo ignorando as permissões. Conceder esses privilégios a uma conta de serviço é conceder administração por caminho indireto — e é assim que boa parte das escaladas em ambiente Windows acontece, como o Capítulo 13 detalha.

11.3. Permissões: dois modelos para o mesmo problema

O controle de acesso a arquivos resolve a mesma questão em Unix e Windows com filosofias distintas. A Figura 11.1 compara as duas.

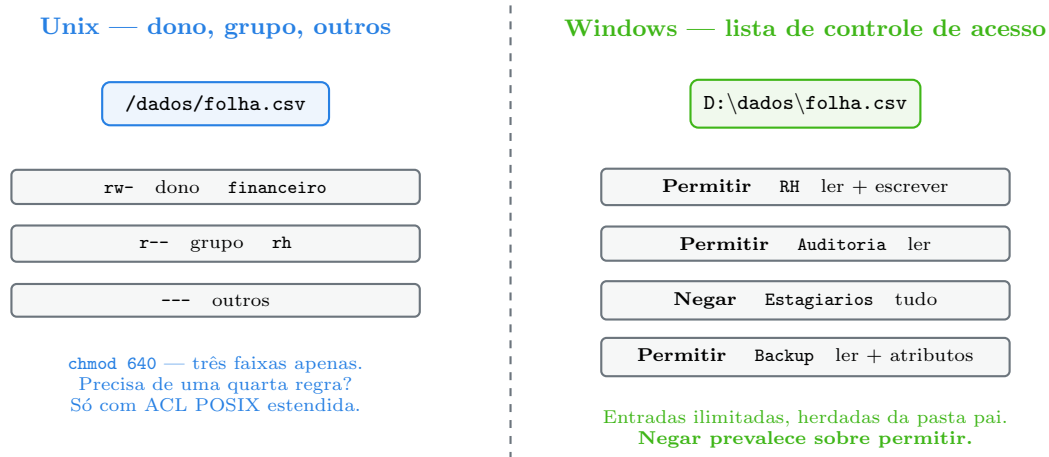


Figura 11.1.: Os dois modelos de permissão. O Unix é simples e enxuto; o do Windows é expressivo e difícil de auditar.

O modelo Unix cabe em nove bits e é fácil de auditar em massa; sua limitação é não expressar “este grupo lê, aquele escreve, aquele outro não vê” sem recorrer a ACLs estendidas. O modelo Windows expressa qualquer política, ao custo de uma complexidade que, na prática, produz permissões efetivas que ninguém consegue enunciar — especialmente com herança em árvores de pastas profundas e grupos aninhados.

Dois detalhes causam a maioria dos erros reais:

A permissão de execução em diretório significa “atravessar”, não “executar”. Sem ela não se acessa nada abaixo, mesmo com leitura no arquivo. Com ela e sem leitura no diretório, acessa-se um arquivo cujo nome já se conhece, mas não se lista o conteúdo — propriedade útil para diretórios que devem ser alcançáveis sem serem enumeráveis.

A permissão do diretório governa a criação e a exclusão, não a do arquivo. Quem tem escrita num diretório pode apagar arquivos dele mesmo sem qualquer permissão sobre esses arquivos. É o motivo de existir o *sticky bit* em `/tmp`: sem ele, qualquer usuário apagaria os arquivos temporários de todos os outros.

E há o erro clássico que aparece em toda auditoria: `chmod 777`. É a resposta rápida para “não estou conseguindo acessar” e significa que qualquer usuário do sistema — inclusive o processo web comprometido do caso de abertura — pode ler, alterar e apagar aquele arquivo. Em diretório com script executado por serviço, é escalonamento de privilégio servido em bandeja.

11.4. Memória: onde a exploração acontece

O núcleo dá a cada processo um espaço de endereçamento virtual próprio, traduzido para memória física por tabelas que só o anel 0 altera. Isso garante isolamento: um processo não enxerga a memória de outro. A Figura 11.2 mostra a organização típica desse espaço.

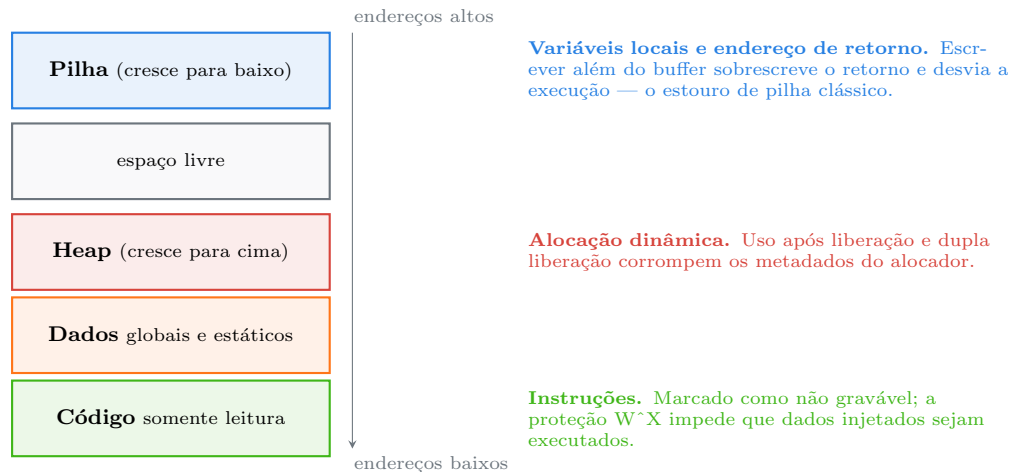


Figura 11.2.: Espaço de endereçamento de um processo e as regiões onde a corrupção de memória ocorre.

11.4.1. Por que a corrupção de memória vira execução de código

Linguagens como C e C++ não verificam limites de vetor. Se um programa reserva 64 bytes para um nome e copia 200, os 136 excedentes sobrescrevem o que estiver adiante — que, na pilha, inclui o **endereço de retorno** da função. Controlando esse endereço, o atacante controla para onde a execução desvia quando a função termina.

Este manual não ensina a construir o desvio — o Capítulo 7 fixou essa fronteira, e o Volume 9 trata do assunto no nível conceitual necessário para entender e detectar. O que interessa aqui é a cadeia de mitigações que a indústria construiu, porque **entender por que cada uma existe é entender por que todas precisam estar ligadas**:

Tabela 11.1.: Mitigações de corrupção de memória e seus limites.

Mitigação	O que faz	O que a contorna
Canário de pilha	Valor sentinela antes do endereço de retorno; alterado, aborta	Vazamento de memória que revela o canário
DEP / NX (W^X)	Páginas graváveis não são executáveis	Reúso de código já presente (ROP)
ASLR	Randomiza posições de pilha, heap e bibliotecas	Vazamento de endereço; entropia baixa em 32 bits
PIE	Randomiza também o executável	Idem
RELRO	Torna a tabela de relocação somente leitura	—
CFI	Restringe destinos de desvio indireto	Cadeias dentro dos destinos válidos
Linguagem com memória segura	Elimina a classe inteira de falhas	Blocos unsafe , dependências em C

Duas conclusões práticas. A primeira: **nenhuma mitigação isolada resolve**; cada uma eleva o custo, e a defesa vem da combinação. A segunda: essas proteções precisam ser **ativadas na**

compilação, e software antigo ou binário proprietário mal empacotado frequentemente não as tem. Verificar isso num binário é tarefa de dois comandos, e está no fim do capítulo.

A tendência de fundo é a migração para linguagens com memória segura. Levantamentos consistentes de grandes bases de código — Microsoft, Google, projetos do núcleo Linux — apontam que aproximadamente **dois terços das vulnerabilidades graves são falhas de segurança de memória**, e recomendações oficiais recentes empurram nessa direção para software novo. Não é solução para o que já existe, mas muda a conta para o que vai ser escrito.

11.4.2. Segredos vivem em memória

Consequência menos óbvia e muito explorada: **tudo que um processo usa está em claro na sua memória**, por melhor que seja a criptografia em disco e em trânsito. Senhas digitadas, chaves privadas carregadas, tokens de sessão, o conteúdo descriptografado de um banco — tudo passa por ali.

Por isso o privilégio de depuração é tão sensível: quem pode ler a memória de outro processo lê seus segredos sem quebrar nenhuma cifra. É o mecanismo por trás das ferramentas que extraem credenciais do processo de autenticação do Windows, e por trás da extração de chaves de um processo de servidor web. As defesas são de contenção — restringir quem tem o privilégio, isolar processos sensíveis, usar módulos de hardware que nunca expõem a chave, e limpar buffers sensíveis após o uso.

11.5. Isolamento: quando o processo não basta

A separação entre processos é boa, mas grosseira demais para muitos casos. Um servidor web comprometido tem, por padrão, acesso a todo o sistema de arquivos legível pelo seu usuário. Daí a construção de camadas adicionais:

Redução de privilégio. Cada serviço com seu próprio usuário sem interpretador de comandos e sem diretório pessoal. Barato, eficaz e ainda assim frequentemente ignorado — serviços rodando como root “porque era mais fácil” são achado comum em qualquer auditoria.

Capacidades. O Linux fatiou os poderes de root em dezenas de capacidades independentes. Um servidor que precisa apenas abrir a porta 80 recebe `CAP_NET_BIND_SERVICE` em vez de ser root inteiro. Vale conhecer as que equivalem a root: `CAP_SYS_ADMIN` (chamada de “a nova root” com razão), `CAP_SYS_PTRACE`, `CAP_SYS_MODULE`, `CAP_DAC_OVERRIDE`.

Espaços de nomes e cgroups. A base dos contêineres: o processo vê apenas um subconjunto de PIDs, montagens, interfaces de rede e usuários, com limites de recurso. Isolamento útil, mas **compartilhando o mesmo núcleo** — uma falha de anel 0 atravessa a fronteira. O Volume 8 trata das implicações.

Filtragem de chamadas de sistema. O `seccomp` restringe quais chamadas um processo pode fazer. Se o serviço nunca precisa de `ptrace` nem de `mount`, negá-las reduz o que uma exploração bem-sucedida consegue fazer em seguida.

Controle de acesso obrigatório. SELinux e AppArmor impõem política que o dono do arquivo não pode relaxar — o modelo MAC que o Volume 4 detalha. Curva de aprendizado real, e o único mecanismo que contém um processo root comprometido.

Virtualização. Fronteira mais forte, com núcleo separado por máquina. É o assunto do Capítulo 14.

O princípio que organiza a lista é o do **menor privilégio**, formulado por Saltzer e Schroeder em 1975 (Saltzer; Schroeder, 1975) e citado no Capítulo 1: cada componente recebe exatamente o necessário para sua função, e nada além. A lista acima é a caixa de ferramentas para aplicá-lo de fato.

11.6. Lendo o que a máquina conta

Voltando ao caso de abertura: o que permitiu ler a situação em dois minutos foi saber onde o sistema operacional guarda cada resposta.

Tabela 11.2.: As sete perguntas de triagem de um processo suspeito.

Pergunta	Onde está	O que revela
Quem iniciou este processo?	PID pai, linha de comando do pai	Origem do comprometimento
Sob que identidade ele roda?	UID efetivo, grupos, token	O que ele alcança agora
Qual binário ele executa?	<code>/proc/<pid>/exe</code> , imagem do processo	Executável apagado é sinal forte
Que arquivos ele mantém abertos?	<code>/proc/<pid>/fd</code> , handles	Dados sendo lidos ou escritos
Com quem ele fala?	Sockets do processo	Comando e controle
O que está na memória dele?	Mapas de memória, regiões graváveis e executáveis	Código injetado
Ele sobrevive a um reinício?	Unidades de serviço, tarefas agendadas, chaves de execução	Persistência

Um detalhe importante para a resposta a incidentes, e que o Volume 13 aprofunda: **desligar a máquina destrói a maior parte dessas respostas**. Memória é volátil; conexões desaparecem; o executável apagado, que só existe como descritor aberto, some para sempre. A ordem correta é preservar antes de conter.

11.7. Brasil em Foco

Registro de comando com privilégio e o não repúdio. O Capítulo 3 tratou de responsabilização; aqui ela vira configuração. Contas administrativas compartilhadas — o **root** que três pessoas usam, o **Administrador** cuja senha está num bilhete — destroem a possibilidade de atribuir uma ação a uma pessoa. Isso enfraquece qualquer apuração interna, prejudica a defesa da organização num processo trabalhista e compromete a resposta a requisições judiciais. Acesso nominal com elevação registrada é o requisito mínimo.

Dados pessoais em memória e a notificação de incidente. Se um processo comprometido tinha em memória dados pessoais de clientes, houve tratamento irregular sob a LGPD (Brasil, 2018). A Resolução CD/ANPD nº 15/2024 estabelece prazo e conteúdo da comunicação de incidente de segurança à autoridade e aos titulares (Autoridade Nacional de Proteção de Dados, 2024), e a avaliação sobre “que dados foram alcançados” depende diretamente das evidências da Tabela 11.2 — coletadas **antes** de desligar a máquina. Quem desliga primeiro perde a capacidade de dizer o que aconteceu, e a resposta “não sabemos” não é aceitável perante a ANPD.

Preservação de evidência é obrigação, não zelo. O art. 13 do Marco Civil trata da guarda de registros de conexão (Brasil, 2014); o Código de Processo Penal e a Convenção de Budapeste, promulgada pelo Decreto nº 11.491/2023 (Brasil, 2023), tratam da preservação expedita de dados. Uma organização que recebe pedido de preservação e já reinstalou o servidor comprometido tem um problema jurídico além do técnico. Procedimento escrito de resposta que inclua “coletar memória e estado antes de qualquer contenção destrutiva” resolve os dois.

Software sem manutenção é risco jurídico e não apenas técnico. Sistema que não recebe correção não tem as mitigações da Tabela 11.1 e acumula falhas conhecidas. Sob a LGPD, os arts. 46 e 47 exigem medidas de segurança aptas a proteger os dados; a ANPD já sinalizou, em guia orientativo dirigido a agentes de pequeno porte (Autoridade Nacional de Proteção de Dados, 2023), que manter software atualizado é medida básica esperada. Rodar sistema fora de suporte com dados pessoais é decisão que precisa estar documentada, com controles compensatórios, ou é exposição pura.

11.8. No Campo

1. Fazer a triagem de processo suspeito na ordem certa. As sete perguntas da Tabela 11.2, sem desligar nada:

```
PID=1234
ls -l /proc/$PID/exe          # (deleted) é sinal forte
ls -l /proc/$PID/cwd
tr '\0' ' ' < /proc/$PID/cmdline; echo
grep -E 'Uid|Gid|PPid|Threads' /proc/$PID/status
ls -l /proc/$PID/fd | head -40
ss -tanp | grep "pid=$PID"
grep -E 'rwx' /proc/$PID/maps  # região gravável e executável: suspeita de
↪ injeção
```

```
# Windows: pai, linha de comando e dono do processo
Get-CimInstance Win32_Process -Filter "ProcessId=1234" |
  Select-Object ProcessId, ParentProcessId, CommandLine, ExecutablePath
Get-NetTCPConnection -OwningProcess 1234
```

2. Manter o inventário de binários SUID e comparar periodicamente. Um SUID novo é indicador de alta confiança:

```
# Linha de base, guardada fora da máquina
find / -xdev \( -perm -4000 -o -perm -2000 \) -type f -printf '%m %u %g %p\n' \
  2>/dev/null | sort > /var/lib/baseline/suid.txt

# Comparação na rotina
diff <(find / -xdev \( -perm -4000 -o -perm -2000 \) -type f -printf '%m %u %g
↪ %p\n' \
  2>/dev/null | sort) /var/lib/baseline/suid.txt
```

3. Caçar permissões frouxas antes que alguém as encontre. 777 em diretório de script executado por serviço é escalonamento pronto:

11. Fundamentos de sistemas operacionais: processos, permissões e memória

```
# Arquivos e diretórios graváveis por todos, fora das áreas temporárias
find / -xdev -perm -0002 ! -type l ! -path '/proc/*' ! -path '/tmp/*' \
    ! -path '/var/tmp/*' -printf '%m %p\n' 2>/dev/null | sort | head -40

# Diretórios de escrita geral sem sticky bit - qualquer um apaga arquivo alheio
find / -xdev -type d -perm -0002 ! -perm -1000 2>/dev/null
```

4. Verificar se os binários em produção têm as mitigações ligadas. Software interno compilado há anos costuma não ter:

```
# NX, PIE, RELRO, canário - o ideal é tudo habilitado
readelf -lW /usr/local/bin/app | grep -E 'GNU_STACK|GNU_RELRO'
readelf -hW /usr/local/bin/app | grep Type          # DYN = PIE, EXEC = sem PIE
nm -D /usr/local/bin/app 2>/dev/null | grep -c stack_chk
```

5. Reduzir o privilégio dos serviços com o que o systemd já oferece. Ganho grande, esforço pequeno, sem tocar na aplicação:

```
[Service]
User=app
Group=app
NoNewPrivileges=yes
PrivateTmp=yes
ProtectSystem=strict
ProtectHome=yes
ReadWritePaths=/var/lib/app
CapabilityBoundingSet=CAP_NET_BIND_SERVICE
SystemCallFilter=@system-service
RestrictAddressFamilies=AF_INET AF_INET6 AF_UNIX
```

6. Restringir quem pode ler a memória de outro processo. Contenção direta contra extração de credenciais:

```
# Linux: só o processo pai pode depurar um filho
sysctl -w kernel.yama.ptrace_scope=1
echo 'kernel.yama.ptrace_scope = 1' > /etc/sysctl.d/10-pttrace.conf
```

```
# Windows: quem tem privilégios equivalentes a administração
whoami /priv | Select-String 'SeDebug|SeImpersonate|SeBackup|SeTakeOwnership'
```

7. Auditar contas de serviço com privilégios perigosos. No Windows, SeDebugPrivilege, SeImpersonatePrivilege e SeBackupPrivilege concedidos a conta de serviço são administração por via indireta. A revisão é anual, no mínimo, e entra na mesma rotina que revisa membros de grupos administrativos.

8. Escrever o procedimento de preservação antes do incidente. Uma página: coletar memória e estado (processos, conexões, descritores abertos) **antes** de conter, onde guardar, quem autoriza, como registrar a cadeia de custódia. Sem isso, a primeira reação do plantão será reiniciar o servidor — e com ele, a evidência.

11.9. Resumo

- A separação entre **modo núcleo e modo usuário** é a fundação de toda segurança de sistema operacional. A chamada de sistema é a única passagem entre eles e o ponto onde a autorização é decidida; uma falha em anel 0 anula todas as demais proteções.
- O que importa num processo é o **contexto**: quem o criou, sob que identidade roda, o que herdou. A relação **pai-filho** é a estrutura mais reveladora numa investigação, e órfãos apagam o rastro da origem.
- **SUID no Unix e privilégios de token no Windows** são os mecanismos legítimos de elevação e as principais superfícies de escalonamento local. O inventário de SUID deve ser pequeno, conhecido e estável; `SeDebugPrivilege`, `SeImpersonatePrivilege` e `SeBackupPrivilege` equivalem a administração.
- Os dois modelos de permissão trocam simplicidade por expressividade. Dois detalhes explicam a maioria dos erros: execução em diretório significa **atravessar**, e é a permissão do **diretório** que governa criação e exclusão. `chmod 777` é escalonamento servido pronto.
- A **corrupção de memória** vira execução de código porque o endereço de retorno é dado gravável. As mitigações — canário, DEP/NX, ASLR, PIE, RELRO, CFI — só funcionam **em conjunto**, precisam ser ativadas na compilação, e cerca de dois terços das falhas graves pertencem a essa classe, que linguagens com memória segura eliminam de origem.
- **Tudo que um processo usa está em claro na memória dele**. Criptografia em disco e em trânsito não protege contra quem tem privilégio de depuração — daí a sensibilidade desse privilégio e a existência de módulos de hardware que nunca expõem a chave.
- O isolamento além do processo é uma escada: usuário próprio, capacidades, espaços de nomes, `seccomp`, MAC (SELinux/AppArmor) e virtualização. Todos são formas de aplicar o **menor privilégio**; contêineres compartilham o núcleo, e uma falha de anel 0 atravessa essa fronteira.
- Numa triagem, sete perguntas resolvem quase tudo — e **desligar a máquina destrói a maior parte das respostas**. Preservar antes de conter é requisito técnico e, no Brasil, também condição para responder à ANPD e a pedidos de preservação.

12. Linux essencial para segurança

Servidor de aplicação de um provedor, sexta-feira de tarde. O monitoramento acusa que a partição raiz encheu. O plantonista entra, roda `du` e encontra 40 GB num arquivo dentro de `/var/tmp` com nome de seis caracteres aleatórios. Apaga o arquivo, o espaço não volta. Reinicia o serviço, o espaço volta — e o arquivo reaparece dez minutos depois.

O que estava acontecendo cabe em três fatos do sistema operacional. O espaço não voltou porque um processo ainda mantinha o arquivo aberto, e no Linux o espaço só é liberado quando o último descritor fecha. O arquivo reapareceu porque havia uma entrada no `cron` de um usuário de serviço, criada três semanas antes. E o processo que escrevia era um minerador, rodando como `www-data`, iniciado por uma falha na aplicação web.

Nenhum desses fatos exige ferramenta especial. Todos são visíveis com comandos que já estão instalados em qualquer distribuição. O problema é que quem não sabe onde olhar apaga o arquivo, vê o espaço “não voltar”, reinicia o servidor e considera o caso encerrado — deixando a persistência intacta.

Este capítulo é o mapa operacional do Linux para quem faz segurança: onde as coisas ficam, como o sistema arranca, como usuários e permissões funcionam de verdade, o que os registros contam e quais são os quinze comandos que resolvem 90% da triagem. O Capítulo 11 deu o modelo conceitual; aqui ele vira caminho de arquivo.

12.1. O sistema de arquivos como mapa mental

Tudo no Linux é um caminho a partir de `/`. Discos, dispositivos, processos, parâmetros do núcleo — tudo aparece como arquivo. Para segurança, os diretórios que importam são poucos:

Tabela 12.1.: Diretórios que importam numa investigação.

Caminho	O que guarda	Por que interessa
<code>/etc</code>	Configuração do sistema	Onde as políticas moram e onde alterações indevidas aparecem
<code>/var/log</code>	Registros	A primeira parada de qualquer investigação
<code>/home</code> , <code>/root</code>	Dados de usuário	<code>.ssh/authorized_keys</code> , histórico de comandos
<code>/tmp</code> , <code>/var/tmp</code> , <code>/dev/shm</code>	Áreas temporárias graváveis por todos	Ponto de largada favorito de código malicioso
<code>/proc</code>	Estado do núcleo e dos processos	A verdade sobre processos, sem intermediários
<code>/etc/systemd</code> , <code>/etc/cron*</code>	Serviços e agendamentos	Onde a persistência é instalada
<code>/usr/bin</code> , <code>/usr/sbin</code>	Binários do sistema	Binário alterado ou novo é achado grave

Caminho	O que guarda	Por que interessa
/opt, /srv	Aplicações e dados de serviço	Onde a aplicação vulnerável costuma estar

Três propriedades do sistema de arquivos explicam comportamentos que confundem quem está começando.

O nome do arquivo não é o arquivo. O que existe de fato é o **inode**, com os dados e os metadados; o nome é apenas um ponteiro num diretório. Por isso apagar não libera espaço enquanto houver processo com o arquivo aberto — foi o que aconteceu no caso de abertura — e por isso um binário malicioso pode continuar executando depois de removido do disco, acessível apenas por `/proc/<pid>/exe`.

Marcas temporais mentem parcialmente. Cada inode guarda **atime** (último acesso), **mtime** (última alteração de conteúdo) e **ctime** (última alteração de metadados). As duas primeiras podem ser reescritas por quem tem permissão; o **ctime** não pode ser definido diretamente e muda quando qualquer coisa muda — inclusive quando alguém tenta forjar as outras duas. Um arquivo cujo **mtime** é de 2019 e cujo **ctime** é de ontem está com data adulterada, e essa discrepância é achado forense de alto valor.

Áreas graváveis por todos são o ponto de partida padrão. `/tmp`, `/var/tmp` e `/dev/shm` são os únicos lugares onde qualquer usuário escreve. Montá-los com `noexec,nosuid,nodev` quebra uma parcela significativa de código malicioso automatizado, que assume poder executar dali.

12.2. Como a máquina arranca — e onde a persistência mora

A sequência é `firmware` → carregador de inicialização (GRUB) → núcleo → `initramfs` → `systemd` → alvo padrão. Em cada etapa há um ponto que interessa à segurança:

- **Firmware e Secure Boot** — assinaturas verificadas antes de qualquer código do sistema executar. É o que impede um *bootkit*.
- **GRUB** — se não tiver senha, quem tem acesso físico edita a linha de comando do núcleo, arranca em modo de usuário único e é root sem senha. Criptografia de disco é o que realmente resolve; senha no GRUB é a mitigação mínima.
- **Núcleo e módulos** — `lsmod` lista o que está carregado. Módulo desconhecido é candidato a *rootkit*. Assinatura obrigatória de módulos fecha essa porta.
- **systemd** — o gerenciador de serviços e, junto com o `cron`, o principal lugar onde persistência é instalada.

A Figura 12.1 reúne os mecanismos de persistência que uma triagem precisa verificar. A lista importa porque **a maioria das respostas a incidente falha aqui**: o processo malicioso é morto, a máquina é reiniciada, e o agendamento que o recria segue intacto.

12.3. Usuários, grupos e o que o sudo realmente permite

As contas vivem em `/etc/passwd` (legível por todos, sem senhas) e as senhas com sal e derivação em `/etc/shadow` (só root). Três leituras rápidas dizem muito sobre a higiene de uma máquina:

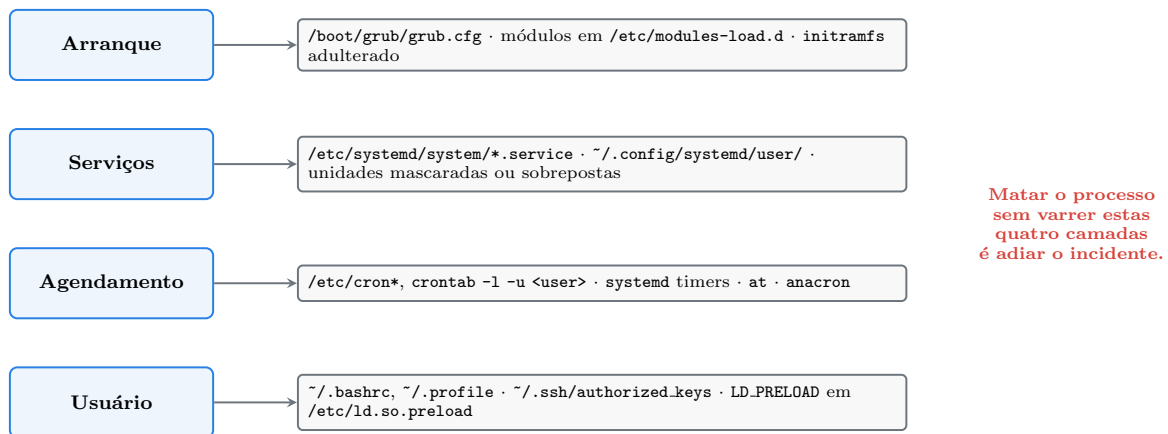


Figura 12.1.: Onde a persistência é instalada em Linux. A varredura precisa cobrir as quatro camadas.

- **Contas com UID 0 além do root.** Deveria haver exatamente uma. Qualquer outra é porta dos fundos.
- **Contas de serviço com interpretador de comandos.** Serviço não precisa de `shell`; `nologin` é o correto.
- **Contas com senha vazia ou sem expiração de credencial.** Achado comum em máquina herdada.

O **sudo** é o mecanismo de elevação, e a maior parte dos problemas está em como ele é configurado. Três armadilhas recorrentes:

NOPASSWD em comando que abre interpretador. Permitir `sudo vim`, `sudo less`, `sudo find`, `sudo awk` ou `sudo tar` sem senha é conceder root, porque todos esses programas executam comandos externos por desenho. A regra: se o binário permitido consegue chamar outro programa, a permissão equivale a acesso total.

Curinga em caminho. `sudo /usr/bin/systemctl restart *` permite muito mais do que reiniciar serviços, porque o argumento não é validado.

Script gravável. `sudo /opt/scripts/backup.sh` com o script gravável pelo usuário é root direto — basta editar o script. A verificação de permissões do alvo de uma regra `sudo` é parte da revisão.

Do lado da observabilidade, o **sudo** registra o que executa, e esse registro é a base da responsabilização discutida no Capítulo 3. Contas administrativas compartilhadas destroem essa cadeia; acesso nominal com elevação registrada é o requisito mínimo.

12.4. SSH: a porta principal

Em servidor Linux, o SSH costuma ser o único serviço administrativo exposto — e por isso concentra a maior parte das tentativas de acesso. A configuração segura cabe em poucas linhas e vale mais do que qualquer camada acrescentada depois:

```
# /etc/ssh/sshd_config - o essencial
PermitRootLogin no
PasswordAuthentication no
```

```

PubkeyAuthentication yes
KbdInteractiveAuthentication no
AllowGroups sysadmin
MaxAuthTries 3
LoginGraceTime 20
X11Forwarding no
AllowTcpForwarding no
ClientAliveInterval 300
ClientAliveCountMax 2

```

Quatro observações que a experiência de campo confirma. **Chave em vez de senha** elimina de uma vez a força bruta e a reutilização de credencial — e é a mudança de maior impacto isolado. **Mudar a porta padrão** reduz o ruído nos registros, mas não é controle de segurança: uma varredura encontra o serviço em qualquer porta, e o Volume 9 mostra como. **AllowGroups** é melhor que **AllowUsers**, porque a lista não precisa ser editada a cada admissão. E **authorized_keys** é **alvo de persistência**: uma chave acrescentada ali sobrevive a troca de senha, a reinstalação de aplicação e a quase toda resposta a incidente — daí a necessidade de compará-la periodicamente com uma linha de base.

12.5. Registros: o que o sistema conta

O Linux registra em dois lugares que coexistem: o **journal** binário do **systemd** e os arquivos de texto em **/var/log**. Os que importam:

Tabela 12.2.: Fontes de registro em Linux e o que cada uma responde.

Arquivo ou fonte	Conteúdo	O que procurar
journalctl	Tudo do systemd , incluindo o núcleo	Serviço que reinicia em laço; unidade desconhecida
/var/log/auth.log, secure	Autenticação, sudo, SSH	Falhas em rajada seguidas de sucesso
/var/log/syslog, messages	Sistema em geral	Mensagens do núcleo, montagens, USB
lastb, last, w	Tentativas e sessões	Login de origem inesperada ou fora de horário
auditd	Chamadas de sistema com regra	Acesso a arquivo sensível, execução privilegiada

Duas verdades desconfortáveis sobre registros locais. A primeira: **quem vira root apaga ou edita o que quiser**. Registro local é ponto de partida, não prova. A segunda: **a maioria das máquinas não registra o que importa**. Execução de comando, leitura de arquivo sensível e mudança de configuração não aparecem por padrão — é o **auditd** que os produz, e ele exige regras escritas.

A conclusão prática vale para toda a operação: **remessa de registro para fora da máquina, em tempo real**, é o que transforma registro em evidência. Uma máquina comprometida não pode ser a guardiã do seu próprio histórico. O Volume 12 trata de centralização e correlação; a decisão de arquitetura, contudo, é deste nível.

12.6. Rede vista de dentro da máquina

A pergunta mais frequente numa triagem é “o que esta máquina está expondo, e com quem ela fala?”. A resposta vem de três comandos, e a coluna do processo é a parte que interessa:

```
ss -tulpn          # o que escuta, e qual processo
ss -tanp state established  # conexões ativas, com PID
ip -br a; ip r     # endereços e rotas, formato compacto
```

Três achados recorrentes merecem atenção imediata. Um serviço escutando em 0.0.0.0 quando deveria estar em 127.0.0.1 — banco de dados, cache, painel administrativo — é exposição desnecessária e frequentemente involuntária. Uma conexão de saída persistente para endereço desconhecido, mantida por processo que não deveria falar com a internet, é o padrão de comando e controle. E um serviço escutando em porta alta sem processo identificável costuma indicar que a ferramenta está sendo enganada por um *rootkit*.

12.7. Os quinze comandos da triagem

O conjunto abaixo resolve a maior parte de uma primeira análise. Vale decorar a ordem, porque ela vai do mais volátil ao menos volátil:

```
# 1. Quem está conectado agora e o que executou
w; last -20; lastb -20

# 2. Processos por consumo, com árvore genealógica
ps auxf --sort=-%cpu | head -25

# 3. O que escuta e com quem fala
ss -tulpn; ss -tanp state established

# 4. Persistência: serviços, timers e agendamentos
systemctl list-units --type=service --state=running
systemctl list-timers --all
for u in $(cut -d: -f1 /etc/passwd); do crontab -l -u "$u" 2>/dev/null | sed
  ↪  "s/^/$u: /"; done
ls -la /etc/cron.d /etc/cron.* / 2>/dev/null

# 5. Arquivos recentes nas áreas graváveis por todos
find /tmp /var/tmp /dev/shm -type f -mmin -1440 -ls 2>/dev/null

# 6. Binários SUID fora do esperado
find / -xdev -perm -4000 -type f -ls 2>/dev/null

# 7. Chaves de acesso e contas privilegiadas
awk -F: '$3==0 {print $1}' /etc/passwd
find /home /root -name authorized_keys -exec ls -l {} \; -exec cat {} \;

# 8. Descritores abertos de arquivos já apagados - o caso de abertura
ls -l /proc/*/exe 2>/dev/null | grep -i deleted
lsof +L1 2>/dev/null | head -20
```

O último bloco é o que responde à pergunta que abriu o capítulo: `ls -l` lista arquivos abertos cuja contagem de nomes é zero — apagados, mas ainda ocupando espaço e ainda em uso.

12.8. Endurecimento: a lista curta que vale a pena

Endurecimento completo é assunto do Volume 6, com referência a benchmarks reconhecidos (Center for Internet Security, 2024). O conjunto abaixo é o que cabe numa tarde e evita a maioria dos problemas comuns:

Montagem restritiva das áreas temporárias. Uma linha em `/etc/fstab` por partição, e uma classe inteira de código malicioso automatizado deixa de funcionar:

```
tmpfs /tmp      tmpfs defaults,noexec,nosuid,nodev,size=2G 0 0
tmpfs /dev/shm   tmpfs defaults,noexec,nosuid,nodev          0 0
```

Parâmetros de núcleo. Os que fecham reconhecimento e ataques de camada 3 tratados no Capítulo 8:

```
# /etc/sysctl.d/99-hardening.conf
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.tcp_syncookies = 1
kernel.yama.ptrace_scope = 1
kernel.dmesg_restrict = 1
fs.protected_hardlinks = 1
fs.protected_symlinks = 1
```

Superfície mínima. Desinstalar o que não é usado é mais eficaz do que configurar o que não é usado. Cada serviço removido é uma porta que não precisa ser vigiada.

Atualização automática de segurança. Em servidor, o receio de que uma atualização quebre algo é legítimo — e a resposta é ambiente de homologação e janela definida, não adiar indefinidamente. `unattended-upgrades` restrito ao repositório de segurança é o meio-termo que funciona.

Controle de acesso obrigatório ligado. SELinux em `enforcing` ou AppArmor ativo. A tentação de desativar ao primeiro problema é grande e o preço aparece depois: é o único mecanismo que contém um processo root comprometido.

12.9. Brasil em Foco

Registro remoto é o que sustenta a apuração. O Capítulo 3 tratou de não repúdio; em Linux isso significa `auditd` com regras e remessa para fora da máquina. Sem isso, a resposta a um pedido de informação sobre “quem acessou este arquivo e quando” é uma suposição. Para provedores, essa capacidade se soma às obrigações de guarda dos arts. 13 e 15 do Marco Civil (Brasil, 2014) — que tratam de registros de conexão e de acesso a aplicações, e não substituem o registro administrativo interno.

Fuso e sincronização de relógio. Registro sem hora confiável não sustenta correlação entre máquinas nem resposta a ofício. `timedatectl` com NTP ativo, fuso declarado e verificação periódica é requisito prático — e o erro de uma hora por horário de verão mal configurado já bastou para inviabilizar identificação de assinante.

Dados pessoais em `/var/log` e em `/tmp`. Registros de aplicação frequentemente contêm CPF, e-mail, endereço e até senha registrada por engano; áreas temporárias acumulam exportações e relatórios esquecidos. Tudo isso é dado pessoal sob a LGPD (Brasil, 2018), com necessidade de prazo de retenção, controle de acesso e eliminação. A rotação de registros precisa de política escrita, e não apenas do `logrotate` que veio com a distribuição.

Software fora de suporte. Distribuições têm data de fim de vida pública. Rodar servidor sem correções de segurança com dados pessoais é decisão que os arts. 46 e 47 da LGPD alcançam, e que a ANPD, em orientação a agentes de pequeno porte, trata como falha em medida básica esperada (Autoridade Nacional de Proteção de Dados, 2023). O inventário com data de fim de suporte por sistema é documento de conformidade, não só de TI.

CERT.br e o que chega pelo contato de abuso. Máquinas Linux comprometidas em redes brasileiras costumam ser detectadas de fora — por participarem de varreduras, ataques de amplificação ou distribuição de código malicioso — e a notificação chega ao contato de abuso do bloco. Manter esse endereço monitorado, com procedimento de triagem definido, é frequentemente a diferença entre descobrir o comprometimento em horas ou em meses (CERT.br, 2024).

12.10. No Campo

1. Guardar uma linha de base e comparar periodicamente. Sem linha de base, “isso é normal?” não tem resposta:

```
BASE=/var/lib/baseline; mkdir -p $BASE
find / -xdev -perm -4000 -type f -printf '%m %u %p\n' 2>/dev/null | sort >
  ↪ $BASE/suid
ss -tulpn | sort > $BASE/listen
systemctl list-unit-files --state=enabled | sort > $BASE/units
awk -F: '{print $1:""$3:""$7}' /etc/passwd | sort > $BASE/users
# Guardar cópia fora da máquina - em máquina comprometida, a linha de base
  ↪ também é alvo
```

2. Fazer `auditd` registrar o que importa. Sem regras, o `auditd` instalado não produz quase nada de útil:

```
# /etc/audit/rules.d/seguranca.rules
-w /etc/passwd -p wa -k identidade
-w /etc/shadow -p wa -k identidade
-w /etc/sudoers -p wa -k elevacao
-w /etc/sudoers.d/ -p wa -k elevacao
-w /root/.ssh/ -p wa -k chaves
-a always,exit -F arch=b64 -S execve -F euid=0 -F auid>=1000 -F auid!=1 -k
  ↪ exec-root
```

```
ausearch -k exec-root --start recent | tail -40
```

3. Enviar registro para fora em tempo real. É o que transforma registro em evidência:

```
# /etc/rsyslog.d/10-remoto.conf - TLS e fila em disco para não perder no corte
*. * action(type="omfwd" target="logs.exemplo.local" port="6514"
        protocol="tcp" StreamDriverMode="1" StreamDriverAuthMode="x509/name"
        queue.type="LinkedList" queue.filename="fwd"
↪ queue.saveonshutdown="on")
```

4. Revisar o sudoers procurando as três armadilhas. Comando que abre interpretador, curinga e script gravável:

```
sudo visudo -c # valida a sintaxe antes de qualquer coisa
grep -rE 'NOPASSWD|\\*' /etc/sudoers /etc/sudoers.d/
# Para cada alvo de regra, conferir se o usuário consegue reescrever o binário
```

5. Comparar authorized_keys com a linha de base a cada varredura. Persistência que sobrevive a quase tudo:

```
find /home /root -name authorized_keys -newer /var/lib/baseline/users -ls
```

6. Investigar espaço que não volta depois de apagar arquivo. O caso de abertura, em dois comandos:

```
lsof +L1 | awk '{print $1, $2, $7, $NF}' | sort -k3 -rn | head
ls -l /proc/*/exe 2>/dev/null | grep -i deleted
```

7. Restringir SSH a chave e grupo, e verificar antes de aplicar. Um erro aqui tranca o administrador do lado de fora:

```
sshd -t # valida a configuração
# Manter a sessão atual aberta e testar em outra antes de encerrar
systemctl reload sshd
ss -tanp state established '( sport = :22 )'
```

8. Montar as áreas temporárias com noexec e conferir que pegou. Muda o resultado de boa parte do código malicioso automatizado:

```
findmnt -no OPTIONS /tmp /var/tmp /dev/shm
```

12.11. Resumo

- No Linux, **o nome não é o arquivo**: espaço só é liberado quando o último descritor fecha, e um binário apagado continua executando por `/proc/<pid>/exe`. `lsof +L1` responde à pergunta “apaguei e o espaço não voltou”.
- **ctime não pode ser forjado diretamente**. Um arquivo com `mtime` antigo e `ctime` recente teve as datas adulteradas — achado forense de alto valor.
- Persistência mora em **quatro camadas**: arranque, serviços, agendamento e perfil de usuário. Matar o processo sem varrer as quatro é adiar o incidente.
- No **sudo**, três armadilhas concentram os problemas: `NOPASSWD` em binário que abre interpretador (`vim`, `less`, `find`, `tar`), curinga em argumento e script alvo gravável pelo próprio usuário. Todas equivalem a conceder root.
- **SSH com chave em vez de senha** é a mudança isolada de maior impacto. Mudar de porta reduz ruído, não é controle. `authorized_keys` é alvo de persistência e precisa de linha de base.
- Registro local é **ponto de partida, não prova** — root reescreve o que quiser, e o padrão da distribuição não registra execução de comando nem acesso a arquivo sensível. `auditd` com regras e **remessa remota em tempo real** é o que transforma registro em evidência.
- A triagem cabe em quinze comandos, do mais volátil ao menos: sessões, processos com árvore, sockets com PID, persistência nas quatro camadas, arquivos recentes em áreas graváveis, SUID, contas UID 0 e descritores de arquivos apagados.
- O endurecimento que cabe numa tarde: `noexec,nosuid,nodev` nas áreas temporárias, parâmetros de núcleo, remoção do que não é usado, atualização automática de segurança e MAC em modo restritivo — o único mecanismo que contém um processo root comprometido.

13. Windows e Active Directory essencial

Uma rede corporativa de 300 estações. Um funcionário do setor comercial abre uma planilha recebida por e-mail e habilita as macros. Nada visível acontece. Em quatro horas, o atacante é administrador do domínio inteiro — e nenhuma vulnerabilidade de software foi explorada em nenhum momento do caminho.

A cadeia, reconstruída depois, tem cinco passos. A macro executou como o usuário comercial, uma conta comum. Da memória do processo de autenticação da estação, o atacante extraiu o hash da senha de uma conta de suporte técnico que havia feito login naquela máquina na semana anterior — porque o Windows guardava aquela credencial em memória. Com esse hash, autenticou-se em outras estações sem jamais precisar da senha em texto claro. Numa delas encontrou uma conta de serviço com privilégio de administrador local em todo o parque, porque a instalação de um sistema pedia isso. Essa conta de serviço tinha um SPN registrado, e sua senha — definida em 2019 e nunca trocada — resistiu duas horas a uma quebra a partir do bilhete Kerberos obtido legitimamente por qualquer usuário autenticado. Aquela senha era a mesma de uma conta com direito de replicação no diretório.

Cada passo usou o Active Directory exatamente como ele foi projetado para funcionar. É essa a razão de o AD ser o alvo central em quase todo incidente corporativo relevante: **não é um sistema com falhas, é um sistema com padrões perigosos e uma superfície de confiança enorme.**

O Capítulo 12 mapeou o Linux. Este faz o mesmo para o Windows e para o serviço de diretório que organiza a maior parte das redes corporativas brasileiras.

13.1. Como o Windows pensa

Três conceitos explicam quase todo comportamento de segurança do sistema.

Tudo é um objeto com um descritor de segurança. Arquivos, chaves de registro, processos, serviços, impressoras, objetos do diretório — cada um carrega dono, lista de permissões (DACL) e lista de auditoria (SACL). A consequência prática é que permissões existem em lugares onde ninguém pensa em procurar: a permissão de um serviço pode permitir que um usuário comum altere seu binário; a permissão de uma chave de registro pode permitir que ele altere o que executa no arranque.

A identidade é o SID, não o nome. Cada conta tem um identificador único e imutável. Renomear a conta `Administrador` não muda seu SID, que termina em `-500` — e é por isso que renomear administrador como medida de segurança é teatro: qualquer ferramenta localiza a conta pelo sufixo. Os SIDs bem conhecidos merecem reconhecimento imediato: `-500` (administrador local), `-512` (Admins. do Domínio), `-519` (Admins. da Empresa), `-518` (Admins. do Esquema).

A autorização acontece por token. Ao autenticar, o usuário recebe um token com seu SID, os SIDs de todos os grupos e a lista de privilégios nomeados. Toda verificação posterior consulta esse token — o que produz um efeito que confunde muita gente: **incluir alguém num**

grupo não tem efeito até que ele saia e entre de novo, porque o token só é montado na autenticação.

Os privilégios que equivalem a administração, já introduzidos no Capítulo 11, valem repetição: `SeDebugPrivilege` (ler a memória de qualquer processo), `SeImpersonatePrivilege` (assumir outra identidade), `SeBackupPrivilege` e `SeRestorePrivilege` (ler e escrever qualquer arquivo ignorando permissões), `SeTakeOwnershipPrivilege` e `SeLoadDriverPrivilege` (carregar código em anel 0). Uma conta de serviço com qualquer um deles é administrador por via indireta.

13.1.1. UAC não é fronteira de segurança

O Controle de Conta de Usuário divide o token de um administrador em dois: um restrito para uso comum e um completo, ativado pela elevação. Isso reduz danos acidentais, e a própria Microsoft o documenta como recurso de conveniência — **não como limite de segurança**. Existem caminhos conhecidos de elevação automática que dispensam o consentimento do usuário.

A consequência operacional é a que importa: **usuário administrador local é usuário administrador local, com ou sem UAC**. A separação real é ter contas distintas — uma comum para o dia a dia, outra administrativa usada apenas quando necessário e jamais para navegar ou ler e-mail.

13.2. Active Directory: o mapa da confiança

O AD é um banco de dados hierárquico com autenticação. Cinco termos organizam tudo:

- **Domínio** — fronteira administrativa e de replicação, com seus usuários, grupos e computadores.
- **Floresta** — conjunto de domínios com esquema comum. É a **verdadeira fronteira de segurança**: comprometer um domínio compromete a floresta, porque as relações de confiança internas não são barreiras defensivas.
- **Unidade organizacional (OU)** — contêiner para organizar objetos e aplicar política. Não é grupo de segurança.
- **GPO** — política aplicada a OUs, sites ou domínio, que configura estações e servidores em massa.
- **Controlador de domínio (DC)** — servidor que guarda o `NTDS.dit`, o arquivo com todas as credenciais do domínio. Comprometer um DC é comprometer tudo.

A confusão mais cara aqui é entre floresta e domínio: separar departamentos em domínios distintos “por segurança” não cria isolamento. Se o requisito é isolamento real, a resposta é floresta separada.

13.3. Autenticação: NTLM, Kerberos e a memória da estação

13.3.1. NTLM e o problema de projeto

O NTLM autentica por desafio e resposta, usando o hash da senha. O ponto que sustenta metade dos ataques em rede Windows é este: **o hash funciona como a senha**. Quem o obtém autentica-se sem nunca conhecer a senha em texto claro — a técnica conhecida como *pass the hash*, o segundo passo do caso de abertura.

Além disso, o NTLM não autentica o servidor, o que viabiliza retransmissão: o atacante induz uma máquina a autenticar-se contra ele e repassa a autenticação a um terceiro serviço, agindo como a vítima. Os protocolos de resolução de nomes de contingência — LLMNR, NBT-NS e mDNS — são o gatilho clássico: quando o DNS falha, a estação pergunta em difusão “quem é servidorx?”, e qualquer máquina na rede pode responder “eu sou”. **Desabilitar LLMNR e NBT-NS por GPO é uma das medidas de melhor relação custo-benefício em todo o Windows.**

A direção correta é reduzir o NTLM ao mínimo, exigir assinatura SMB e LDAP (o que quebra a retransmissão) e caminhar para bloqueá-lo — com o cuidado de auditar antes, porque sistemas antigos ainda dependem dele.

13.3.2. Kerberos e seus dois ataques clássicos

O Kerberos é o protocolo padrão no domínio, baseado em bilhetes emitidos por um centro de distribuição de chaves que roda no DC. A Figura 13.1 mostra o fluxo normal e onde os dois abusos mais comuns se encaixam.

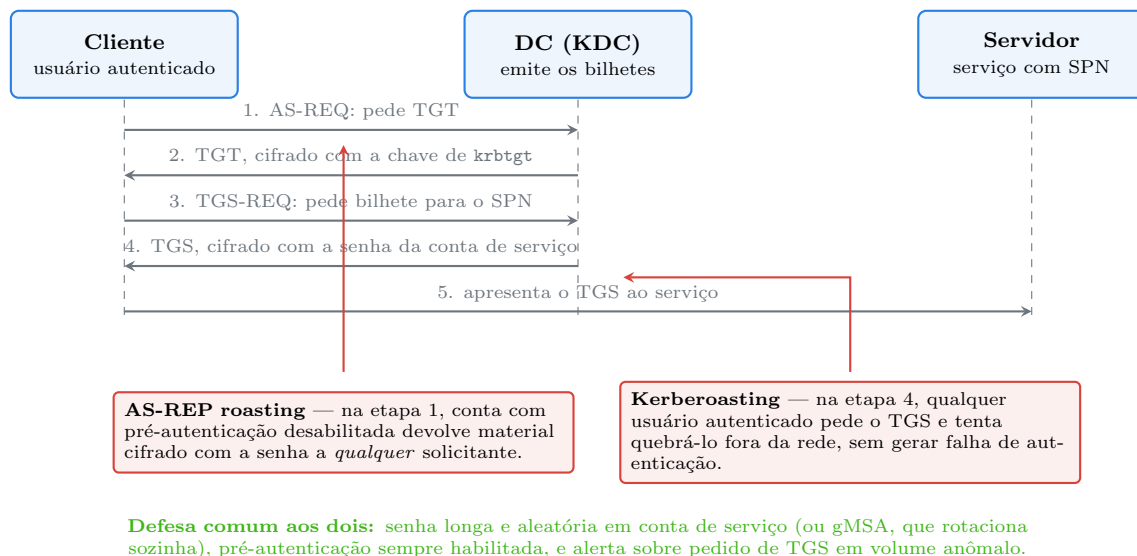


Figura 13.1.: Fluxo Kerberos e os dois abusos que dispensam qualquer vulnerabilidade de software.

O **Kerberoasting** foi o terceiro passo do caso de abertura, e é insidioso porque cada etapa é legítima: pedir um bilhete de serviço é o que todo cliente faz. A tentativa de quebra ocorre **fora da rede**, sem gerar falha de autenticação e sem disparar bloqueio de conta. A defesa, portanto, não é bloquear o pedido — é tornar a quebra inviável, com senhas longas e aleatórias, idealmente através de contas de serviço gerenciadas por grupo (gMSA), que trocam a senha automaticamente.

Dois outros abusos merecem menção, porque aparecem em qualquer relatório de teste de invasão: a **delegação irrestrita**, em que um servidor configurado assim guarda em memória os TGTs de todos que o acessam — incluindo administradores —, e o **bilhete dourado**, forjado a partir do hash da conta `krbtgt`, que dá acesso perpétuo até que essa conta seja trocada duas vezes.

13.3.3. Por que a estação guarda credenciais

O passo que costuma surpreender é o primeiro: como a macro executada por um usuário comum obteve a credencial de um técnico de suporte? Porque o processo de autenticação do Windows mantinha em memória o material de autenticação de todas as sessões ativas ou recentes na máquina — necessário para o *logon* único funcionar sem pedir senha a cada acesso a recurso de rede.

Daí decorrem três controles que se reforçam:

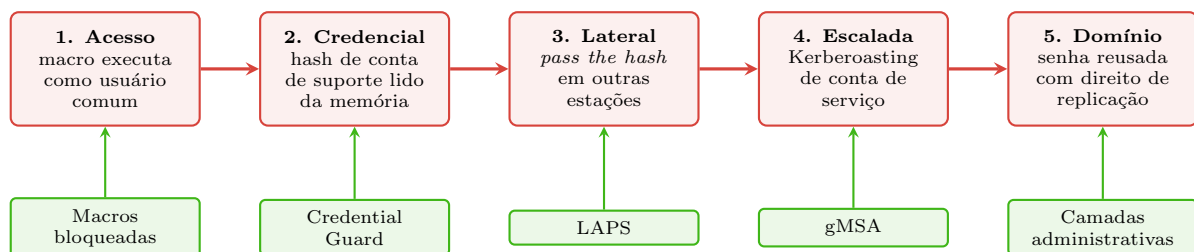
Credential Guard, que isola esses segredos num ambiente protegido por virtualização, inacessível mesmo ao núcleo comprometido. É a mitigação mais efetiva e exige hardware moderno.

Camadas administrativas (o modelo de níveis): a credencial de administrador de domínio **nunca** é usada numa estação de trabalho. Administração de servidores a partir de servidores; administração de domínio a partir de estações administrativas dedicadas. A regra que resume o modelo: *uma credencial só deve ser usada em máquinas do seu nível ou superior*.

LAPS, que dá a cada estação uma senha de administrador local diferente, aleatória e rotacionada, guardada no diretório. Elimina a reutilização que permite pular de máquina em máquina — o segundo passo do caso de abertura.

13.4. Os caminhos de escalada que existem sem falha nenhuma

O que torna o AD difícil de defender é que os privilégios se compõem por relações, e não por listas. Um usuário pode não ser administrador e ainda assim ter um caminho até o domínio através de uma cadeia de permissões individualmente razoáveis. A Figura 13.2 refaz a cadeia do caso de abertura, marcando o controle que interrompe cada elo.



Nenhum passo explorou vulnerabilidade de software. Qualquer um dos cinco controles quebra a cadeia.

Figura 13.2.: A cadeia do caso de abertura e o controle que interrompe cada elo.

Os padrões recorrentes por trás dessa e de outras cadeias:

Tabela 13.1.: Caminhos de escalada em AD que não dependem de vulnerabilidade de software.

Caminho	Como funciona	Correção
Senha reutilizada de admin. local	Mesma senha em todo o parque; hash serve em todas	LAPS
Conta de serviço com privilégio excessivo	Instalação pediu admin. de domínio e ninguém revisou	Conta dedicada, gMSA, privilégio mínimo
Senha em GPO ou em script de logon	SYSVOL é legível por qualquer usuário do domínio	Remover; trocar a credencial exposta

Caminho	Como funciona	Correção
Grupos administrativos inchados	Dezenas de membros herdados de anos	Revisão trimestral; administração temporária
Permissão delegada esquecida	Direito de trocar senha ou escrever em objeto	Auditoria de ACL do diretório
Delegação irrestrita	Servidor acumula TGTs de quem o acessa	Migrar para delegação restrita
Conta com senha sem expiração e sem MFA	Força bruta lenta e discreta ao longo de meses	Política de senha e MFA

A descoberta desses caminhos é automatizável, e é exatamente isso que ferramentas de análise de grafo do diretório fazem — inclusive as usadas defensivamente. Rodar essa análise contra o próprio ambiente, com autorização documentada nos termos do Capítulo 7, é o exercício mais revelador que uma equipe de infraestrutura pode fazer, e costuma encontrar caminhos de cinco saltos que ninguém imaginava.

13.5. Registros e detecção: o que ligar antes de precisar

O Windows registra muito por padrão — e quase nada do que interessa. Os eventos que efetivamente sustentam detecção precisam ser habilitados por política de auditoria e, em alguns casos, por instalação adicional:

Tabela 13.2.: Eventos do Windows que sustentam detecção.

Evento	O que indica
4624 / 4625	Logon bem-sucedido / falho, com o tipo (3 = rede, 10 = RDP)
4648	Logon com credencial explícita — sinal de movimentação lateral
4672	Atribuição de privilégio especial na sessão
4720, 4728, 4732	Conta criada; membro adicionado a grupo global e local
4768 / 4769	Bilhete Kerberos pedido — o 4769 em volume é indício de Kerberoasting
4698	Tarefa agendada criada — persistência
7045	Serviço instalado — persistência e execução remota
1102	Registro de segurança apagado — sempre investigar
4104	Bloco de script PowerShell registrado (exige registro de blocos ligado)

Três configurações mudam o patamar de visibilidade e não custam licença: **registro de linha de comando na criação de processo** (evento 4688 com o comando completo), **registro de blocos e transcrição do PowerShell**, e **aumento do tamanho do registro de segurança**, que no padrão gira em horas numa máquina movimentada e apaga a evidência antes que alguém a leia. Sobre isso, vale a mesma regra do Capítulo 12: **remessa para um coletor externo**,

porque quem vira administrador apaga o registro local — e é justamente esse apagamento que o evento 1102 denuncia.

13.6. Brasil em Foco

Licenciamento e sistema fora de suporte. Parque com Windows sem suporte — e ainda há muito Windows 7 e Server 2008 em operação no país — não recebe correção e não suporta os controles modernos deste capítulo. Sob os arts. 46 e 47 da LGPD (Brasil, 2018), manter dados pessoais em sistema sem manutenção é falha em medida de segurança esperada, e a ANPD já indicou atualização como item básico em sua orientação a agentes de pequeno porte (Autoridade Nacional de Proteção de Dados, 2023). O inventário com data de fim de suporte é documento de conformidade.

Ransomware entra pelo AD. Os ataques que pararam hospitais, prefeituras e empresas brasileiras seguiram, quase sempre, a cadeia deste capítulo: acesso inicial por phishing ou RDP exposto, roubo de credencial em memória, movimentação lateral com hash, escalada até administrador do domínio e, por fim, distribuição da carga por GPO ou por ferramenta de administração remota — usando a própria infraestrutura de gerência contra a organização. Como incidente de segurança com dados pessoais, dispara a comunicação prevista na Resolução CD/ANPD nº 15/2024 (Autoridade Nacional de Proteção de Dados, 2024), com prazo e conteúdo definidos. O Volume 11 trata da anatomia completa.

RDP exposto à internet é o vetor mais comum e o mais evitável. Uma varredura de qualquer bloco brasileiro encontra milhares de portas 3389 abertas. Expor administração remota diretamente é decisão que precisa ser eliminada — VPN, gateway com MFA ou acesso por bastião —, e sua manutenção dificilmente se sustenta numa avaliação de diligência após um incidente.

Registro de acesso e responsabilização. O Capítulo 3 tratou de não repúdio; em ambiente Windows isso significa contas administrativas nominais, jamais compartilhadas, com auditoria ligada e remessa externa. Uma apuração interna ou uma resposta a ofício que dependa de saber “quem executou o quê” fracassa quando três pessoas usam a mesma conta **Administrador**.

Dados pessoais no diretório. O AD guarda nome, matrícula, cargo, telefone, e-mail e frequentemente CPF em atributos personalizados — base de dados pessoais sob a LGPD, com necessidade de controle de acesso. Vale lembrar que **qualquer usuário autenticado lê a maior parte do diretório por padrão**: a lista completa de funcionários, sua estrutura hierárquica e seus contatos estão disponíveis a qualquer conta comprometida.

13.7. No Campo

1. Desabilitar LLMNR e NBT-NS por GPO. Corta a retransmissão NTLM na origem, e é a medida de melhor relação custo-benefício do capítulo:

```
Configuração do Computador > Modelos Administrativos > Rede > Cliente DNS  
→ "Desativar a resolução de nomes multicast" = Habilitado
```

NBT-NS: nas propriedades de TCP/IPv4 de cada adaptador, ou por script na

```
↪ imagem:
```

```
Set-ItemProperty -Path
```

```
↪ 'HKLM:\SYSTEM\CurrentControlSet\Services\NetBT\Parameters\Interfaces\*' ` -Name NetbiosOptions -Value 2
```

2. Implantar LAPS. Elimina a senha de administrador local reutilizada em todo o parque:

```
# Windows LAPS (integrado às versões atuais) - conferir aplicação
Get-LapsADPassword -Identity ESTACAO-042 -AsPlainText
Get-CimInstance Win32_ComputerSystem | Select-Object Name, Domain
```

3. Caçar contas de serviço com SPN e senha antiga. É o vetor do Kerberoasting, e a consulta leva segundos:

```
Get-ADUser -Filter 'ServicePrincipalName -like "*" ' `
-Properties ServicePrincipalName, PasswordLastSet, AdminCount |
Select-Object Name, PasswordLastSet, AdminCount,
    ↳ @{n='SPN';e={$_.ServicePrincipalName -join ';' }} |
Sort-Object PasswordLastSet
```

4. Encontrar as contas sem pré-autenticação e sem expiração de senha. Achado de dois minutos que costuma render:

```
# AS-REP roasting
Get-ADUser -Filter 'DoesNotRequirePreAuth -eq $true' -Properties
    ↳ DoesNotRequirePreAuth

# Senha que nunca expira
Get-ADUser -Filter 'PasswordNeverExpires -eq $true -and Enabled -eq $true' |
    Select-Object Name, SamAccountName

# Delegação irrestrita - servidores que acumulam TGT de quem os acessa
Get-ADComputer -Filter 'TrustedForDelegation -eq $true' -Properties
    ↳ TrustedForDelegation
```

5. Revisar os grupos que importam, trimestralmente. Poucos membros, todos justificáveis:

```
foreach ($g in 'Domain Admins','Enterprise Admins','Schema Admins','Account
    ↳ Operators','Backup Operators') {
    "==" $g == "
    Get-ADGroupMember -Identity $g -Recursive | Select-Object -Expand
    ↳ SamAccountName
}
```

6. Procurar senha em SYSVOL. Legível por qualquer usuário do domínio, e ainda aparece:

```
Get-ChildItem \\dominio.local\SYSVOL -Recurse -Include *.xml,*.ps1,*.bat,*.vbs
    ↳ -ErrorAction SilentlyContinue |
    Select-String -Pattern 'cpassword|password\s*=' |
    Select-Object Path, Line -First 40
```

7. Ligar o registro que sustenta detecção. Sem isso, o incidente é reconstruído por adivinhação:

Política de Auditoria Avançada (por GPO):

Logon/Logoff → Logon, Logoff, Bloqueio de conta Êxito e Falha
Acesso a Objetos → Compartilhamento de Arquivos Êxito e Falha
Rastreamento Detalhado → Criação de Processo Êxito
Alteração de Política, Uso de Privilégio Êxito e Falha

Modelos Administrativos > Sistema > Auditoria de Criação de Processo
→ "Incluir linha de comando" = Habilitado

Componentes do Windows > Windows PowerShell

→ Registro de blocos de script = Habilitado
→ Transcrição = Habilitado (destino em compartilhamento restrito)

Tamanho do log Segurança: mínimo 1 GB nas estações, 4 GB nos servidores

8. Aplicar o modelo de camadas administrativas. A regra que mais reduz o alcance de um comprometimento: credencial de administrador de domínio nunca toca estação de trabalho. Estação administrativa dedicada, sem e-mail e sem navegação, e restrição por GPO (“Negar logon local” para contas de domínio nas estações comuns) para que a regra não dependa de disciplina individual.

13.8. Resumo

- No Windows, **tudo é objeto com descritor de segurança** — inclusive serviços e chaves de registro, onde permissões frouxas viram escalonamento. A identidade é o **SID** (renomear a conta administrador não muda o -500), e a autorização vem do **token**, montado na autenticação: mudança de grupo só vale no próximo logon.
- **UAC não é fronteira de segurança.** A separação real é ter contas distintas para uso comum e para administração.
- **A floresta é a fronteira de segurança**, não o domínio. Separar departamentos em domínios não cria isolamento.
- No **NTLM**, o hash funciona como a senha (*pass the hash*), e a ausência de autenticação do servidor viabiliza retransmissão. **Desabilitar LLMNR e NBT-NS** e exigir assinatura SMB e LDAP corta o vetor mais comum.
- **Kerberoasting e AS-REP roasting** abusam de operações legítimas: a quebra ocorre fora da rede, sem falha de autenticação e sem bloqueio de conta. A defesa é senha longa e aleatória em conta de serviço — idealmente **gMSA** — e pré-autenticação sempre habilitada.
- A estação guarda credenciais em memória para o *logon* único funcionar. As três defesas que se reforçam: **Credential Guard**, **modelo de camadas administrativas** (credencial de domínio nunca em estação) e **LAPS** (senha local única por máquina).
- Os caminhos de escalada em AD **não dependem de vulnerabilidade de software** — vêm de senha reutilizada, conta de serviço com privilégio excessivo, senha em SYSVOL, grupos inchados, delegação esquecida. São descobríveis por análise de grafo, e rodar essa análise contra o próprio ambiente é o exercício mais revelador disponível.
- O Windows registra muito e quase nada do que interessa. **Linha de comando na criação de processo, registro de blocos do PowerShell, log de segurança grande e remessa externa** são o mínimo — e o evento **1102** (log apagado) merece alerta sempre.

14. Virtualização e montagem do laboratório de estudos

Um estudante de segurança quer entender ARP spoofing. Leu o Capítulo 8, entendeu a teoria, e agora quer ver acontecer. Instala a ferramenta na própria máquina, aponta para o gateway de casa e executa. Funciona: a conexão da família cai, a irmã reclama que o vídeo travou, e ele não aprende quase nada — porque não tinha como observar os dois lados, não podia repetir em condições controladas e não podia errar sem consequência.

Duas semanas depois, o mesmo estudante monta três máquinas virtuais numa rede isolada: uma vítima, um atacante e um gateway. Executa o mesmo ataque. Captura o tráfego dos três pontos ao mesmo tempo. Vê a tabela ARP da vítima mudar em tempo real. Liga Dynamic ARP Inspection num switch virtual e vê o ataque falhar. Restaura o *snapshot* e repete de outro jeito. Em uma tarde, entende mais do que em um mês de leitura.

A diferença não é conhecimento nem ferramenta: é **ambiente**. O laboratório é o que separa quem sabe descrever um ataque de quem sabe reconhecê-lo, detectá-lo e contê-lo. E ele tem uma segunda função, igualmente importante: **é o único lugar onde a prática é inequivocamente legal**, o que o Capítulo 7 fixou como fronteira da profissão.

Este capítulo fecha o Volume 2 construindo esse ambiente. É também o capítulo mais prático do manual até aqui, e o que torna utilizáveis os próximos volumes.

14.1. Virtualização: o que a fronteira realmente vale

Um **hipervisor** cria máquinas virtuais, cada uma com seu núcleo, sua memória e seus discos virtuais. Há dois tipos, e a diferença importa mais para desempenho do que para segurança: o **tipo 1** roda direto no hardware (Proxmox VE, ESXi, Hyper-V, XCP-ng); o **tipo 2** roda sobre um sistema operacional hospedeiro (VirtualBox, VMware Workstation, Hyper-V no Windows cliente).

Para segurança, o que interessa é a **força do isolamento**, e a comparação com contêineres é o ponto central:

Tabela 14.1.: Máquina virtual e contêiner como fronteiras de isolamento.

Aspecto	Máquina virtual	Contêiner
Núcleo	Um por VM	Compartilhado com o hospedeiro
Fronteira	Hipervisor (superfície pequena)	Chamadas de sistema (superfície grande)
Escape	Raro, alto valor, corrigido com urgência	Mais frequente; erro de configuração basta
Arranque	Segundos a minutos	Milissegundos
Custo de recursos	Alto	Baixo

Aspecto	Máquina virtual	Contêiner
Uso em laboratório	Análise de código malicioso, sistemas completos	Serviços vulneráveis, alvos web

A regra prática que decorre disso: **contêiner para conveniência, máquina virtual para contenção**. Rodar um alvo web deliberadamente vulnerável em contêiner é adequado. Executar código malicioso desconhecido em contêiner **não é** — o Volume 11, ao tratar de análise dinâmica, trabalha com máquina virtual isolada, com instantâneo e sem rede, precisamente por isso.

Vale ainda registrar que o isolamento do hipervisor, embora forte, não é absoluto. Escapes existem e são corrigidos com urgência máxima; e há canais laterais em CPU compartilhada que atravessam fronteiras de VM, o que importa muito em nuvem multi-inquilino — assunto do Volume 8 — e pouco num laboratório doméstico. As orientações do NIST sobre virtualização segura (National Institute of Standards and Technology, 2011) resumem o quadro: a VM é uma fronteira forte, não uma garantia.

14.2. O laboratório mínimo

A pergunta mais comum de quem começa é sobre hardware. A resposta honesta: **8 GB de RAM já permitem estudar**, 16 GB tornam a experiência confortável, 32 GB permitem simular um domínio Windows completo. Disco SSD importa mais que processador, porque o gargalo real é entrada e saída — e um disco de 256 GB dedicado a máquinas virtuais é suficiente para começar.

A Figura 14.1 mostra a topologia que serve de base para tudo o que vem nos próximos volumes.

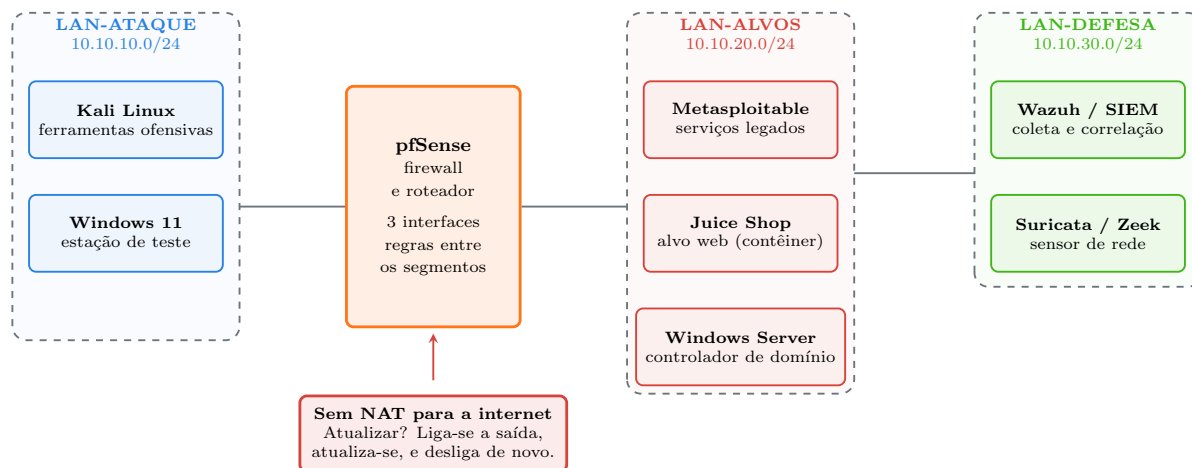


Figura 14.1.: Topologia do laboratório. Três segmentos separados por um firewall, sem rota para a internet no uso normal.

14.2.1. Os três segmentos e por que separá-los

LAN-ATAQUE hospeda as ferramentas ofensivas. **LAN-ALVOS** hospeda os sistemas deliberadamente vulneráveis. **LAN-DEFESA** hospeda a coleta e a detecção. A separação não é preciosismo: ela permite escrever regras de firewall entre os segmentos e **observar o efeito**

delas — que é justamente o que se quer aprender. Um laboratório com tudo numa única rede plana ensina metade.

14.2.2. A regra inegociável do isolamento

Um alvo deliberadamente vulnerável é uma máquina vulnerável. Se ela tiver rota para a internet, será comprometida — não hipoteticamente: sistemas como o Metasploitable são varridos e explorados em minutos quando expostos. E aí o laboratório deixa de ser laboratório e passa a ser um problema seu, do seu provedor e de terceiros.

Quatro regras que não têm exceção:

1. **Rede interna ou apenas hospedeiro**, nunca em ponte com a rede doméstica ou corporativa.
2. **Sem NAT no uso normal**. Precisa atualizar um alvo? Liga a saída, atualiza, desliga. Nunca deixa ligada.
3. **Alvos vulneráveis jamais expostos**, nem “só por cinco minutos para testar de fora”.
4. **Instantâneo antes de qualquer coisa interessante**, e restauração depois. É o que permite errar à vontade.

E uma regra que decorre do Capítulo 7: **o alvo é sempre seu**. O laboratório existe justamente para que a resposta à pergunta “eu tenho autorização?” seja trivialmente sim.

14.3. O que instalar, em que ordem

A tentação de montar tudo de uma vez leva ao abandono. A ordem abaixo entrega valor a cada etapa e cada uma leva algumas horas.

14.3.1. Etapa 1 — Hipervisor e a primeira máquina

Em máquina dedicada, **Proxmox VE** é a melhor escolha: gratuito, robusto, com interface web, instantâneos, contêineres LXC e rede virtual configurável. Em notebook de uso diário, **VirtualBox** ou **VMware Workstation** resolvem sem reinstalar nada.

A primeira VM deve ser uma distribuição Linux comum — Debian ou Ubuntu Server — e não uma distribuição de segurança. O objetivo é praticar o Capítulo 12 num sistema que se administra de verdade: montagens, `systemd`, `auditd`, SSH com chave, `nftables`.

14.3.2. Etapa 2 — Atacante e alvo, uma rede

Kali Linux ou **Parrot OS** de um lado, **Metasploitable 2** do outro, ambos em rede interna. Com apenas essas duas máquinas já se pratica varredura, enumeração, análise de serviço e captura de tráfego — a base dos Volumes 5 e 9.

14.3.3. Etapa 3 — Alvos web

OWASP Juice Shop e **DVWA**, ambos disponíveis como contêiner, cobrem praticamente todo o Volume 7. O Juice Shop é moderno e tem progressão em forma de desafios; o DVWA tem níveis de dificuldade que permitem ver a mesma falha com e sem correção — recurso didático que poucos alvos oferecem.

```
# Dois alvos web em minutos, na rede isolada do laboratório
docker run -d --name juice --network lab-alvos -p 3000:3000
↳ bkimminich/juice-shop
docker run -d --name dvwa --network lab-alvos -p 8080:80 vulnerables/web-dvwa
```

14.3.4. Etapa 4 — Firewall e segmentação

pfSense ou **OPNsense** como roteador entre os segmentos. É aqui que se aprende de verdade o que o Capítulo 8 e o Capítulo 9 descreveram: escrever regra, testar, ver o registro, entender por que o pacote não passou. É também a base do Volume 5.

14.3.5. Etapa 5 — Domínio Windows

Um **Windows Server** como controlador de domínio, com duas estações associadas. Exige 16 GB de RAM para ficar confortável, e é o que torna praticável o Capítulo 13: criar contas de serviço com SPN, observar Kerberoasting no registro de eventos, implantar LAPS, aplicar GPO e ver o efeito. As versões de avaliação são gratuitas por 180 dias e podem ser reinstaladas.

14.3.6. Etapa 6 — Defesa e visibilidade

O passo que a maioria pula, e o que mais ensina. **Wazuh** (ou uma pilha de coleta equivalente) recebendo registros das máquinas; **Suricata** ou **Zeek** observando o tráfego; **Security Onion** se a máquina aguentar, por trazer tudo pronto.

O exercício que fecha o ciclo é sempre o mesmo, e vale mais que qualquer leitura: **executar um ataque conhecido e ir procurar o rastro que ele deixou**. Quem já tentou detectar o próprio ataque entende, de uma vez, por que o Volume 12 existe.

14.4. Plataformas de treino: o complemento

O laboratório próprio ensina a **construir**; as plataformas de treino ensinam a **resolver**. Ambas são necessárias, e todas as citadas têm autorização explícita nos termos de uso:

- **TryHackMe** — trilhas guiadas, boa porta de entrada, com material em progressão.
- **Hack The Box** — máquinas sem orientação, mais próximas da realidade; a academia associada é estruturada.
- **PortSwigger Web Security Academy** — gratuita e a melhor referência prática para o Volume 7.
- **PicoCTF** e competições brasileiras — formato CTF, excelente para fundamentos.
- **Blue Team Labs / CyberDefenders** — o lado defensivo, com investigação de incidentes reais simulados.

A ordem que funciona: fundamentos em plataforma guiada, prática no laboratório próprio para entender a infraestrutura, e só então máquinas sem orientação.

14.5. Um roteiro de exercícios que percorre o volume

Fecha o capítulo — e o volume — um conjunto de exercícios que usa o laboratório para fixar o que os seis capítulos anteriores apresentaram. Cada um leva de uma a três horas.

Tabela 14.2.: Roteiro de exercícios do laboratório para o Volume 2.

Exercício	O que pratica	Capítulo
Capturar um handshake TCP completo e identificar cada flag	Camada 4 na prática	Capítulo 8
Executar ARP spoofing entre duas VMs e observar as tabelas dos dois lados	Camada 2 e MITM	Capítulo 8
Segmentar o laboratório em três VLANs e escrever as regras entre elas	Endereçamento e filtragem	Capítulo 9
Configurar DNS interno e observar o efeito de uma resposta forjada	Resolução e envenenamento	Capítulo 10
Publicar SPF, DKIM e DMARC num domínio de teste e verificar a rejeição	Autenticidade de e-mail	Capítulo 10
Encontrar todos os binários SUID e explicar por que cada um existe	Privilegio e escalada	Capítulo 11
Ligar <code>auditd</code> , executar comandos privilegiados e achá-los no registro	Registro e responsabilização	Capítulo 12
Criar conta de serviço com SPN e senha fraca; observar o pedido de TGS no evento 4769	Kerberos e detecção	Capítulo 13
Enviar todos os registros ao coletor e escrever um alerta que dispare	Visibilidade fim a fim	Volume 12

O último exercício é o mais importante, e por isso está no fim: **um ataque que você executou e não conseguiu detectar é a medida exata da lacuna de visibilidade** da sua operação. Essa constatação, feita no laboratório, custa uma tarde. Feita em produção, custa um incidente.

14.6. Brasil em Foco

O laboratório é a resposta à ausência de porto seguro legal. O Capítulo 7 registrou que o Brasil não tem salvaguarda explícita para pesquisa de segurança de boa-fé: quem reporta depende da decisão da vítima de não representar. Enquanto isso não muda, o ambiente próprio e

isolado é o único lugar onde a prática ofensiva não depende da boa vontade de terceiros. Não é limitação didática — é a diferença entre estudar e cometer o crime do art. 154-A do Código Penal.

Cuidado com o que entra no laboratório. Baixar amostra real de código malicioso para análise é atividade legítima de estudo, e o Volume 11 trata do procedimento. Duas cautelas valem desde já: a amostra pode conter dados pessoais de vítimas — cujo tratamento tem de ser justificado sob a LGPD (Brasil, 2018) — e o isolamento precisa ser real, porque uma amostra que escapa e ataca terceiros gera responsabilidade de quem a executou. Máquina virtual dedicada, sem rede, com instantâneo e descartada ao fim.

Alvo vulnerável exposto tem consequência para o provedor. Uma máquina do laboratório acessível pela internet e comprometida passa a atacar terceiros a partir do bloco do provedor. O resultado prático é notificação do CERT.br ao contato de abuso (CERT.br, 2024), entrada do bloco em listas de reputação e prejuízo para todos os assinantes daquele bloco. Para quem estuda a partir de uma conexão residencial, o contrato de serviço tipicamente veda uso que gere abuso — e a responsabilidade civil por dano a terceiro independe da cláusula contratual.

Licenças e as versões de avaliação. Windows Server e Windows cliente têm versões de avaliação legítimas e gratuitas por prazo determinado, e usá-las em laboratório está dentro dos termos. Recorrer a ativação irregular é violação de direito autoral (Lei 9.610/1998) e crime previsto no art. 184 do Código Penal — e ainda contamina o laboratório com binários de origem desconhecida, o que compromete qualquer conclusão obtida ali.

Documentar o laboratório também é prática profissional. Um documento simples com topologia, endereçamento, finalidade e a declaração de que os alvos são próprios e isolados serve a dois propósitos: organiza o estudo e, se algum tráfego for questionado pelo empregador ou pelo provedor, demonstra a natureza da atividade. É a versão pessoal do princípio de autorização documentada do Capítulo 7.

14.7. No Campo

1. Criar as redes isoladas antes de criar qualquer VM. No Proxmox, três pontes sem interface física associada:

```
# /etc/network/interfaces - pontes isoladas, sem porta física
auto vmbr10
iface vmbr10 inet manual
    bridge-ports none
    bridge-stp off
    bridge-fd 0
# LAN-ATAQUE 10.10.10.0/24

auto vmbr20
iface vmbr20 inet manual
    bridge-ports none
# LAN-ALVOS 10.10.20.0/24

auto vmbr30
iface vmbr30 inet manual
    bridge-ports none
# LAN-DEFESA 10.10.30.0/24
```

```
# VirtualBox: rede interna nomeada, sem NAT e sem ponte
VBoxManage modifyvm "alvo-metasploitable" --nic1 intnet --intnet1 "lab-alvos"
VBoxManage modifyvm "kali" --nic1 intnet --intnet1 "lab-ataque"
```

2. Verificar o isolamento antes de ligar o primeiro alvo. Trinta segundos que evitam o problema inteiro:

```
# De dentro do alvo vulnerável: as três devem falhar
ping -c2 8.8.8.8
ping -c2 192.168.0.1          # gateway da rede doméstica
curl -m5 -sI https://example.com
```

3. Automatizar o instantâneo antes de cada sessão. O hábito que transforma o laboratório em ambiente de experimentação real:

```
# Proxmox: instantâneo com data em todas as VMs do laboratório
for id in 101 102 103 104; do
    qm snapshot $id "limpo-$(date +%Y%m%d)" --description "estado antes da
    ↪ sessão"
done
qm rollback 102 limpo-20260730          # voltar em segundos
```

4. Manter uma janela de atualização controlada. Os alvos precisam de correção eventual, e a saída não pode ficar aberta:

```
No pfSense, uma regra desabilitada e pronta:
LAN-ALVOS → any (allow) [desabilitada]
Habilitar, atualizar, desabilitar. Nunca deixar habilitada entre sessões.
```

5. Documentar o laboratório numa página. Topologia, endereçamento por segmento, finalidade, sistema e versão de cada VM, e a declaração de propriedade e isolamento. Atualizada a cada mudança relevante.

6. Praticar a restauração, não só o instantâneo. Instantâneo que nunca foi restaurado é backup que nunca foi testado — a mesma lição que o Volume 14 aplica à continuidade de negócio. Restaurar de propósito, uma vez, e cronometrar.

7. Fechar o ciclo em todo exercício. A regra que multiplica o valor do laboratório: para cada ataque executado, **procurar o rastro**. No registro do alvo, no sensor de rede, no coletor. O que não deixou rastro é lacuna de visibilidade identificada — e é a partir dessa lista que o Volume 12 faz sentido.

8. Registrar o que aprendeu no próprio laboratório. Um arquivo por exercício com o que foi feito, o comando exato, o resultado e o rastro encontrado. Além de fixar o aprendizado, é o embrião do relatório técnico que o Volume 9 vai exigir — e escrever bem é parte do ofício, não acessório.

14.8. Resumo

- **Contêiner para conveniência, máquina virtual para contenção.** O contêiner compartilha o núcleo com o hospedeiro e tem superfície de escape muito maior; código malicioso desconhecido só se executa em VM isolada, com instantâneo e sem rede.
- O laboratório mínimo cabe em **8 GB de RAM**; 16 GB tornam confortável e 32 GB permitem um domínio Windows completo. SSD importa mais que processador.
- A topologia base tem **três segmentos** — ataque, alvos e defesa — separados por um firewall. A separação é o que permite escrever regras e observar seu efeito; rede plana ensina metade.
- Quatro regras de isolamento sem exceção: **rede interna, nunca em ponte**; sem NAT no uso normal; alvos vulneráveis jamais expostos; instantâneo antes de qualquer coisa interessante. Um alvo deliberadamente vulnerável exposto é comprometido em minutos.
- A montagem funciona **em etapas**: hipervisor e Linux comum, atacante e alvo, alvos web em contêiner, firewall e segmentação, domínio Windows, e por fim coleta e detecção.
- **A etapa de defesa é a que a maioria pula e a que mais ensina.** O exercício que fecha o ciclo é executar um ataque conhecido e ir procurar o rastro: o que não deixou rastro é a medida exata da lacuna de visibilidade.
- Plataformas de treino complementam o laboratório próprio — ele ensina a construir, elas ensinam a resolver — e todas trazem a autorização nos termos de uso.
- No Brasil, onde **não há porto seguro legal para pesquisa de boa-fé**, o laboratório próprio é o único ambiente em que a prática ofensiva não depende de terceiros. Documentá-lo é a versão pessoal do princípio de autorização escrita.

Parte III.

Volume 3 — Criptografia Aplicada

15. História e princípios da criptografia

(em elaboracao)

16. Criptografia simétrica: AES, modos de operação e AEAD

(em elaboracao)

17. Funções hash, HMAC e integridade

(em elaboracao)

18. Criptografia assimétrica: RSA, Diffie-Hellman e curvas elípticas

(em elaboracao)

19. PKI, certificados digitais e cadeias de confiança

(em elaboracao)

20. TLS na prática: handshake, versões e configuração segura

(em elaboracao)

21. Erros clássicos: criptografia mal empregada

(em elaboracao)

Parte IV.

**Volume 4 — Identidade, Autenticação e
Controle de Acesso**

22. Modelos de controle de acesso: DAC, MAC, RBAC e ABAC

(em elaboracao)

23. Senhas: armazenamento, políticas e ataques

(em elaboracao)

24. Autenticação multifator e fatores de autenticação

(em elaboracao)

25. Federação de identidade: SAML, OAuth 2.0 e OpenID Connect

(em elaboracao)

26. Gestão de identidades e de acessos privilegiados (IAM e PAM)

(em elaboracao)

27. Arquitetura Zero Trust

(em elaboracao)

Parte V.

Volume 5 — Segurança de Redes

28. Arquitetura segura e segmentação de redes

(em elaboracao)

29. Firewalls: tipos, políticas e boas práticas

(em elaboracao)

30. VPNs: IPsec, WireGuard e acesso remoto seguro

(em elaboracao)

31. IDS, IPS e detecção em rede

(em elaboracao)

32. Segurança de DNS: ataques, DNSSEC e DoH

(em elaboracao)

33. Segurança do roteamento e BGP: sequestros, vazamentos e RPKI

(em elaboracao)

34. Segurança em redes sem fio e enlaces de rádio

(em elaboracao)

35. Ataques de negação de serviço e estratégias de mitigação

(em elaboracao)

Parte VI.

**Volume 6 — Endpoints e Sistemas
Operacionais**

36. Hardening de servidores Linux

(em elaboracao)

37. Hardening de Windows e Active Directory

(em elaboracao)

38. Antivírus, EDR e XDR

(em elaboracao)

39. Gestão de vulnerabilidades e ciclo de patches

(em elaboracao)

40. Segurança de dispositivos móveis e BYOD

(em elaboracao)

41. Criptografia de disco e proteção de dados em repouso

(em elaboracao)

Parte VII.

Volume 7 — Segurança de Aplicações

42. Ciclo de desenvolvimento seguro e DevSecOps

(em elaboracao)

43. OWASP Top 10: panorama e como usar

(em elaboracao)

44. Injeção: SQL, NoSQL e comandos de sistema

(em elaboracao)

45. Cross-site scripting e ataques no lado do cliente

(em elaboracao)

46. Falhas de autenticação e gestão de sessão

(em elaboracao)

47. Falhas de controle de acesso: IDOR, SSRF e escalonamento

(em elaboracao)

48. Segurança de APIs REST e GraphQL

(em elaboracao)

49. SAST, DAST, SCA e automação de testes de segurança

(em elaboracao)

Parte VIII.

Volume 8 — Nuvem e Contêineres

50. Modelo de responsabilidade compartilhada

(em elaboracao)

51. IAM em nuvem e os erros de configuração mais caros

(em elaboracao)

52. Segurança de contêineres e de imagens

(em elaboracao)

53. Segurança em Kubernetes

(em elaboracao)

54. Infraestrutura como código e segurança de pipeline

(em elaboracao)

55. Segredos, cofres e gestão de chaves

(em elaboracao)

Parte IX.

Volume 9 — Testes de Invasão

56. Metodologias e definição de escopo: PTES, OSSTMM e NIST SP 800-115

(em elaboracao)

57. Reconhecimento passivo e OSINT

(em elaboracao)

58. Varredura e enumeração

(em elaboracao)

59. Análise de vulnerabilidades

(em elaboracao)

60. Exploração: conceitos e anatomia de uma falha

(em elaboracao)

61. Pós-exploração, persistência e movimentação lateral

(em elaboracao)

62. Teste de invasão em aplicações web na prática

(em elaboracao)

63. Relatório técnico e comunicação de achados

(em elaboracao)

Parte X.

Volume 10 — Fator Humano

64. Engenharia social: os princípios psicológicos da persuasão

(em elaboracao)

65. Phishing, spear phishing e fraude do e-mail corporativo

(em elaboracao)

66. Fraudes digitais no Brasil: Pix, clonagem e golpes por mensageria

(em elaboracao)

67. Segurança física e ataques presenciais

(em elaboracao)

68. Cultura de segurança e programas de conscientização

(em elaboracao)

Parte XI.

**Volume 11 — Malware e Inteligência de
Ameaças**

69. Taxonomia de malware

(em elaboracao)

70. Anatomia de um ataque de ransomware

(em elaboracao)

71. Análise estática em laboratório

(em elaboracao)

72. Análise dinâmica e sandboxing

(em elaboracao)

73. MITRE ATT&CK e o mapeamento de TTPs

(em elaboracao)

74. Inteligência de ameaças e indicadores de comprometimento

(em elaboracao)

Parte XII.

**Volume 12 — Blue Team, SOC e
Detecção**

75. Estrutura e operação de um SOC

(em elaboracao)

76. Logging: o que registrar, por quanto tempo e por quê

(em elaboracao)

77. SIEM: arquitetura, ingestão e correlação

(em elaboracao)

78. Escrita de regras de detecção com Sigma e YARA

(em elaboracao)

79. Threat hunting: caçando o que a regra não pegou

(em elaboracao)

80. Deception: honeypots, honeytokens e canários

(em elaboracao)

81. Métricas e maturidade da detecção

(em elaboracao)

Parte XIII.

**Volume 13 — Resposta a Incidentes e
Forense Digital**

82. O ciclo de resposta a incidentes

(em elaboracao)

83. Preparação: plano, papéis e playbooks

(em elaboracao)

84. Contenção, erradicação e recuperação

(em elaboracao)

85. Fundamentos de forense digital e cadeia de custódia

(em elaboracao)

86. Forense de disco e sistemas de arquivos

(em elaboracao)

87. Forense de memória

(em elaboracao)

88. Forense de rede e análise de tráfego

(em elaboracao)

Parte XIV.

Volume 14 — Continuidade e Resiliência

89. Backup: estratégias e a regra 3-2-1-1-0

(em elaboracao)

90. Recuperação de desastres e continuidade de negócio

(em elaboracao)

91. Testes de continuidade e exercícios de mesa

(em elaboracao)

92. Alta disponibilidade e resiliência de infraestrutura

(em elaboracao)

93. Recuperação após um ataque de ransomware

(em elaboracao)

Parte XV.

**Volume 15 — Governança, Risco e
Conformidade**

94. Governança de segurança e o papel do CISO

(em elaboracao)

95. ISO/IEC 27001 e 27002

(em elaboracao)

96. NIST Cybersecurity Framework e CIS Controls

(em elaboracao)

97. LGPD na prática: bases legais, incidentes e a ANPD

(em elaboracao)

98. Marco Civil, Lei 12.737 e o direito penal digital brasileiro

(em elaboracao)

99. Obrigações regulatórias de provedores de internet

(em elaboracao)

100. PCI-DSS e requisitos setoriais

(em elaboracao)

101. Auditoria, conformidade e gestão de riscos de terceiros

(em elaboracao)

Parte XVI.

Volume 16 — Fronteira e Carreira

102. Segurança de sistemas de IA e modelos de linguagem

(em elaboracao)

103. Criptografia pós-quântica

(em elaboracao)

104. Segurança de OT, IoT e sistemas embarcados

(em elaboracao)

105. Segurança da cadeia de suprimentos de software

(em elaboracao)

106. Privacidade, anonimato e vigilância

(em elaboracao)

107. Carreira, certificações e aprendizado contínuo

(em elaboracao)

Referências

AGÊNCIA NACIONAL DE TELECOMUNICAÇÕES. Resolução n. 717, de 23 de dezembro de 2019. Regulamento de Qualidade dos Serviços de Telecomunicações — RQUAL., 2019.

AGÊNCIA NACIONAL DE TELECOMUNICAÇÕES. Resolução n. 740, de 21 de dezembro de 2020. Regulamento de Segurança Cibernética Aplicada aos Produtos de Telecomunicações., 2020.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Guia orientativo: segurança da informação para agentes de tratamento de pequeno porte., 2023.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Resolução CD/ANPD n. 15, de 24 de abril de 2024. Aprova o Regulamento de Comunicação de Incidente de Segurança., 2024.

BANCO CENTRAL DO BRASIL. Resolução CMN n. 4.893, de 26 de fevereiro de 2021. Política de segurança cibernética das instituições financeiras., 2021.

BRASIL. Lei n. 9.296, de 24 de julho de 1996. Regulamenta o inciso XII do art. 5º da Constituição Federal., 1996.

BRASIL. Medida Provisória n. 2.200-2, de 24 de agosto de 2001. Institui a Infraestrutura de Chaves Públicas Brasileira — ICP-Brasil., 2001.

BRASIL. Lei n. 12.737, de 30 de novembro de 2012. Tipificação criminal de delitos informáticos., 2012.

BRASIL. Lei n. 12.965, de 23 de abril de 2014. Marco Civil da Internet., 2014.

BRASIL. Lei n. 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais., 2018.

BRASIL. Lei n. 14.063, de 23 de setembro de 2020. Assinaturas eletrônicas em interações com entes públicos., 2020.

BRASIL. Lei n. 14.155, de 27 de maio de 2021. Agrava as penas dos crimes de invasão de dispositivo informático, furto e estelionato cometidos de forma eletrônica., 2021.

BRASIL. Decreto n. 11.491, de 12 de abril de 2023. Promulga a Convenção sobre o Crime Cibernético (Convenção de Budapeste)., 2023.

CENTER FOR INTERNET SECURITY. CIS Benchmarks., 2024.

CERT.BR. Práticas de Segurança para Administradores de Redes Internet., 2024.

- CROCKER, Dave; HANSEN, Tony; KUCHERAWY, Murray. **DomainKeys Identified Mail (DKIM) Signatures.**, 2011.
- FERGUSON, Paul; SENIE, Daniel. **Network Ingress Filtering: Defeating Denial of Service Attacks which employ IP Source Address Spoofing.**, 2000.
- FIELDING, Roy T.; NOTTINGHAM, Mark; RESCHKE, Julian. **HTTP Semantics.**, 2022.
- FORUM OF INCIDENT RESPONSE AND SECURITY TEAMS. **Common Vulnerability Scoring System version 4.0: specification document.**, 2023.
- FREUND, Jack; JONES, Jack. **Measuring and Managing Information Risk: A FAIR Approach.** [S.l.]: Butterworth-Heinemann, 2014.
- FULLER, Vince; LI, Tony. **Classless Inter-domain Routing (CIDR): The Internet Address Assignment and Aggregation Plan.**, 2006.
- HOFFMAN, Paul; MCMANUS, Patrick. **DNS Queries over HTTPS (DoH).**, 2018.
- HUBBARD, Douglas W.; SEIERSEN, Richard. **How to Measure Anything in Cybersecurity Risk.** [S.l.]: Wiley, 2016.
- INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27000: information technology — security techniques — information security management systems — overview and vocabulary.** GenebraISO, a2018.
- INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO 31000: risk management — guidelines.** GenebraISO, b2018.
- INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 29147: information technology — security techniques — vulnerability disclosure.** GenebraISO, c2018.
- INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 30111: information technology — security techniques — vulnerability handling processes.** GenebraISO, 2019.
- INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27005: information security, cybersecurity and privacy protection — guidance on managing information security risks.** GenebraISO, 2022.
- ISC2. **ISC2 Code of Ethics.**, 2024.
- IYENGAR, Jana; THOMSON, Martin. **QUIC: A UDP-Based Multiplexed and Secure Transport.**, 2021.
- KITTERMAN, Scott. **Sender Policy Framework (SPF) for Authorizing Use of Domains in Email, Version 1.**, 2014.
- KUCHERAWY, Murray; ZWICKY, Elizabeth. **Domain-based Message Authentication, Reporting, and Conformance (DMARC).**, 2015.

KUROSE, James F.; ROSS, Keith W. **Redes de Computadores e a Internet: uma abordagem top-down**. 8. ed. [S.l.]: Pearson, 2021.

MITRE CORPORATION. **MITRE ATT&CK: adversarial tactics, techniques and common knowledge**., 2024.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **Guide to Security for Full Virtualization Technologies**., 2011.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **Guide for Conducting Risk Assessments**., 2012.

PARKER, Donn B. **Fighting Computer Crime: A New Framework for Protecting Information**. [S.l.]: Wiley, 1998.

REKHTER, Yakov *et al.* **Address Allocation for Private Internets**., 1996.

SALTZER, Jerome H.; SCHROEDER, Michael D. The Protection of Information in Computer Systems. **Proceedings of the IEEE**, v. 63, n. 9, p. 1278–1308, 1975.

SCHNEIER, Bruce. Attack Trees. **Dr. Dobb's Journal**, v. 24, n. 12, p. 21–29, 1999.

SCHNEIER, Bruce. **Secrets and Lies: Digital Security in a Networked World**. [S.l.]: Wiley, 2000.

SHOSTACK, Adam. **Threat Modeling: Designing for Security**. [S.l.]: Wiley, 2014.

